



**Technical Proposal For:
Higher Colleges of Technology (HCT)**

**Requirement For:
Secure Access Service Edge (SASE) – 3 years**

Ref.No. NE-26-0129

Submitted by
Inspira MEA IT Solutions L.L.C

Submission Date
September 7, 2026



Contents

COVER LETTER	4
1 COMPANY PROFILE	5
2 CONTEXT & EXECUTIVE OVERVIEW	9
3 WHY ZSCALER.....	9
4 PART 1- PROPOSED SOLUTION: ZSCALER INTERNET ACCESS (ZIA)	10
4.1 UNDERSTANDING THE ZIA CLOUD ARCHITECTURE.....	12
4.1.1 Zscaler Central Authority	12
4.1.2 ZIA Public Service Edges	12
4.1.3 Nanolog Clusters.....	13
4.2 TRAFFIC FORWARDING.....	13
4.2.1 Zscaler Client Connector.....	14
4.2.2 GRE Tunnels	14
4.2.3 IPSec Tunnels.....	14
4.2.4 PAC Files	14
4.2.5 Cloud/Branch Connector	15
4.3 ZSCALER ZERO TRUST FIREWALL	15
4.3.1 Zscaler Cloud Native Firewall Key Capabilities	16
4.3.2 Zscaler Zero Trust Firewall Core Features:	17
4.3.3 Zscaler Zero Trust Firewall Licensing:.....	18
4.4 ZSCALER ZERO TRUST SANDBOXING	20
4.4.1 Zscaler Sandboxing Key Capabilities	21
4.4.2 Zscaler Sandboxing Core Features	22
4.4.3 Zscaler Sandboxing Licensing.....	23
4.5 ZSCALER ZERO TRUST BROWSER (ZTBROWSER)	24
4.5.1 Zscaler Cloud Browser Key Capabilities.....	24
4.5.2 How Zscaler Cloud Browser Works.....	24
4.5.3 Zscaler Zero Trust Enterprise Browser (EB)	25
4.6 ZSCALER AI GUARD FOR USERS	26
4.6.1 Key Capabilities of AI Guard	26
4.6.2 AI Guard for Users Architecture	27
5 PART 2 PROPOSED SOLUTION: ZSCALER PRIVATE ACCESS (ZPA).....	28
5.1 KEY CAPABILITIES.....	28
5.2 GETTING STARTED WITH ZPA.....	28
5.3 ZPA CLOUD ARCHITECTURE.....	29
5.3.1 ZPA Central Authority.....	29
5.3.2 ZPA Public Service Edges and ZPA Private Service Edges	30
5.3.3 App Connectors	30
5.3.4 Logging Streaming Service	30
5.4 TRAFFIC FORWARDING.....	31
5.4.1 Zscaler Client Connector.....	31
5.4.2 Browser Access.....	31
5.5 UNDERSTANDING COMMUNICATION BETWEEN COMPONENTS AND SUBSYSTEMS.....	32
5.5.1 Zscaler Tunnel	32
5.5.2 Microtunnel.....	33
5.6 TRANSITIONING TO A ZERO TRUST ZPA DEPLOYMENT	33
5.7 AI-POWERED SEGMENTATION	34
5.8 ZSCALER VPN (FOR LEGACY APPS)	36
5.8.1 ZPA Architecture for VoIP and Server-to-Client Apps: Network Connectors, Secondary Tunnel, and Zero Trust Exchange	36
6 PART 3- PROPOSED SOLUTION: ZSCALER DIGITAL EXPERIENCE MONITORING (ZDX)	37

6.1	KEY CAPABILITIES.....	38
6.2	UNDERSTANDING ZDX PROBES	38
6.2.1	ZDX Web Probes.....	39
6.2.2	ZDX Cloud Path Probes.....	40
6.3	APPLICATIONS MONITORING.....	41
6.3.1	Applications Definition.....	42
6.3.2	Defining Custom Applications and Probes for ZDX	42
6.4	ZDX, ZPA AND PRIVATE APPLICATIONS	43
6.5	DEVICE SCORING AND DEVICE EVENTS	43
7	PART 4 - TECHNICAL REQUIREMENT COMPLIANCE	45
7.1	SASE PLATFORM	45
7.2	HCT INFORMATION SECURITY REQUIREMENTS BASELINE	87
8	PART 5- STATEMENT OF WORK	92
8.1	IDENTITY INTEGRATION & ZCC ENROLMENT	92
8.2	ZIA BUSINESS EDITION BASELINE	92
8.3	CYBER THREAT PROTECTION — SANDBOX & FIREWALL ADVANCED.....	92
8.4	SECURE AI ACCESS.....	93
8.5	ZERO TRUST BROWSER ADVANCED	93
8.6	ZDX ADVANCED PLUS	93
8.7	ZSCALER PRIVATE ACCESS (ZPA)	93
9	IMPLEMENTATION & MIGRATION APPROACH	93
10	PROJECT PLAN — 3 MONTHS	95
11	BOQ	95
12	PROPOSED TEAM STRUCTURE.....	97
13	ASSUMPTIONS	97
14	DEPENDENCIES.....	98
15	OUT OF SCOPE	98
16	PROJECT CHANGE REQUEST FORM PROCEDURE	98
17	PLACE(S) OF PERFORMANCE	98
18	DELIVERABLES.....	99
19	MISCELLANEOUS	100
20	CLIENTELE	101
21	PAST PROJECT SUCCESS AND REFERENCES.....	102
22	INDICATIVE PROFILES.....	104
23	VENDOR POINT OF CONTACT	105

Cover Letter

Inspira MEA IT Solutions L.L.C
Dubai, UAE

To:
Higher Colleges of Technology (HCT)
Abu Dhabi, UAE

RE: Technical Proposal for Secure Access Service Edge (SASE) – 3 years
Ref.No. NE-26-0129

Dear Sir/Ma'am,

On behalf of **Inspira MEA IT Solutions L.L.C**, thank you for the chance to respond to the **Higher Colleges of Technology (HCT)** solicitation for seeking the **Secure Access Service Edge (SASE) – 3 years**. We believe our proposal successfully addresses Client's need to evolve and have related support services to a more predictable and cost-effective consumption model that leverages innovation to transform its current environment quickly, efficiently, and securely. As a trusted service partner, Inspira is positioned to help Client achieve these objectives, offering some unique advantages.

Inspira Enterprise, a global organization specializing in cybersecurity assessment, with operations in UAE, KSA, Oman, Kenya, the USA, Singapore, the Philippines, and India, have exhaustive experience to execute such engagements. We believe that security and protection of information systems are not technology challenges, but that addressing People, Process, and Technology will give 360-degree protection to the systems. Our engagements are enriched by our common control frameworks comprising multiple standards, regulatory norms, laws, and industry best practices. When it comes to secure businesses, our approach is Security by Default and by Design.

Inspira is 1500+ employee organization. We specialize in the Cybersecurity domain, Identity & Access Management, Security Operations Centre, Managed Security Services, Data Analytics, and Data Loss Protection. Our team profiles demonstrate the accumulated experience of over 18+ years in the field of Information Security. Our governance framework is managed by professionals who have served banks, healthcare, real estate, Oil & Gas, Government, and other sectors, and they each carry at least 25+ years of experience.

We are committed to providing our clients with the highest level of service and support, and we work closely with our clients to ensure that our solutions are tailored to their specific needs and requirements. Our customer-centric approach has earned us a reputation for excellence in the industry, and we are proud to have many long-standing relationships with our clients.

We would welcome the opportunity to discuss your needs further and explore how we can help you achieve your security and compliance goals. Please do not hesitate to contact us to schedule a consultation.

Sincerely,

Sunil Krishnarao
Country Head (UAE)
Inspira MEA IT Solutions L.L.C
Dubai, UAE
+971521903533
sunil.krishnarao@inspiraenterprise.com

1 Company Profile

Overview

Inspira recognizes the importance of this project for the client and is confident in its ability to deliver a comprehensive and effective solution that meets all your requirements.

Inspira Enterprise is a Global Digital Transformation service provider with offices and customers across the Americas, Asia Pacific, Middle East, India, and Africa regions. Inspira offers end-to-end analytics services.

Inspira Enterprise has been in business in India since 2008, for approximately 18+ years.

WHO WE ARE

CYBER RESILIENCE. END-TO-END.

Inspira empowers enterprises to design, transform, and operate modern cybersecurity, at scale and at speed.

We bring together **strategy, architecture, engineering, and AI-driven operations** to help organizations stay resilient against today's threats and tomorrow's unknowns.

01. Cyber Advisory, Compliance & Transformation	02. AI-Powered Cyber Defense via our Global Cyber Fusion Centres	03. Modernize Identity-first security foundations: secure, seamless & scalable	04. Cloud, Infrastructure & Platform Security Acceleration
05. Continuous Exposure, Threat & Vulnerability Management	06. Safeguard Data, Applications & OT/IOT environments	07. Managed & AI- Driven MDR & SOC Services	

WHY INSPIRA

BUILT FOR TRUST

 Customer-first delivery	 AI-accelerated security maturity
 Deep Partnership & OEM ecosystem	 Proven enterprise outcomes across Fortune 500 & global enterprises



18+ Years of Experience	1500+ Security Professionals	5 Cyber Fusion Centers	600+ Active Clientele Spanning 10+ Countries	100+ Advisory and Domain Specialists	30+ Alliances and Partnerships
--------------------------------------	---	-------------------------------------	---	---	---

Inspira has collaborated with many organizations, helping them secure their digital assets with leading cybersecurity services and solutions for over a decade. Since then, we have guided our clients with their control implementations as they have embarked on securing their digital assets and customer experience. Our cybersecurity practice is structured to allow our clients to focus on “outcomes” while we leverage leading practices and solutions to support your vision. The categories of services we offer are:

- **Cyber Transformation**– Our services in this category are designed to enable the modernization and transformation of an organization’s cybersecurity posture to support business outcomes. This portfolio includes a wide array of services, from Identity and Access Management to Security Operations modernization and Cloud Migration. In summary, we can leverage our deep cybersecurity domain expertise to assist our clients in taking actionable steps following cybersecurity assessments.
- **Cyber Advisory** – Our services in this category are designed to support our clients who are seeking security assessment services or our guidance/advice on a future state cybersecurity strategy and roadmap for their organization. We also specialize in providing domain-specific assessment and strategy services. For example, we can offer assessment services that are based on compliance frameworks such as the National Institute of Standards and Technology (NIST) – Cybersecurity Framework (CSF) or the Center for Internet Security (CIS). Similarly, specialized assessments and program planning initiatives, such as Security risk assessment strategies and roadmaps, are provided under this category of service.
- **Cyber Operations** – Our services in this category enable our clients to offload security operations to take advantage of the operational efficiencies offered by our integrated managed services with an accelerated path toward automation. In addition, the clients that leverage us for cyber operations benefit from investments that we make in enhancing our services (e.g., automation) in alignment with leading industry practices. For example, we have a globally recognized, mature, multi-tenant 24x7X365 SOC-as-a-service setup suitable for organizations large and small. Our SOC practice helps you improve the cybersecurity posture with minimum effort on your side, thus enabling you to respond to threats robustly and with precision.

HOW WE CREATE IMPACT

OUTCOMES. OPTIMIZED.



Faster detection & response with AI



Reduced risk exposure



Security teams that scale



Compliance without complexity



Optimized security spends

AI-DRIVEN. OUTCOME-FOCUSED. GLOBAL.





HEALTHCARE & BIOTECH

- Protect Patient & Org. Safety
- Safeguard Sensitive Health Data
- Secure Digital Connected Devices



ENERGY & UTILITIES

- Secure IT-OT, Smart Grid Ecosystems
- Resilience, Operational Continuity
- Meet Regulatory & Safety Mandates



PUBLIC SECTOR

- Protect Critical Infra & Services
- Safeguard Citizen data
- National Security & Governance



BANKING & FINANCIAL SERVICES

- Protect financial Assets, Audit & Compliance
- Early Detection, Rapid Response
- Enable Secure Digital Banking



RETAIL, MANU. & LOGISTICS

- Secure Omnichannel & Supply Chain
- Protect Customer Trust / Identities
- Safeguard OT& IOT Security

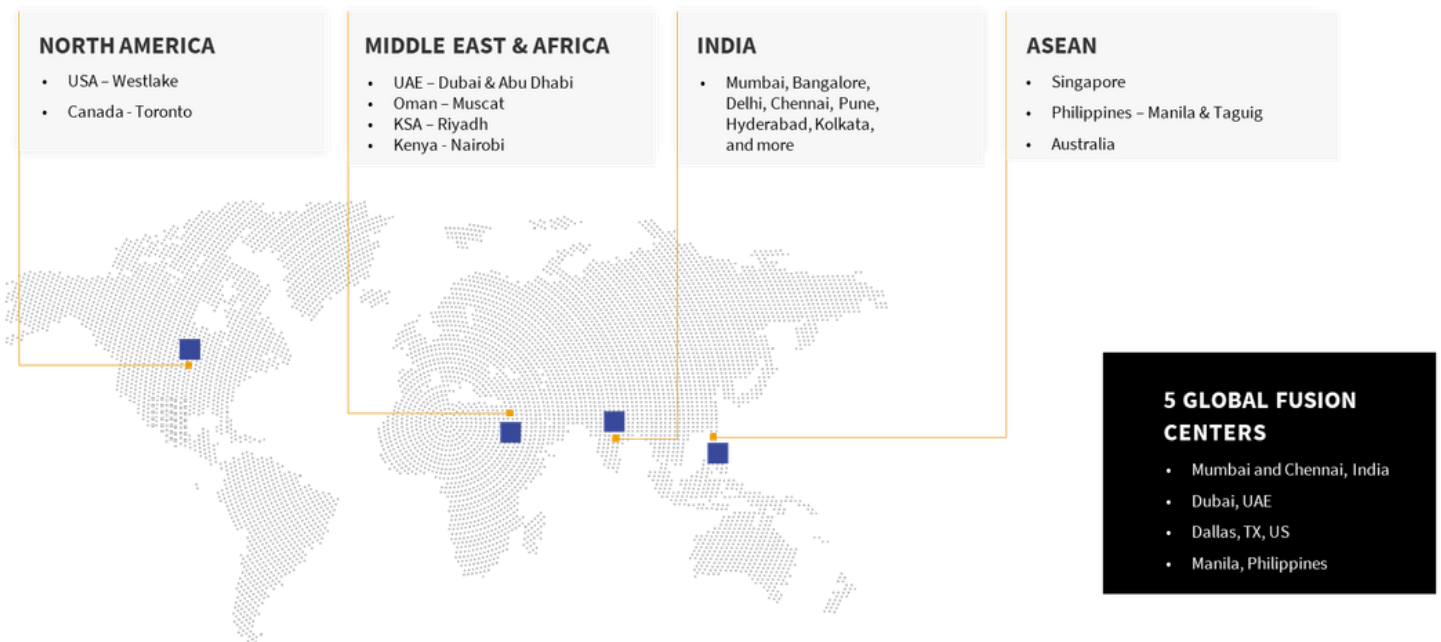


TELCO, MEDIA & TRANSPORT

- Protect Digital Platforms
- Privacy & Compliance
- Secure Cloud Native Ecosystems

GLOBAL FOOTPRINT

LOCAL. EVERYWHERE.



- **Industry Standards Achieved by Inspira** -Inspira holds several internationally recognized certifications, including ISO 27001 for information security, ISO 9000 for quality management, ISO 20000 for IT service management, SOC 2 Type II for security and availability, ISO 22301, ISO 9001, GDPR, and CMMI Level 4/5 certifications. These certifications not only showcase our global competency but also demonstrate our commitment to the highest standards in information security, quality management, IT service delivery, and process maturity. In addition, we have been recognized by IDC MarketScape in 2024, Everest Group in 2023, and Forrester in 2020.

Inspira's recognition for excellence:

Recognition Type	Award/Recognition Details
 Industry Leader	IDC MarketScape Leader in Worldwide Emerging MDR Services (2024) & Risk Assessment Vendor Assessment (2023), Everest Group IAM "Major Contender" (2025) & Leader in the Cybersecurity Services for Mid-Market (2025), Top 250 MSSP Globally (MSSP Alert), Top 35 MSSP in Forrester's Now Tech: Managed Security Services, SKOCH Award
 Partner Excellence	Microsoft Security Partner of the Year (India & South Asia, 2024), Exabeam Partner of the Year (2025), Saviynt Implementation Partner of the Year (2023), Splunk APAC Rookie Partner of the Year (2021), Westcon Thuglife Partner (2023)
 Technical Prowess	1st Place Winner: Global Entra Permissions Management Hackathon (Microsoft , 2023), Visionary Partner for OT Security (Flying The Next 500, 2023)
 Brand & Solution	2024 Iconic Brand of India (Economic Times), VARINDIA Best Solution Partner (2024), 2025 TIPS Awarded Vendor

Vision

Our vision is to provide high-quality, cost efficient, and highly secure IT infrastructure solutions that enable the convergence of applications and emerging technologies for e-Governance, PSUs, and large enterprises.

Mission

Company: Achieve profitable and sustainable growth.

Partners: Enhance the value of the partnership through our market understanding and technical expertise.

Customers: Create long term relationships by being responsive, relevant, and consistently delivering value.

People: Create an environment of trust and growth, "Can Do" attitude, by being respectful, honest, and persistent.

Core Values

Best people and respect for the individuals – We attract, develop, and retain the best talent for us business. We value ideas and the unique contributions of our people, and encourage an informal, mutually supportive, and open work environment.

Integrity

Being ethical, honest, and trustworthy. There is complete coordination between the words that we say, our behaviour, and actions, i.e., saying what we mean, matching our behaviors to our words, and taking responsibility for our actions.

Excellence is a journey!! We ensure quality in all aspects of our work and take pride in our products and solutions.

Innovation that brings a difference to our client's business.

Commitment is dedicated to the success of our customers, partners, and employees.

2 Context & Executive Overview

Higher Colleges of Technology (**HCT**) is taking a visionary step in its digital transformation journey by seeking a unified, scalable, and resilient cloud-delivered Secure Access Service Edge (**SASE**) platform.

As the largest applied higher education institution in the United Arab Emirates, operating 17 campuses across Abu Dhabi, Dubai, and the Northern Emirates, **HCT** requires a modern cybersecurity posture capable of seamlessly protecting both managed staff devices and student Bring Your Own Device (**BYOD**) environments without sacrificing performance or operational agility.

Today's Threat Landscape presents unprecedented challenges: organizations face high-volume, highly sophisticated cyber threats, including ransomware, advanced phishing attacks, malware, and data exfiltration. These risks are exacerbated by cloud adoption, hybrid learning models, and direct-to-internet traffic flows. Legacy perimeter-based architectures and appliance-centric web gateways can no longer provide consistent security enforcement or holistic visibility for modern, distributed user populations.

To solve these challenges, **Zscaler** is delighted to present this proposal for the **Zscaler Zero Trust Exchange™** platform. Powered by **Zscaler Internet Access (ZIA)** and optionally augmented by **Zscaler Private Access (ZPA / ZTNA)**, our cloud-native solution eliminates the complexity of fragmented legacy security stacks, providing unified, AI-powered protection for every HCT campus, user, and device.

3 Why Zscaler

Zscaler is a leading cloud enterprise security provider helping global businesses adopt zero trust for secure digital transformation.

Leveraging the largest security cloud on the planet, Zscaler anticipates, secures, and simplifies the experience of doing business for the world's most established companies.

We've achieved incredible growth since our founding in 2007, and today, we exist to create a world in which the exchange of information is always secure and seamless. It's our mission to anticipate, secure, and simplify the experience of doing business—transforming today and tomorrow.

The most trusted name in zero trust + AI

40%

of Global 2000
companies use Zscaler

500B+

transactions secured
daily by Zscaler

>70

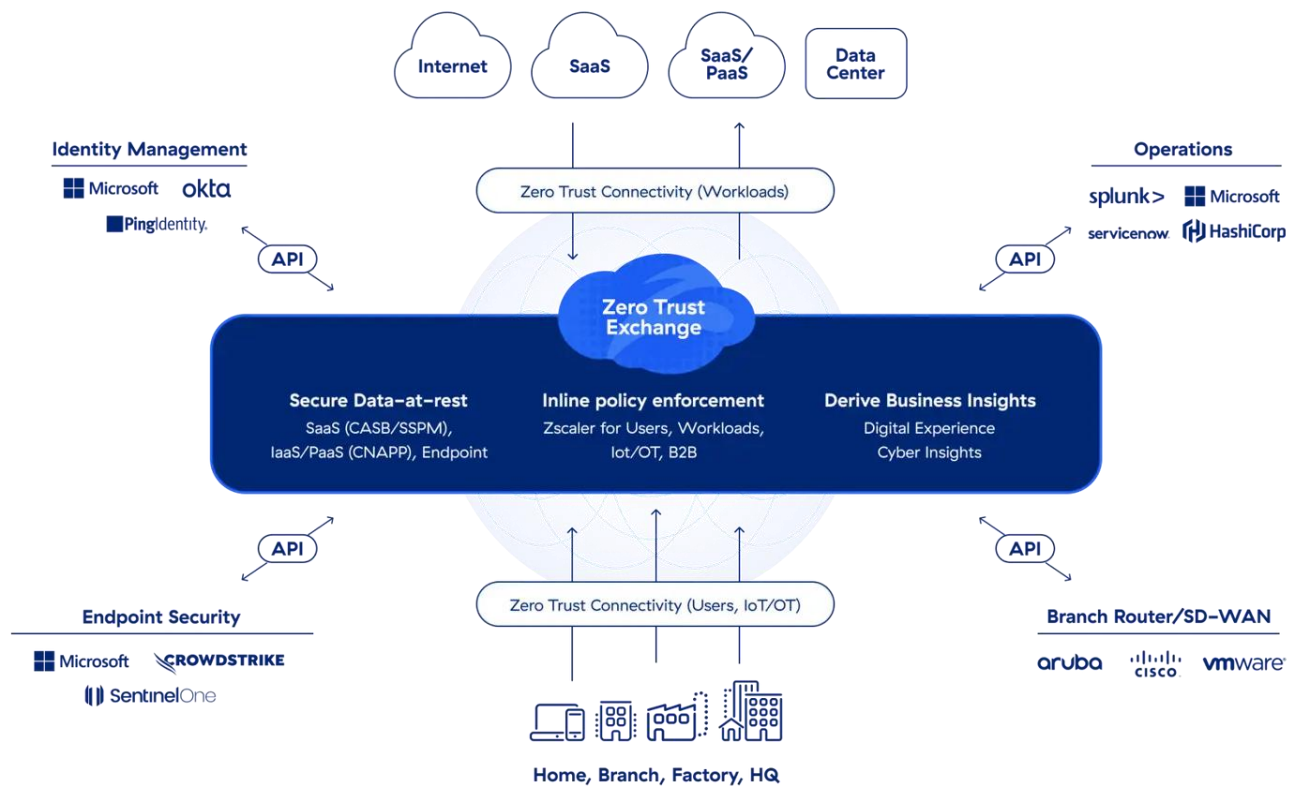
Net Promoter Score

Zscaler was positioned as a clear Leader as a Secure Service Edge provider with a leading Zero Trust Network Access (ZTNA) solution from prominent industry analysts Gartner and Forrester:

- A Leader in the 2026 Gartner® Magic Quadrant™ for Security Service Edge (SSE) and Secure Access Service Edge (SASE)
<https://www.zscaler.com/gartner-magic-quadrant-security-service-edge-sse>
- A 2025 Customers' Choice in the Gartner® Peer Insights™ "Voice of the Customer" for Security Service Edge
<https://www.zscaler.com/campaign/2025-gartner-customers-choice-sse>
- A Leader in The Forrester Wave™: Secure Access Service Edge Solutions, Q3 2025.
<https://www.zscaler.com/campaign/forrester-wave-sase-solutions>
- Zscaler Gets 100% Security Efficacy Score in the 2025 CyberRatings SSE Test
<https://www.zscaler.com/campaign/zscaler-sse-test-results-2025>
- Zscaler Gets 100% Security Efficacy Score in the 2025 CyberRatings ZTNA Test
<https://www.zscaler.com/campaign/cyberratings-ztna-security-2025>
- A Leader in The Forrester Wave™: Security Service Edge Solutions, Q1 2024.

<https://www.zscaler.com/forrester-wave-security-service-edge>

Our ecosystem of partners and integrations enables faster and more reliable deployments, facilitates easier and more agile operations, and enhances our customers' cloud experience.



4 Part 1- Proposed Solution: Zscaler Internet Access (ZIA)

Securing today's cloud- and mobile-first enterprise requires a fundamentally different approach built on zero trust. Zscaler Internet Access, part of the Zscaler Zero Trust Exchange™, is the world's most deployed security service edge (SSE) platform, built on a decade of secure web gateway leadership.

Delivered as a scalable and resilient SaaS cloud security platform, ZIA eliminates legacy network security solutions to stop advanced attacks and prevent data loss with a comprehensive zero trust approach, offering:

- **Best-in-class, consistent security for today's hybrid workforce:** When you move security to the cloud, all users, apps, devices, and locations get always-on threat protection based on identity and context. Your security policy goes everywhere your users go.
- **Lightning-fast access with zero infrastructure:** Direct-to-cloud architecture ensures a fast, seamless user experience. This eliminates backhauling, improves performance and user experience, and simplifies network administration—with no physical infrastructure required.
- **AI-powered protection from the world's largest security cloud:** Inline inspection of all internet and SaaS traffic, including SSL decryption, with a suite of AI-powered cloud security services to stop ransomware, phishing, zero-day malware, and advanced attacks based on threat intelligence from 500 trillion daily signals.

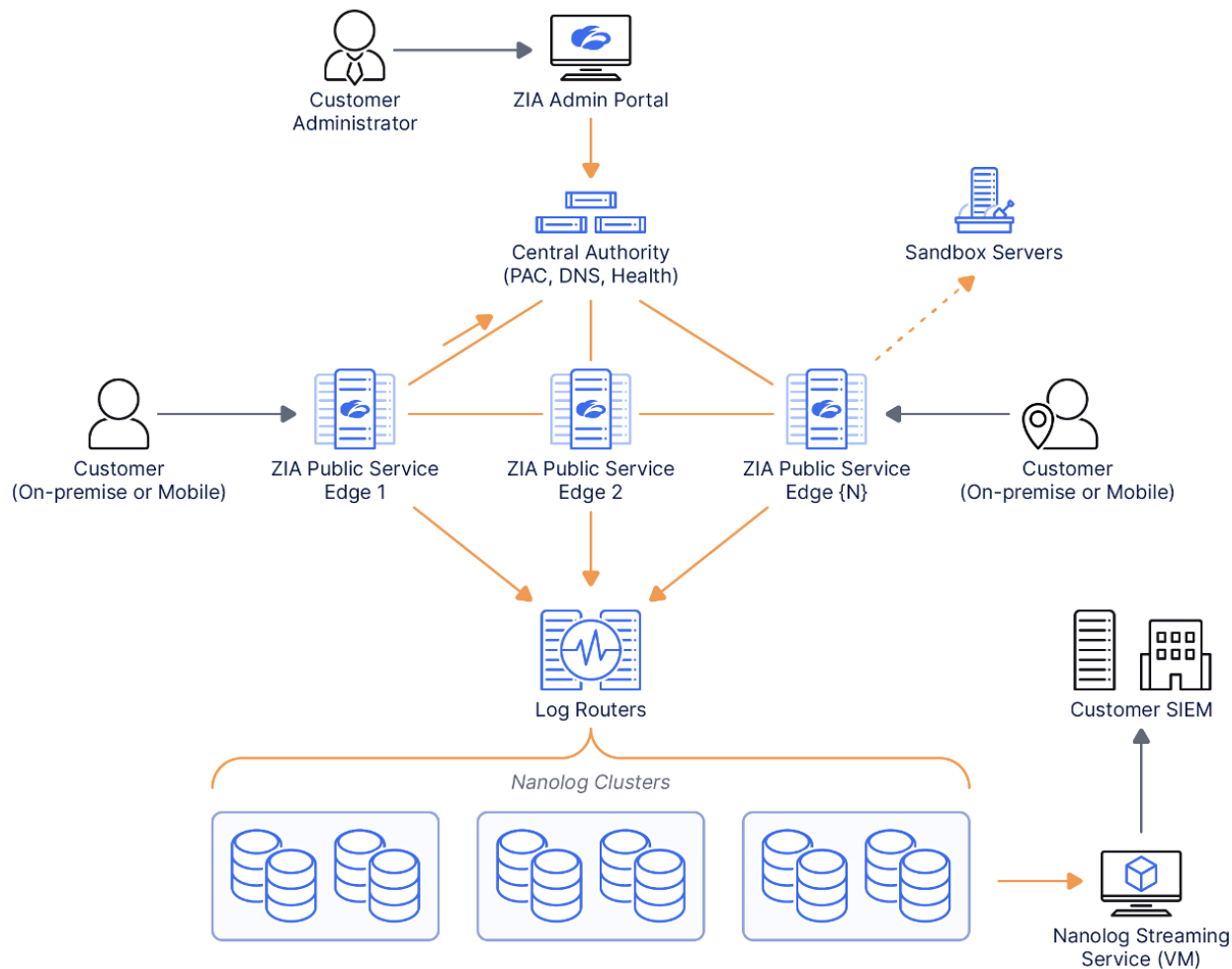
- **Simplified management:** Using a cloud native security solution infused with AI, less hardware to manage, automation to streamline workflows, and business-focused policy creation frees up valuable time for your team to focus on strategic goals.

Zscaler Internet Access includes a comprehensive suite of AI-powered security and data protection services to help you stop cyberattacks and data loss. As a fully cloud-delivered SaaS solution, you can add new capabilities without any additional hardware or lengthy deployment cycles. The modules available as part of Zscaler Internet Access are:

- **Cloud Secure Web Gateway (SWG):** Deliver a safe, fast web experience that eliminates ransomware, malware, and other advanced attacks with real-time, AI-powered analysis and URL filtering.
- **Cloud Access Security Broker (CASB):** Secure cloud apps with integrated CASB to protect data, stop threats, and ensure compliance across your SaaS and IaaS environments.
- **Cloud Data Loss Prevention (DLP):** Protect data in motion with full inline inspection and advanced measures like exact data match (EDM), optical character recognition (OCR), and machine learning.
- **Zscaler Firewall & cloud IPS:** Extend industry- leading protection to all ports and protocols and replace edge and branch firewalls with a cloud native platform.
- **Zscaler Sandbox:** Stop never-before-seen and elusive malware across web and file transfer protocols with AI-driven quarantine, sharing consistent and global protection across all users in real time.
- **AI-Powered Zero Trust Browser:** Make web-based attacks obsolete and prevent data loss by creating a virtual air gap between users, the web, and SaaS.
- **Zero Trust Branch Connectivity:** Reduce risk and complexity with non-routable branch and data center connectivity for users, servers, and IOT/OT devices.
- **DNS Security:** Optimize DNS security and performance for all users, devices, and applications, on all ports and protocols, anywhere in the world.

4.1 Understanding the ZIA Cloud Architecture

Zscaler operates the world's largest security-as-a-service (SECaaS) cloud platform to provide the industry's only 100% cloud-delivered web and mobile security solution. The highly scalable, global, multi-cloud infrastructure features three key components: the Zscaler Central Authority (CA), ZIA Public Service Edges, and Nanolog clusters.



4.1.1 Zscaler Central Authority

The Zscaler Internet Access (ZIA) Central Authority (CA) is the brain and nervous system of a Zscaler cloud. It monitors the cloud and provides a central location for software and database updates, policy and configuration settings, and threat intelligence. The CA consists of one active server and two servers in passive standby mode. The active CA replicates data in real time to the two standby CAs, so any of them can become active at any time. Each server is hosted in a separate location to ensure fault tolerance.

4.1.2 ZIA Public Service Edges

ZIA Public Service Edges are full-featured, inline internet security gateways that inspect all internet traffic bi-directionally for malware and enforce security and compliance policies.

An organisation can forward its traffic to any ZIA Public Service Edge in the world or use the advanced geo-IP resolution capability of Zscaler to direct its users' traffic to the nearest ZIA Public Service Edge.

When the user moves to a different location, the policy follows the user, with the ZIA Public Service Edge downloading the appropriate policy. Customer traffic is not passed to any other component within the Zscaler infrastructure. The TCP stack on the ZIA Public Service Edge runs in user mode and is specially crafted to ensure multitenancy and data security. ZIA Public Service Edges never store any data to disk.

Log data generated for every transaction is compressed, tokenized, and exported over secure TLS connections to Log Routers that direct the logs to the Nanolog cluster, hosted in the appropriate geographical region, for each organization.

ZIA Public Service Edges are always deployed in active-active load-balancing mode all over the world, and the CA monitors the health of ZIA Public Service Edges to ensure availability.

4.1.3 Nanolog Clusters

Nanolog clusters store transaction logs and provide reports. Each cluster consists of one active server and two servers in passive standby mode.

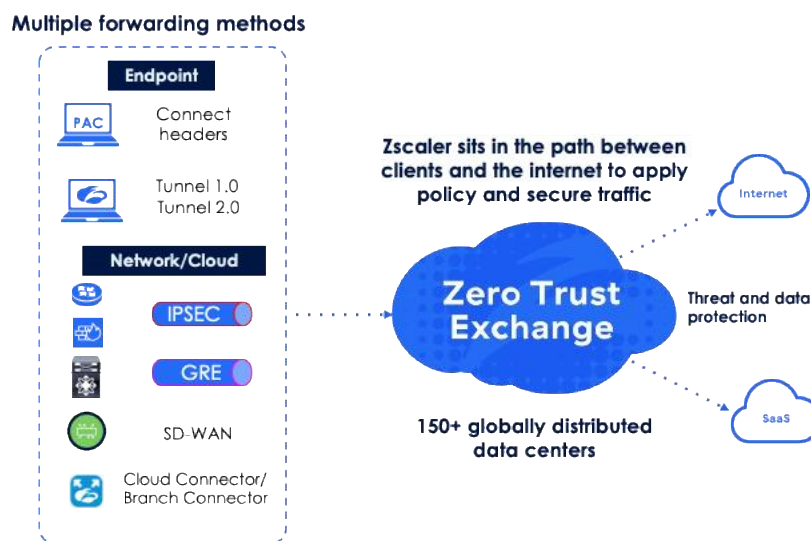
The active Nanolog immediately replicates data to the other two servers, so any of them can become active at any time, with no data loss. Each Nanolog server is hosted in a separate location to ensure fault tolerance.

Every second, a Nanolog cluster receives logs from all over the world, correlates them to a specific customer organization, and writes them to disk for high-speed retrieval of reporting and analytics.

A Nanolog cluster processes up to 1.2+ billion logs per day. Additionally, Zscaler offers a Nanolog Streaming Service (NSS), which uses a virtual appliance to stream web and firewall traffic logs in real time from the Zscaler Nanolog to the customer's security information and event management (SIEM) system.

4.2 Traffic Forwarding

Zscaler supports the following traffic forwarding mechanisms.

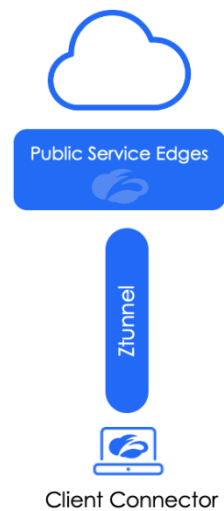


Depending on your environment and requirements, you can choose one or a combination of the following traffic forwarding methods. Zscaler recommends that you use a combination of tunneling, PAC files, Zscaler Client Connector, and Zscaler Cloud Connector to forward traffic to the Zscaler service.

4.2.1 Zscaler Client Connector

Zscaler recommends that you install Zscaler Client Connector on your users' devices to protect their web traffic when they are accessing the internet from an unknown location (i.e., remote users).

With Zscaler Client Connector's internet security feature, you can protect your users' web traffic even when they are outside your corporate network. The app forwards user traffic to the Zscaler service and ensures that your organization's security and access policies are enforced wherever they might be accessing the internet from. The app automatically detects when the user is no longer within the secure network, then automatically creates a connection to the Zscaler service from an unknown location.

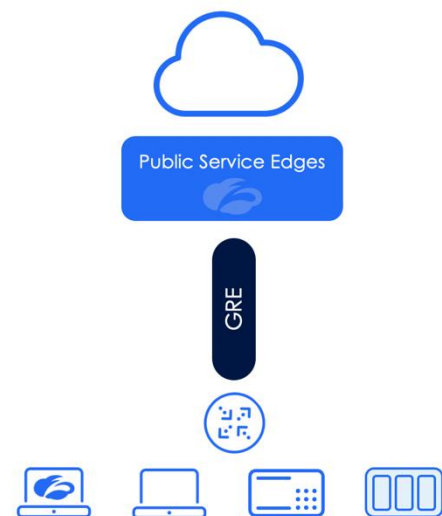


4.2.2 GRE Tunnels

A GRE tunnel can be used for forwarding internet-bound traffic from your corporate network to the Zscaler service.

If your organization has an internal router or switch that supports GRE and its egress port has a static address, you can configure a GRE tunnel.

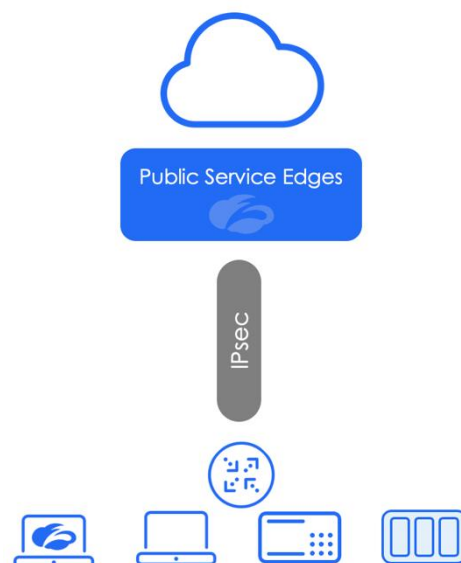
Zscaler recommends that you configure two GRE tunnels from an internal router behind the firewall to the ZIA Public Service Edges: a primary tunnel to a ZIA Public Service Edge in one data center and a secondary tunnel to a ZIA Public Service Edge in another data center. These deployments provide visibility into internal IP addresses, which can be used for security policies and logging.



4.2.3 IPSec Tunnels

IPSec is a suite of protocols that provide network-layer security to a Virtual Private Network (VPN). If your router does not support GRE or if you use dynamic IP addresses, you can configure IPSec VPN tunnels.

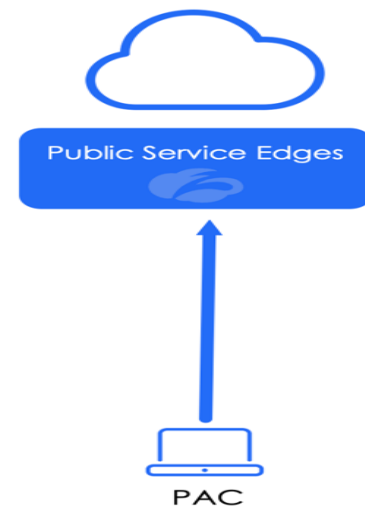
Zscaler recommends that you configure two IPSec tunnels from an internal router behind the firewall to the ZIA Public Service Edges: a primary tunnel to a ZIA Public Service Edge in one data center and a secondary tunnel to a ZIA Public Service Edge in another data center. These deployments provide visibility into internal IP addresses, which can be used for security policies and logging.



4.2.4 PAC Files

A PAC file is a text file that directs the browser to forward traffic to a ZIA Public Service Edge. You can install a PAC file for each of your users to ensure coverage outside the corporate network.

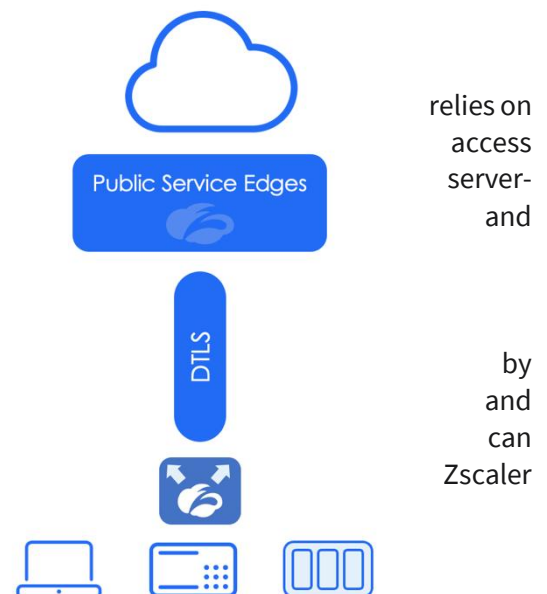
If certain applications need to be excluded from the Zscaler service, it is easy to write an exclude statement in your PAC file to send traffic directly. Using PAC files allows you to set exceptions for forwarding your traffic, such as excluding intranet corporate sites from the Zscaler service.



4.2.5 Cloud/Branch Connector

Zscaler Cloud/Branch Connector works similarly to Zscaler Client Connector, using software-defined networking (SDN) principles. It a unified Zero Trust Architecture for connectivity, security, and to the Zscaler cloud. It works by establishing zero trust access for to-server traffic, east-west traffic in a public cloud, IT/OT networks, data centers.

Cloud Connector simplifies traffic forwarding to the Zscaler service securing server access to the internet and providing highly secure simplified access to the Zscaler cloud. Using Cloud Connector, you forward specific web traffic or application traffic through the cloud.



4.3 Zscaler Zero Trust Firewall

Zscaler Zero Trust Firewall delivers cloud-based protection for non-web traffic (DNS, FTP, RDP, SSH, Telnet and more), while Zscaler Internet Access (ZIA) delivers deep inspection for web traffic (HTTP/HTTPS). Together, they secure all ports and protocols, including non-web applications and non-standard web, across all users, devices and locations.

Zero Trust Firewall improves connectivity and performance by enabling local internet breakout—eliminating the need for VPN backhauling or redundant on-premises appliance stacks.

Zero Trust Firewall helps organizations easily meet regulatory standards while universally configuring, managing, and enforcing user- and application-aware threat protection and risk-based policies to ensure network and application visibility with a centralized policy management console. As a true firewall-as-a-service (FWaaS) solution—built from the ground up for the cloud—Zscaler Zero Trust Firewall eliminates the need for hardware provisioning or managed service models, delivering elastic scale and policy control without legacy limitations.

Zscaler Zero Trust Firewall provides forensically complete logs for every session, capturing detailed attributes such as user identity, device info, source and destination IPs, port, country, threat category, and more. This rich visibility across all users, devices, and locations eliminates the need for packet capture tools and ensures organizations have access to the right information at the right time.

4.3.1 Zscaler Cloud Native Firewall Key Capabilities

- **Purpose-Built For Today's Digital World:** Zscaler Zero Trust Firewall ensures you can securely access the internet and handle all web and non-web traffic, across all ports and protocols, with infinite elastic scalability and unbeatable performance. Your users get consistent protection no matter what device they're using or where they are—at home, HQ or branch offices, or on the road—without the cost, complexity, and performance limitations of traditional network security and next-generation firewall appliances.
- **Powered by an Adaptive Zero Trust Platform:** Stop compromising on static inspections, performance degradation, and capacity limits from physical firewall appliances. Built on a fully integrated, cloud-native platform, Zscaler Zero Trust Firewall elastically scales to handle cloud application traffic requiring long-lived connections while natively intercepting and inspecting TLS/SSL traffic—at scale—to detect malware hidden in encrypted traffic.
- **Transformative Hybrid and Branch Connections:** Evolve from costly and network-centric infrastructure to true cloud-delivered local internet breakouts. Route internet traffic locally to provide direct-to-cloud connections for consistently fast connections while delivering security and access controls for all ports and protocols. Without the need for any appliances to deploy or manage, this reduces MPLS backhauling costs and eliminates expensive and time-consuming patch management, coordination of outage windows, and policy management.
- **Ubiquitous Security for Modern Workforces:** Leverage real-time security updates informed by 500+ trillion daily signals and shared across the entire cloud each day for identical protection on any device wherever users connect. Bringing the entire security stack close to the user provides unparalleled user- and app-aware threat protection with dynamic, follow-me policies on and off the corporate network.
- **Always-On Blocking of Known Malicious Attacks:** Go where traditional solutions can't with a cloud-delivered intrusion prevention system (IPS) managed by Zscaler ThreatLabz. Through unlimited inline traffic inspection, including IoT/OT and encrypted traffic, behavioral IPS signatures are applied in real time across thousands of web-based and non-web applications.
- **DNS Optimization for Performance and Security:** Achieve faster resolution by pairing geographically local apps, driving better user experience and cloud app performance while implementing Domain Name System (DNS) security and control policies. With TLS/SSL inspection at scale, gain back visibility and stop attackers from abusing DNS-over-HTTPS (DoH), better protecting users and employees from reaching malicious domains and bypassing enterprise policies. By delivering DNS-as-a-service, Zscaler minimises latency and secures local internet breakouts using full proxies for all DNS traffic and leverages machine learning to detect and block data exfiltration tunnel activity.
- **Easy-To-Understand Policy Management:** Universally define, deploy, and immediately enforce policies for all users, across all locations from a single console. In place of complex matrices of policies, network configurations and recreating policies for each location of typical firewalls, Zero Trust Firewall simplifies policy management by centralizing granular firewall rules based upon user, application, location, group, and department.
- **Enforce Precise Policies with Process-Level Awareness:** Extend Firewall, DNS, and IPS controls beyond IPs and ports by identifying the actual application process running on the device - such as PowerShell.exe or Chrome.exe. This enables security teams to block or allow activity based on the true source of the connection, reducing false positives, enhancing threat detection, and allowing more targeted risk response.

4.3.2 Zscaler Zero Trust Firewall Core Features:

Feature Name	Description
Centralized policy management	Define and immediately enforce policies across all locations without the need to recreate policies for each location.
Fully integrated security services	Share contextual information across DLP, APT, sandbox, and other services to provide better protection and deeper visibility.
Real-time granular control, logging, and visibility	Maintain forensically rich logging for detailed visibility with globally unified and unlimited logging for six months, enabling analysis and correlation for trend discovery, productivity analysis, and troubleshooting.
User-aware threat protection	Define users by Groups, Departments, or Locations, including setting work-from-home or remote users as a location, and integrate with identity providers and local user databases, allowing consistent policies regardless of users' physical locations.
Endpoint App Control	Define and enforce policies based on the actual application process running on the device, such as PowerShell or Chrome, enabling more precise control, reducing false positives, and providing stronger protection against targeted threats and insider activity.
App-aware threat protection	Supports a wide range of application types: • All network services - ports and protocols • Network applications identified by SNI (hostname) and Deep Packet Inspection (DPI) • Application Services such as UCaaS, using First Packet Identification, IP address, FQDN groups, and other heuristic-based detection methods
Advanced security inspection	Apply advanced deep-packet inspection on non-web protocols, including FTP, DNS, RDP, Telnet, and more, to identify and prevent evasive traffic on non-standard ports.
Adaptive IPS security with custom rules	Deliver always-on threat prevention with a cloud-delivered IPS engine powered by thousands of adaptive, behavioral, and context-aware signatures managed by Zscaler ThreatLabz. Gain additional control with Cloud Custom IPS, allowing you to define and enforce Snort-based rules tailored to specific applications, threats or compliance needs.
	Communicate security policy actions to end users through desktop pop-ups via Client Connector for Firewall, DNS, and IPS, or browser-based messages

End user notifications (EUN)	for DNS blocks with web EUN, helping users understand why access was denied and reducing IT support queries.
Granular role-based access control (RBAC)	Create and assign custom admin roles—such as SecOps or NetOps—with controls over who can view, edit, or manage security policies, logs, and alerts to enhance operational clarity and enforce least-privileged access across teams.
DNS security and control	Optimize cloud application performance and minimize latency while ensuring uncompromised security by proxying all DNS through Zscaler. Enable policies based on user, app, location, and resolved IP country to automatically block users from malicious domains and detect and prevent DNS tunnelling • Resolution: DNS-as-a-service provides optimal resolution with localisation, tenancy, and lowest latency • DNS Filtering: Create custom DNS filtering rules to block, allow, or redirect different types of DNS requests against known and malicious destinations • Security and Data Exfiltration: Detect malware, phishing, DNS tunnelling, and data exfiltration using AI • DNS over HTTPS (DoH): Prevent DoH blind spots and bypassing of organizational controls when encrypting DNS connections in common HTTPS traffic
Fully qualified domain name (FQDN) policies	Easily configure and manage access policies for applications hosted across multiple IPs
File Transfer Protocol (FTP) control and Network Address Translation (NAT) support	Support access control of FTP and FTP over HTTP and support for NAT destination proxy and NAT forwarding.
Globally shared protection	Leverage the cloud effect: every time a new threat is identified in any of the tens of billions of requests processed daily by the Zscaler cloud, it gets blocked for all Zscaler users, everywhere.

4.3.3 Zscaler Zero Trust Firewall Licensing:

Zscaler provides two levels of license for our firewall: standard and advanced.

Zscaler is proposing the advanced firewall license for **Higher Colleges of Technology (HCT)** to cover advanced firewalling requirements as well as DNS security requirements.

	Standard	Advanced
Zero Trust Firewall Policy Criteria		
Network and Application Services	 Up to 10 rules	
Source/Dest L3/4 and FQDN-based policies		
Location Awareness		
User Awareness	-	
Network Application (DPI)	-	
Dynamic Risk-Based Policy	-	
Geo-blocking (source & destination country)		
Firewall Rules	 Up to 10 rules	 Up to 10,000+ rules
Granular Role-Based Access Control (RBAC)		
End User Notifications (EUN)	 Web notifications for any DNS action	 ZCC notifications for any Firewall, DNS and IPS action
Endpoint App Control for process precision	-	
DNS Control		
Trusted DNS Resolver		
DNS Filtering and Security	 Up to 64 rules	
DNS Tunnel and App Detection	-	
IPs Control with Custom Rules	-	

Ftp Control	✓	✓
Nat Control	✓	✓
Platform Features		
Full SSL Inspection	✓	✓
Real-time Logging	✓ Aggregated logging details for allowed firewall actions and detailed logging details for block actions with full DNS logs	✓ All logs for all actions and all functions including user ID, App ID, IPs, and more

4.4 Zscaler Zero Trust Sandboxing

Built on a cloud native, proxy-based architecture, Zscaler Cloud Sandbox is the world's first AI-driven inline malware prevention engine that blocks unknown, file-based threats before they reach endpoints. With real-time analysis, instant AI-driven verdicts, and continuous threat intelligence sharing, our sandbox helps organizations stay ahead of sophisticated attacks without compromising productivity.

To cater to varying customer needs, the Zscaler Cloud Sandbox offers two options:

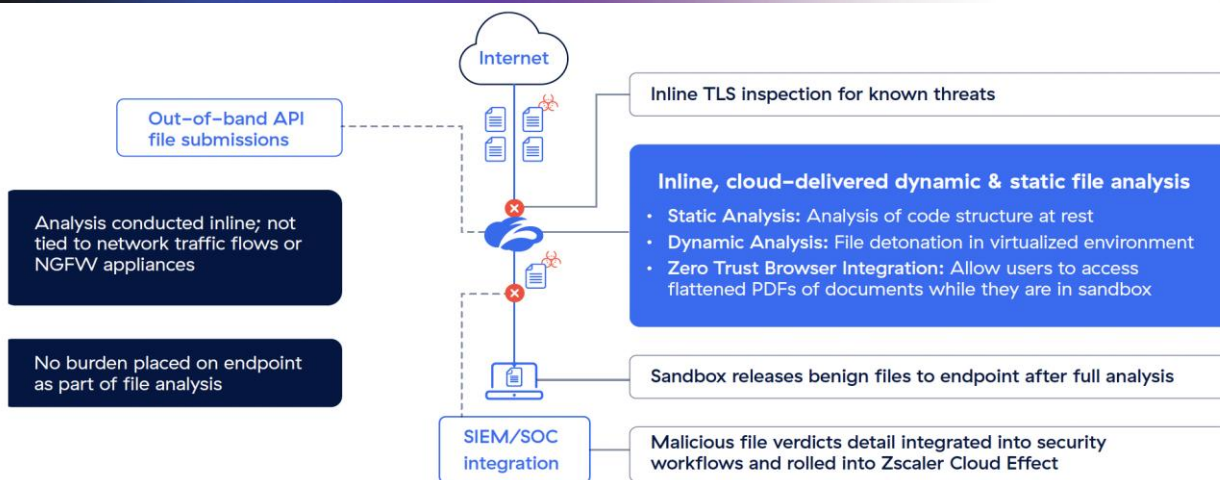
- Cloud Sandbox included with Zscaler Internet Access (ZIA) provides essential threat prevention capabilities for baseline protection.
- Advanced Cloud Sandbox delivers enhanced features such as AI Instant Verdict, granular policy control, API-driven analysis, and in-depth threat investigation for customers requiring more robust defenses.

Unlike traditional sandbox solutions that depend on network firewalls or endpoint-heavy agents, Zscaler Cloud Sandbox operates directly from the cloud. It eliminates the burden on endpoints, requires no reliance on network traffic flows, and seamlessly integrates into SOC workflows for faster, more effective threat detection and response.

The sandbox operates in two key modes to ensure flexible and comprehensive security:

- Inline Inspection: Files are analyzed as traffic flows through the cloud, and AI delivers real-time verdicts to block threats without latency.
- Out-of-Band Inspection: Files can be submitted via APIs for a quick scan or in-depth analysis as needed.

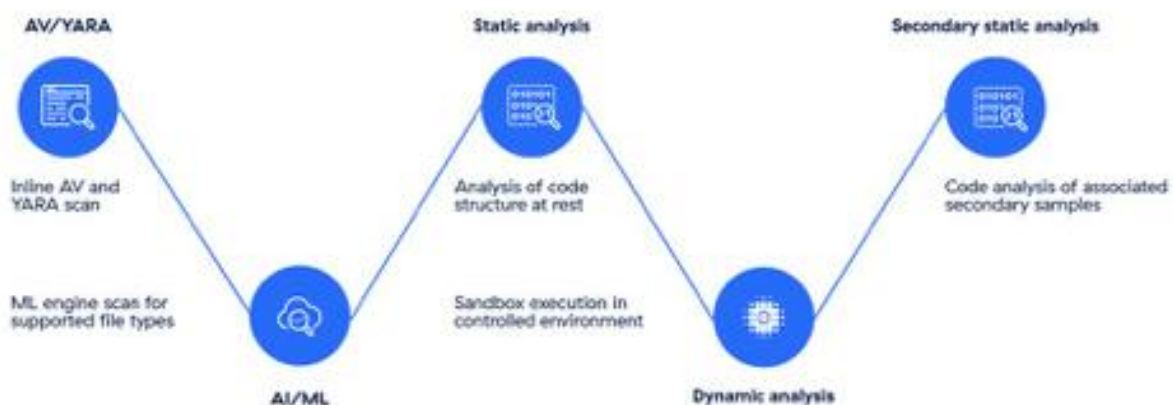
By offering foundational and advanced options, Zscaler ensures that customers of all sizes can benefit from layered security tailored to their needs.



4.4.1 Zscaler Sandboxing Key Capabilities

- AI-Powered Security:** Harness the power of AI/ML models trained on over 600 million samples to deliver instant, high-confidence verdicts on unknown files. The AI Instant Verdict engine predicts whether a file is malicious or benign in real time, allowing immediate blocking or rapid delivery to users without delay. For cases where files are flagged as “suspicious,” our customizable Minimum Threat Score enables users to fine-tune policy behavior, balancing security and productivity. All confirmed threats are further validated through the Advanced Cloud Sandbox, which generates detailed reports and comprehensively analyzes the threat.
- Layered Malware Detection:** Zscaler Cloud Sandbox delivers multilayered threat detection powered by real-time updates from over 500 trillion daily threat signals and the Zscaler Cloud Effect, which instantly blocks known threats for all customers once identified. The process begins with static analysis to inspect the file’s code structure while at rest, followed by dynamic analysis where the file is detonated in a virtualized environment to observe its behavior. A secondary static analysis examines any hidden or secondary payloads.

This layered approach, combined with inline protection and unlimited TLS/SSL inspection using our Single Scan, Multi-Action engine, ensures low-latency, high-performance threat prevention for even the most sophisticated, evolving threats.



- Zero Trust Browser Integration:** The Zero Trust Browser integrates seamlessly with the Advanced Cloud Sandbox to ensure users remain productive without compromising security. This feature allows users to securely interact with original files in a cloud-based, isolated environment while the files undergo sandbox analysis. Risky or unknown files are automatically quarantined, but users can still access them securely during the analysis. If the sandbox analysis determines the file is safe, users can download the original version without delays.

If the file is flagged as malicious, users have options: they can download a flattened PDF version with all active content removed (CDR- 1) or, when appropriate, download an editable version with only the harmful content removed (CDR-3, may require additional licensing). This flexible integration ensures that users remain productive while zero-day threats are thoroughly examined and blocked when necessary. It is important to note that Zero Trust Browser is an optional module and works in tandem with the Advanced Cloud Sandbox to enhance the overall user experience.

- **API-Driven Analysis:** Zscaler Cloud Sandbox’s API integration streamlines investigations by allowing files to be sent directly to the sandbox for analysis. Security teams can easily access sandbox results via APIs, ingest them into SIEMs, SOAR platforms, or share with EDR solutions, enabling seamless SOC workflows. After detonation, the sandbox generates comprehensive reports, highlighting polymorphism, callback behaviors, and attack lifecycles, mapped to the MITRE ATT&CK framework. These insights can be operationalized to enhance threat detection, response, and proactive threat hunting.

For flexibility, organizations can use the Advanced Sandbox Submission API for thorough analysis of files out-of-band, supporting on demand submission and reporting of unknown threats, or the Deep Inspection Scan API to receive an instant verdict on a file sample. Both APIs help reduce investigation times and enhance collaboration across the security stack.

- **Granular Policy Control and Reporting:** With Zscaler Cloud Sandbox, administrators can configure and enforce granular security policies tailored to specific user roles, locations, or application categories—all within just a few clicks. The intuitive interface allows for fast, simple policy creation and deployment, minimizing time and resource investment. Policies, including rule orders for precise execution, are easily managed and automatically follow users or groups, even when they change locations. For deeper control, admins can configure custom hash blocklists, YARA rules, and automated JA3 fingerprinting to enhance threat detection.

4.4.2 Zscaler Sandboxing Core Features

Capabilities	Description
Prefiltering engine	AV, file hash blocklists, YARA rules, automated JA3 fingerprinting detections, and ML/AI model
Static, dynamic, and secondary analysis	All files go through 3 stages of sandbox analysis: static analysis, dynamic analysis, and secondary static analysis of all files dropped during dynamic analysis.
File support	Check the following documentation for the list of supported file types: https://help.zscaler.com/zia/configuring-sandbox-policy
SSL inspection	Unlimited capacity
File retention	Zscaler Cloud Sandbox operates solely in memory. Files are stripped of identifiable information during analysis. After analysis is completed, benign files are purged from memory while malicious files are encrypted and stored indefinitely, sharing insights across all Zscaler’s users for continuous protection (Cloud Effect).
Protocol support	HTTP, HTTPS, FTP, FTP over HTTP
Files per day	Unlimited capacity (inline)
Deployment method	Cloud native, no on-premises hardware or NGFW hooks needed
Threat intel integration	40+ security partner threat intel feeds

Management and reporting	Full reporting including malware behavior and intent, indicators of compromise (IOCs), dropped files, PCAPs
Forensics	Initial sample, secondary payloads, PCAPs
API support	Robust API support, two sample submission APIs and report retrieval via API in JSON format in summary or detailed formats
Granular policies	Easy to use and configure policies for users, location, location groups, file types, user groups, departments, URL categories, and protocols
3rd Party Independent Validation	AAA rating by CyberRatings

4.4.3 Zscaler Sandboxing Licensing

Zscaler is proposing the advanced sandboxing license for **Higher Colleges of Technology (HCT)**

Feature	Value	Standard Cloud Sandbox	Advanced Cloud Sandbox
File type support	Broad file- type coverage. Expand protection against evolving threats.	 - Windows Executables - Windows Libraries - Zip archives	 Check the following documentation for the list of supported file types: https://help.zscaler.com/zia/configuring-sandbox-policy
AI Instant Verdict (AI/ML Quarantine and Blocking)	Allows benign or blocks malicious files in seconds with high confidence		 Available for select file types
Granular policies	Tailor security policies using multiple criteria--users, locations, URL categories, and more.	—	 Granular policies fitting many use cases can be created with ease.
Reporting	Detailed reports with MITRE ATT&CK matrix mappings, TTPs, malware behavior and intent, IOCs, PCAPs, and more for actionable insights	—	 Multiple reports and dashboards are available, providing rich insights.
API	Out-of-band API for on demand Sandbox file analysis	—	 Advanced Sandbox Submission API* (includes dynamic analysis) includes 3000 files per month by default Deep Inspection Scan API* (not including dynamic analysis) includes 5 files per day *Additional licensing may be required based on API usage requirements

Zero Trust Browser Integration	Automatically quarantines risky files, allowing users to safely access the file during sandbox analysis.	—	 Available for PDF and Microsoft Office files
---------------------------------------	--	---	---

4.5 Zscaler Zero Trust Browser (ZTBrowser)

Zero Trust Browser provides an organization the capability to isolate users from potentially harmful content on the internet. This is done by loading the accessed web page on a remote browser in any one of the many Zscaler data centers across the globe and streaming the rendered content as a stream of pixels to the user's native browser.

The overall solution of Zero Trust Browser consists of three primary components:

- A browser extension that handles web-based security and access
- A lightweight agent that enforces device posture controls and advanced data protection during the session
- And a cloud browser for accessing private applications in an isolated session.

Isolating web pages on an ephemeral, remote browser ensures that the HTML files, CSS files, JavaScript files, and any other active content served by the accessed web page never reach the user's machine or the corporate network, thus ensuring an air gap between the user and the web page they access.

Zero Trust Browser not only provides the capability to isolate web pages but also allows the user to view file types in isolation without requiring a download of the files to their local machine.

4.5.1 Zscaler Cloud Browser Key Capabilities

- **Secure Browsing:** Air-gapped browsing stops web threats to complement URL filtering, including AI-driven threat isolation stopping threats on any site that presents risk.

File isolation balances security and productivity, allowing users to interact with files in isolated sessions while preventing file-based threats from taking hold.

- **Secure Agentless Application Access:** Allow employees, contractors and third parties to safely access and use applications from any unmanaged device without the need for an agent. Allow employees, contractors and third parties to safely access and use applications from any unmanaged device without the need for an agent or VDI.

Fully isolate applications from users to eliminate the risk of vulnerable clients and malware-infected endpoints being leveraged by attackers to compromise applications.

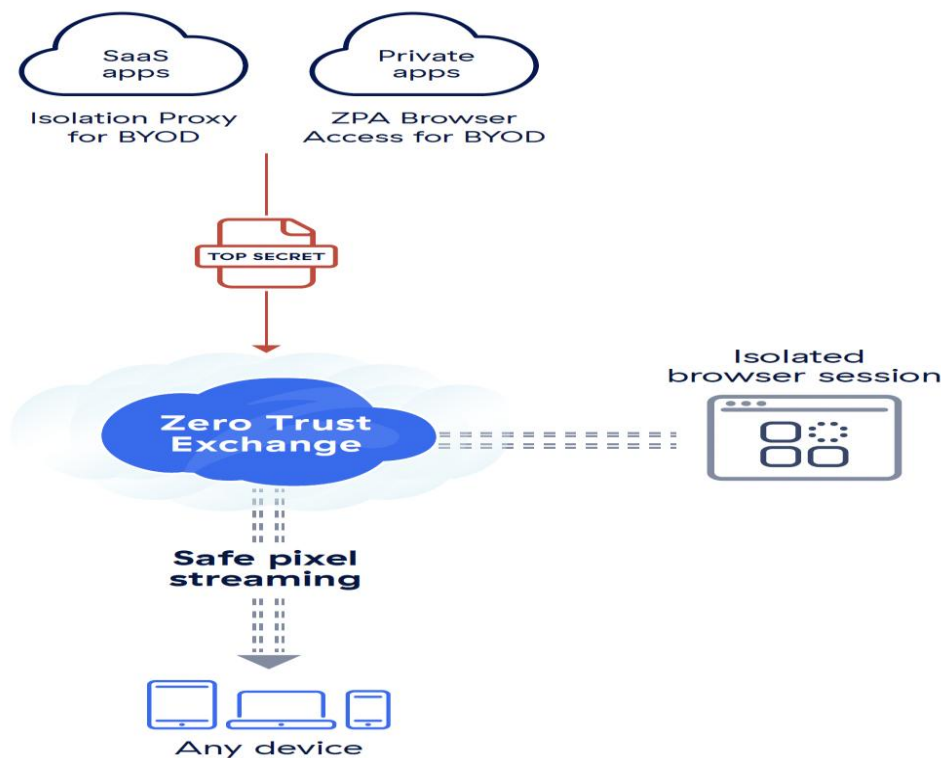
- **Stops Data Leakage:** Allows secure access to web-based SaaS and private applications while restricting copy, paste, and print to prevent data leakage and theft. Get granular control of upload and download activity across SaaS and private applications to protect confidential business data from ending up on unmanaged endpoints.

In addition to browser-based control, Zero Trust Browser enjoys full integration with Zscaler Data Protection portfolio to protect against sensitive data leakage.

4.5.2 How Zscaler Cloud Browser Works

For managed devices with Zscaler Client Connector, triggered policies for any app or web destination automatically isolate the session.

For unmanaged devices without ZCC, agentless access occurs via browser-based access in the Zero Trust Browser for both SaaS and web apps.



4.5.3 Zscaler Zero Trust Enterprise Browser (EB)

Zero Trust Enterprise Browser for Zero Trust Browser is for accessing private applications while in an isolated session. Traditional security technologies are not designed to focus on securing daily browser execution, and they often lack the needed layers of protection for all the complex operations that browsers perform. This feature enables organizations to detect, investigate, and control browser-native threats and sensitive data interactions in real time.

Enterprise Browser protects organizations without relying solely on traditional endpoint or network-centric controls. Instead, it combines several proactive methods: threat prevention, data encryption, and policy enforcement. It also utilizes tamper-resistant runtime on the browser for the entirety of a user's isolated session. Additionally, it continuously monitors malicious actions occurring inside browser sessions and fully analyzes user behavior as soon as the user starts interacting with web content.

The Enterprise Browser component prevents common attacks on users that occur in daily operations within browsers, such as:

- Accessing SaaS applications
- Uploading or downloading files
- Using browser extensions
- Interacting with generative AI (Gen AI) platforms
- Authenticating to cloud services
- Browsing internal and external websites
- Sharing sensitive information through collaboration tools

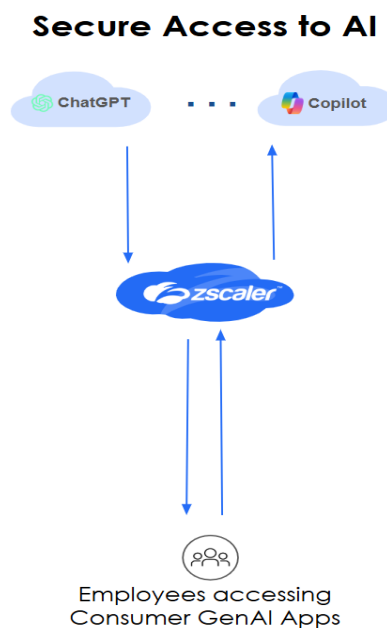
This feature is automatically part of the Zscaler offerings for Zero Trust Browser, and admins do not have to manually enable it for users. When a user enters isolation, the isolated browser utilizes the Enterprise Browser capabilities and maintains the native look and feel of a regular browser.

4.6 Zscaler AI Guard for Users

The rise of generative large language models (LLMs) has accelerated the pace of application innovation and increased productivity, with organizations customizing LLMs to their specific tasks. However, the proliferation of LLMs in apps and agents is creating new security challenges, including prompt injection, toxicity, and code leakage. This increasing adoption of LLMs necessitates the implementation of AI security in applications, in addition to cybersecurity and data security.

AI Guard is a service that provides run-time protection for your AI applications by enforcing enterprise policies that prevent prompt injections, block jailbreak attempts, and stop personal information leakage with guardrails around LLM interactions.

It secures these interactions by filtering harmful or inappropriate content from the prompts that users enter and the responses they receive in the AI application. AI Guard enforces intent-based detectors on both prompts and responses.



4.6.1 Key Capabilities of AI Guard

The following functionality and guardrails are some of the options available to you with AI Guard:

- **Visibility & Access Control:** You can monitor which applications are accessing private AI systems, with granular controls over access permissions. Visibility tools ensure complete oversight of private AI interactions across the enterprise.
- **Prompt Injection & Jailbreak Protection:** AI models can be manipulated with adversarial prompts to bypass restrictions or produce unintended outputs. The AI Guard guardrails detect and neutralise such attacks, ensuring that AI responses stay within defined safety parameters.
- **Toxicity:** AI-generated content can potentially be emotionally harmful for workers. AI Guard's guardrails apply real-time monitoring and filtering to prevent toxic language.
- **Sensitive Data Protection:** AI models can inadvertently expose or process confidential, regulated, or proprietary information. AI Guard enables inline inspection and classification to detect and block sensitive data before it is sent to AI APIs.
- **Off-Topic Response Detection:** AI Guard detects and prevents off-topic responses, ensuring that AI stays focused on its intended use cases.
- **Malicious URL Detection & Blocking:** AI-generated responses can sometimes include harmful or phishing links. AI Guard's solution actively scans links and blocks malicious URLs to prevent security threats and safeguard users from cyber risks.

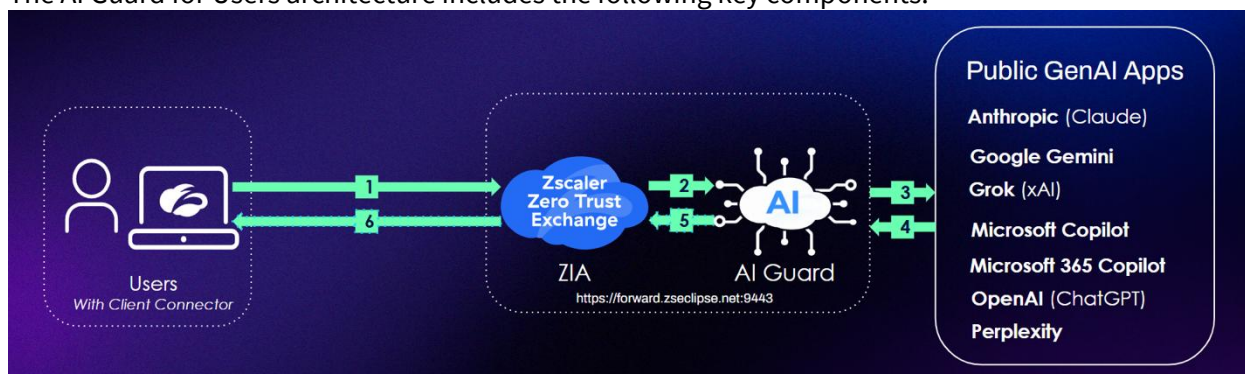
- **Language Detection & Enforcement:** Organizations can enforce AI interactions in specific approved languages, preventing unauthorized language use that can lead to miscommunication or security vulnerabilities.
- **Code Injection & Execution Detection:** AI Guard detects and prevents unauthorized code snippets embedded in AI interactions, protecting against potential security risks from malicious scripts or unauthorized automation attempts.
- **Gibberish & Low-Quality Prompt/Response Filtering:** AI models can sometimes produce nonsensical or low-value responses. Our system detects gibberish, meaningless text, and irrelevant output, ensuring that AI responses remain coherent and valuable.
- **Refusal Detection & Intervention:** When AI refuses to respond to valid queries due to overly restrictive filters or misunderstanding, our system flags and intervenes to alert the security team because it might be a denial-of-service attack.
- **Finance Advice:** AI Guard can block actionable financial guidance (investing, trading, tax, product choices); allows neutral finance facts, history, and definitions.
- **Prompt Tagging-based Access Control:** AI Guard has a prompt tagging model that automatically classifies prompts into different categories, enabling organizations to enforce AI governance, security, and compliance while optimizing AI interactions.
- **Competitor Discussion Detection:** You can identify and block prompts that reference competitors, rival products, pricing comparisons, or market strategies.
- **URL Reachability Detection:** AI-provided links can sometimes be outdated or unreachable. This guardrail verifies whether URLs in prompts are accessible, safe, or broken to prevent hallucinations.
- **Legal Advice:** Block prompts seeking legal advice, interpretation, or compliance guidance. This allows for neutral legal facts, definitions, and non-legal work inquiries.

4.6.2 AI Guard for Users Architecture

AI Guard for Users is a service that provides run-time protection for your generative AI (GenAI) applications on a per-user or user group basis by enforcing enterprise policies that prevent prompt injections, block jailbreak attempts, and stop personal information leakage with guardrails around LLM interactions.

It secures these interactions by filtering harmful or inappropriate content from the prompts that users enter and the responses they receive in the AI application. AI Guard enforces intent-based detectors on both prompts and responses.

The AI Guard for Users architecture includes the following key components:



1. **Signing in to ZIA:** Zscaler Client Connector authenticated users connect to ZIA to send traffic to it.
2. **User prompt is analyzed by AI Guard:** ZIA forwards traffic to the public GenAI apps using proxy chaining to the AI Guard infrastructure within Zscaler cloud (traditional Cloud App Controls, Web DLP, Threat Protection still occur here). If an AI Guard policy blocks the prompt, the traffic will not go to the GenAI apps.
3. **Prompts that aren't blocked are sent to GenAI apps:** If the prompt isn't blocked, AI Guard initiates (proxies) the traffic to the Gen AI apps.
4. **GenAI apps response sent to AI Guard:** The public GenAI apps return their response to AI Guard, where it is analyzed with policy response detectors if configured. If blocked, the user will instead receive a blocked message from AI Guard.
5. **Response sent through ZIA:** The response is sent back to ZIA.

6. User receives response: ZIA returns the response to the user.

5 Part 2 Proposed Solution: Zscaler Private Access (ZPA)

The Zscaler Private Access (ZPA) service enables organizations to provide access to internal applications and services while ensuring the security of their networks. ZPA is an easier to deploy, more cost-effective, and more secure alternative to VPNs. Unlike VPNs, which require users to connect to your network to access your enterprise applications, ZPA allows you to give users policy-based secure access only to the internal apps they need to get their work done. With ZPA, application access does not require network access.

While ZPA is for connecting users to an enterprise's internal applications, Zscaler Internet Access (ZIA) is for connecting users to public applications on the internet.

Additionally, ZPA decouples applications from the physical network so you can provide seamless connectivity to private internal applications and assets whether they are in the cloud, the data center, or both. It also adjusts dynamically to network changes, so you can move your resources without impacting user access.

You can configure settings and policies on a central ZPA Admin Portal, which also feature dashboards where you can see your users and the apps they access, and monitor the health of your servers and resources. You can configure ZPA to automatically discover servers and applications when users request them, or you can configure them manually as well. You then define policies that specify which apps users or groups can use, and ZPA allows them to connect to those apps only. ZPA renders your applications invisible to all but the authorized users and unrouteable to anyone.

5.1 Key Capabilities

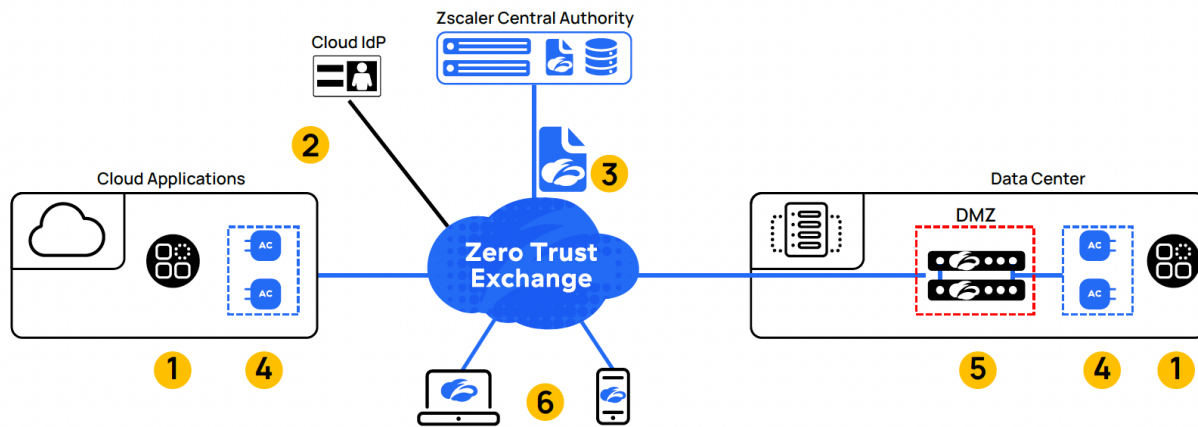
Below are ZPA key features and benefits:

- **Seamless User Experience:** Policy-driven connectivity that dynamically adjusts to network changes.
- **Enhanced Security:** Application-specific connectivity without ever bringing users on-net.
- **Ease of Deployment:** Does not require hardware or hardware upgrades.
- **Instant Deployment and Discovery:** Can automatically discover applications so you can easily build policies around them.
- **Single Sign-On (SSO):** ZPA is tied directly to your existing authentication infrastructure, leveraging SSO to further reduce complexity.
- **Real-Time Visibility:** Dashboards provide unparalleled visibility into your users and applications, and the health of your organization's applications and servers

5.2 Getting Started with ZPA

ZPA allows you to define a set of policies, authentication, and application definitions that combine to provide user access to applications. The ZPA service ensures that applications are available and that users have the correct policy applied.

The following ZPA components and configuration elements compose the foundation for implementing zero trust principles via user segmentation.



1. **Applications, Application Segments, and Segment Groups** – An application is a Fully Qualified Domain Name (FQDN), local domain name, or IP address that is defined on a standard set of ports. Applications must be defined within an application segment. Zscaler recommends using FQDN whenever possible. An application segment is a set of defined applications on shared ports across one or more back-end servers. A segment group is a set of application segments combined for policy purposes. Applications can be grouped into application segments and segment groups based on access type, authorized users, etc.
2. **SAML and SCIM Attributes** – SAML and SCIM attributes such as group membership, role, etc. are used in access policy rules to provide least-privilege access to applications. These attributes may originate in existing authentication/ authorization repositories, such as Active Directory, binding users to relevant groups that reflect onboarding, movement to different departments, changes such as termination, etc.
3. **Access Policy** – Access policy rules enable context-based access control. To configure an access policy rule, you must first define which applications or segment groups the rule controls, and then define the context required for access. Additional context for access policies may include device posture, access type, network location, and other context provided by the SAML Identity Provider (IdP).
4. **App Connectors** – App Connectors provide a secure, encrypted, authenticated interface between a customer's servers and applications and the ZPA cloud for delivering user traffic to back-end applications.
5. **Private Service Edge** – A ZPA Private Service Edge is a single-tenant instance that provides complete broker functionality of a ZPA Public Service Edge in an organization's environment. For an on-premises user connecting via a local Private Service Edge and local App Connector, all control-plane and data-plane traffic stays within the network; the Private Service Edge communicates to the Zscaler cloud for management plane (configuration, logging, etc.) and delivery of user traffic to remote resources.
6. **Zscaler Client Connector** – Zscaler Client Connector is an agent that resides on your mobile or desktop devices. Supported on popular operating systems such as Windows, macOS, Android, iOS, and CentOS, this agent connects your devices to Zscaler's Zero Trust Exchange. At the ZPA Service Edge, requests are evaluated and approved users are connected to appropriate applications.

5.3 ZPA Cloud Architecture

ZPA was built from the ground up to provide secure remote access.

ZPA runs on a unique multi-tenant infrastructure, separate from that of Zscaler Internet Access (ZIA) solution, in order to make the service highly available. This separation ensures that when the same organization is using both services, public and internal traffic never mix on the same device. Additional measures are used to ensure security and privacy between organizations using the ZPA service, and in many cases, traversing the same equipment. Finally, all communication is encrypted end-to-end.

The ZPA service includes the following key components and subsystems:

5.3.1 ZPA Central Authority

The ZPA Central Authority (CA) is the "brain and nervous system" of the ZPA cloud. It is a geographically distributed system of in-sync nodes that are all actively servicing requests. To learn more, see ZPA Public Service Edges and the Central Authority.

The ZPA CA monitors the cloud and provides a central location for software and database updates, as well as policy and configuration settings. Each component of the system is aware of the health of the entire cloud, and policy is distributed across all components of the CA. It includes user interfaces connected via APIs to configuration components, as well as distributed dispatchers that track real-time application states.

5.3.2 ZPA Public Service Edges and ZPA Private Service Edges

ZPA Public Service Edges and ZPA Private Service Edges enforce user policies and provide secure transport to App Connectors. Maintained by Zscaler and deployed globally, ZPA Public Service Edges are the cloud-based portion of the ZPA data forwarding path, responsible for giving Zscaler Client Connector and App Connectors the ability to provide secure, authenticated, policy-based access to internal applications. ZPA Private Service Edges act in the same capacity, but they are managed by an organization. The ZPA Public Service Edges and Private Service Edges are responsible for a variety of functions, including:

- Zscaler Client Connector and App Connector configuration and authentication, using public key cryptography.
- Creating and managing M-Tunnels, including authentication, policy, setup, teardown, and data forwarding. M-Tunnels are end-to-end encrypted connections designed to ensure that all traffic stays separate.

5.3.3 App Connectors

App Connectors provide the authenticated secure interface between an organization's application servers and the ZPA cloud. App Connectors can be distributed using lightweight virtual machines (VM) to run in legacy enterprise data centers and public cloud environments or as a package that can be installed under supported operating systems.

App Connectors are deployed in locations where internal applications reside, or they can be deployed in any location that has connectivity to those applications. ZPA selects the closest App Connector given the location of the user and the App Connector-to-application latency. It is best to install them in redundant (N+1) configurations, where (N) is the number of App Connectors required to support the applications, because they are always active. App Connectors never communicate with each other and do not accept inbound connections. They only require an outbound connection to the internet to reach ZPA Public Service Edges or Private Service Edges, so they can provide users access to internal applications in your organization.

Using a key pair (i.e., a provisioning key and a corresponding TLS client certificate), the App Connector and the ZPA cloud verify each other as part of enrolment. After an App Connector is enrolled, the TLS client certificate allows it to maintain its authentication with the nearest ZPA Public Service Edge or Private Service Edge, which provides the App Connector with its configuration and allows it to begin its operational tasks. These tasks include:

- Find applications as requested by users
- Act on behalf of the application to send traffic back to users
- Complete DNS requests on demand, based on established policies
- Monitor applications for their reachability

5.3.4 Logging Streaming Service

The Log Streaming Service (LSS) provides real-time and historical visibility into the operation of ZPA by analyzing events reported, primarily by the ZPA Public Service Edges or Private Service Edges. In addition to real time analytics and status, the LSS provides short and long-term storage.

Information sent to the LSS includes user activity and status, connector status, and http information related to Browser Access. The default fields in log templates created by ZPA do include personally identifiable information (PII). However, your organization can create a custom log template that only captures specific fields.

The LSS has two components: a log receiver and an App Connector. It can stream logs from your ZPA tenant to a SIEM or log receiver you manage. You must specify the logs required for streaming in the ZPA Admin Portal.

Because ZPA was purpose-built to ensure secure, private access to internal applications, the service does not store any information on any type of persistent media (i.e., disk) unless it is configured to do so by your organization. The information can also be obfuscated based on your organization's preferences.

5.4 Traffic Forwarding

There are two ways to manage traffic forwarding:

5.4.1 Zscaler Client Connector

Zscaler Client Connector is a client or app that is installed on a user's device (or endpoint), which authenticates the endpoint with the ZPA cloud and enables access to internal applications on behalf of that endpoint. Zscaler Client Connector verifies the integrity of both the ZPA infrastructure and the peers it is communicating with using public key cryptography.

Beyond the full authentication, as handled as part of the standard SAML 2.0 workflow, Zscaler Client Connector creates a unique fingerprint of the user's device. This means if someone copies Zscaler Client Connector from one device to another, the fingerprint generated by Zscaler Client Connector will prevent successful enrollment from the new device.

Zscaler Client Connector recognizes the internal applications that are available via ZPA. Access to these applications is defined in ZPA based on policies. Using information received from the ZPA Public Service Edge or ZPA Private Service Edge, it intercepts the user requests for those applications and then forwards those requests to the ZPA cloud. No network information is required to access available applications, and an organization can specify if resources must go through ZPA at all times, when on an untrusted network only, or never.

To facilitate secure private connections that are abstracted from the physical network, Zscaler Client Connector associates permitted internal applications with a set of synthetic IP addresses. So, when a client application (i.e., a web browser or SSH client) sends out a DNS request, Zscaler Client Connector is able to recognize the domain as an internal application being protected by ZPA. Zscaler Client Connector then intercepts the DNS request and delivers a DNS response to the client application that uses the synthetic IP address associated with the internal application.

Organizations can also use Zscaler Client Connector to direct user traffic to ZIA. Zscaler Client Connector identifies internal applications to forward traffic to ZPA, and other traffic goes to ZIA. If an organization is using ZIA and ZPA, Zscaler Client Connector will inherit some functionality from ZIA, including enrolment, user profiles, traffic management, etc. However, organizations do not need access to ZIA in order to use ZPA.

5.4.2 Browser Access

Browser Access allows you to leverage a web browser for user authentication and application access over ZPA. This allows users who cannot install the Zscaler Client Connector on their devices, but who still need access to applications, to do it over ZPA.

The application must be available via HTTP/HTTPS in a web browser that supports TLS 1.2. When a user tries to access an internal web application, they can open any web browser on their device and enter the application's URL. ZPA directs this traffic to the organization's identity provider (IdP), where the IdP authenticates the user and grants a SAML certificate before forwarding the traffic to a ZPA Public Service Edge or Private Service Edge. Browser Access is session based, so the user must authenticate via the IdP every time they try to access the web application.

The ZPA Public Service Edge or Private Service Edge accepts the SAML certificate and applies all policies, making only permissioned internal web applications accessible to the user. If the policy allows the user access, ZPA identifies the best-path App Connector for the internal web application and connects them to it. When the ZPA Public Service Edge or Private Service Edge sends out a request to all App Connectors sitting at the application level, the App Connector sitting closest to the internal web application responds by connecting to the ZPA Public Service Edge or Private Service Edge.

The connections from user to ZPA Public Service Edge (or Private Service Edge) and App Connector to ZPA Public Service Edge (or Private Service Edge) are then stitched together, forming a TLS-encrypted tunnel, creating a secure channel between the authorized user and the internal web application without granting network access.

5.5 Understanding Communication Between Components and Subsystems

All communication between ZPA components travels within a mutually pinned, client- and server certificate-verified, TLS connection. Within this TLS-encrypted Zscaler Tunnel, a microtunneling protocol exists. Select components of ZPA run through this encrypted Microtunnel end-to-end.

Because client and server use pinned certificates, it is cryptographically impossible for ZPA to experience a Man-in-the-Middle (MITM) attack. The client certificates are verified against an organization's Certificate Authority (CA), and the server certificates are verified against Zscaler's CA, which cannot be spoofed by any third-party compromised CA.

All Zscaler certificates are signed through an offline-only, air-gapped signing ceremony. ZPA only accepts connections from the Zscaler Client Connector and the App Connector instances that present a client certificate signed by a CA associated with each tenant. Zscaler Client Connector and App Connector will only connect to ZPA service components that present a certificate signed by the ZPA infrastructure PKI.

All certificates used within the ZPA infrastructure, including all organization-operated systems, have private keys that never leave the physical device in which they were generated. The private keys for each organization's Central Authority (CA) are stored in encrypted format (i.e., AES256-GCM). Proper best practices for public key lifecycles are always maintained.

5.5.1 Zscaler Tunnel

A Zscaler Tunnel (Z-Tunnel) is a TLS-encrypted, mutually authenticated point-to-point connection between Zscaler Client Connector and a ZPA Public Service Edge managed by Zscaler, or it's between an App Connector and a ZPA Private Service Edge managed by an organization. A Z-Tunnel does not contain any direct IP data. An additional Z-Tunnel is created between Zscaler Client Connector and a ZPA Public Service Edge, or between an App Connector and a ZPA Private Service Edge, to support multi-tenancy in Zscaler Client Connector. This allows Zscaler Client Connector to establish a Z-Tunnel with the tenant and establish a separate Z-Tunnel with the partner tenant. The second Z-Tunnel works without any additional setup or configuration. Also, the Z-Tunnel can carry multiple communication channels called Microtunnels.

Z-Tunnels are authenticated using public key cryptography. Zscaler Client Connector and App Connectors are authenticated with the organization's public key infrastructure (PKI). ZPA Public Service Edges and Private Service Edges are authenticated with Zscaler's PKI. In addition to the certificate-based authentication already applied, the Z-Tunnel is further authenticated using SAML 2.0.

5.5.2 Microtunnel

A Microtunnel (M-Tunnel) is an end-to-end communication channel created between Zscaler Client Connector and an internal application via a ZPA Public Service Edge or Private Service Edge and an App Connector upon demand.

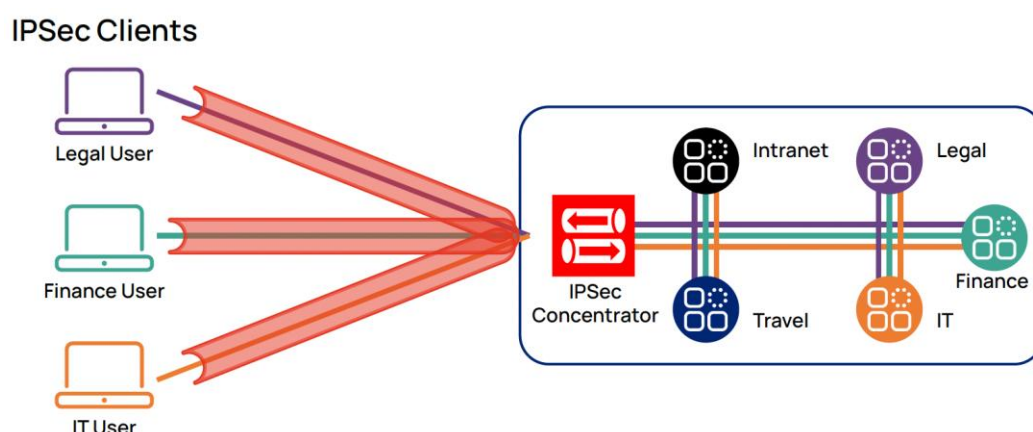
An M-Tunnel originates at Zscaler Client Connector when traffic from a client application (i.e., a web browser or SSH client) attempts to connect to an application server, which is associated with a synthetic IP address. The M-Tunnel extends to the ZPA Public Service Edge or ZPA Private Service Edge using a tag created by Zscaler Client Connector. The M-Tunnel then extends to the appropriate App Connector using a different tag chosen by that connector. Finally, the App Connector connects the M-Tunnel to the actual application server providing the service originally requested by the client application.

At no point in the communication is actual IP identification data passed. Instead, the combination of tags created by Zscaler Client Connector and the App Connector functions similarly to the label stack in a Multiprotocol Label Switching (MPLS) network. Just as in an MPLS network, where the label-switched path (LSP) uniquely identifies a connection, Zscaler Client Connector and App Connector tags identify a unique connection for each application request.

5.6 Transitioning to a Zero Trust ZPA Deployment

One common driver for ZPA deployment is to replace a remote access IPSec VPN. In the VPN model, endpoints are connected to a network, and access security must be handled by network segmentation or application controls. In your initial deployment of ZPA, you can do something similar with wildcard discovery. You can deploy ZPA in a policy configuration that mirrors the open-access VPN model with wildcard app segments and broad access policies. This allows you to make one conceptual change at a time: first change the transport to the applications, then work on granularity of control. This also reduces risk by ensuring that no user applications break due to policy restrictions.

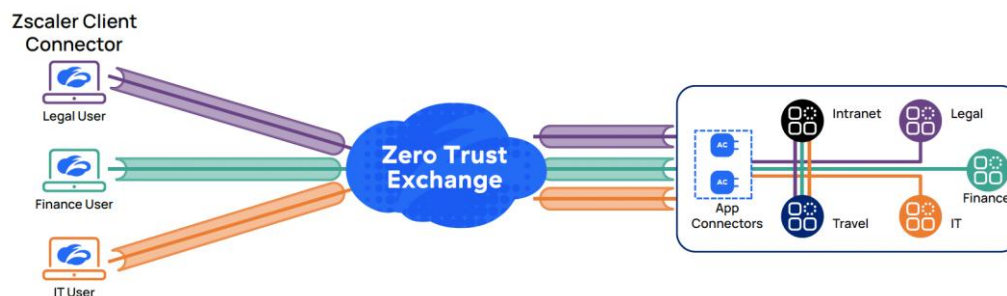
At a high level, the starting point will look something like the following illustration, where users have access to various applications.



When transitioning to ZPA for access, it should be as transparent as possible to the end user. By setting up ZPA to use wildcard discovery, you are replicating the user's existing controls. After migration to Zscaler, initial setup will look something like the following illustration, mirroring your IPSec VPN access policy so users have a similar experience and access to the applications.



After your initial group is migrated to ZPA, you need to begin building more granular policy. The goal is to refine the app segment definitions, user context, and access policies based on what is learned in discovery, and to provide access to required applications only to users and user groups who should have access to these resources. This can be achieved in multiple ways depending on the requirements. The same process of discovery and refinement allows you to extend your ZPA protection beyond the remote-access use case and also encompass on-premises user access.



How your organization progresses toward a zero-trust transformation will be defined by the kinds of access you want to grant and the relationship of the user, device, or location to your organization. Some use cases require using fully granular zero trust policies. Examples include third-party access to internal tools, or during an acquisition where the user community is easily identified and the target resources are clearly scoped.

For other use cases, such as employee roles where the traditional approach has been full network access, a different approach may be required. A targeted access policy can allow only those users to get to a broad range of resources (e.g., *.internal.safemarch.com), enabling initial connectivity as well as dynamic application discovery. The resulting user activity logs offer visibility to inform development of more granular policies, so you can evolve towards more granular zero trust controls for those users as context becomes available.

It's important to remember that "success" at zero trust does not necessarily mean eliminating all wildcard access. There may be use cases in your organization where it's appropriate to provide a certain user community access to a full range of applications within a certain domain or subdomain. Granularity then might mean ensuring that only authorized users on appropriate devices, possibly with additional context controls, are permitted access via that wildcard policy.

5.7 AI-Powered Segmentation

Zscaler's AI-powered Intelligent Application Segmentation is an advanced capability that streamlines the Zero Trust journey. It delivers precise user-to-Application Segmentation and tailored Access Policy recommendations, ensuring secure and efficient connectivity for users across the organization.

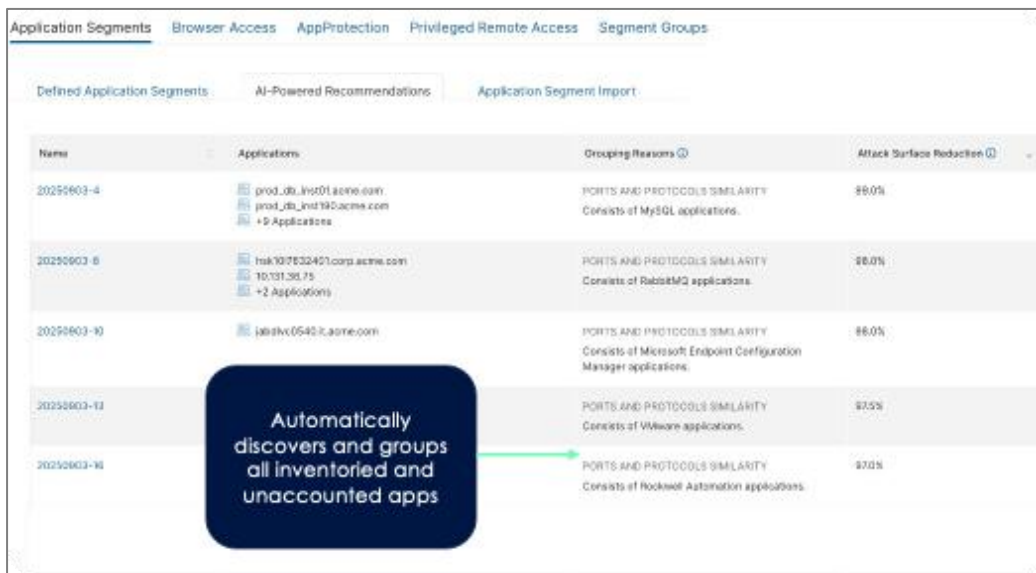
The AI/ML-powered Intelligent Application Segmentation is a ZPA feature built to assist the ZPA administrator with their journey towards Application Segmentation, providing Zero Trust access for private applications. It performs the following:

- Digests application access logs for the last 30 days
- Using the access patterns of the discovered applications, AI/ML provides recommendations for the following areas:
 - Identifies Application Segments required to serve the observed application requests, which would eventually help with removal of “open” (wildcard) Application Segments
 - Users and/or probable SCIM or SAML Departments/Groups that require the access which can be used in Access Policy definition

The outcome helps in reducing the attack surface (and henceforth limit lateral movement) by enabling the following:

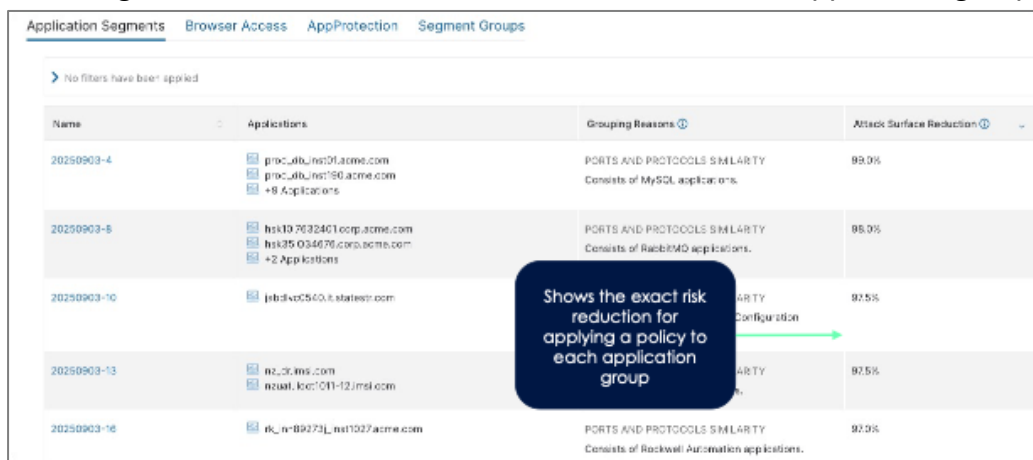
- Application Segments defined with right set of FQDN/IP(s), port(s) and protocol(s)
- Least privilege access, so only the correct set of users have access to the correct set of applications via Access Policies

The AI-Powered Segmentation Automatically Discover and Group Unaccounted Apps



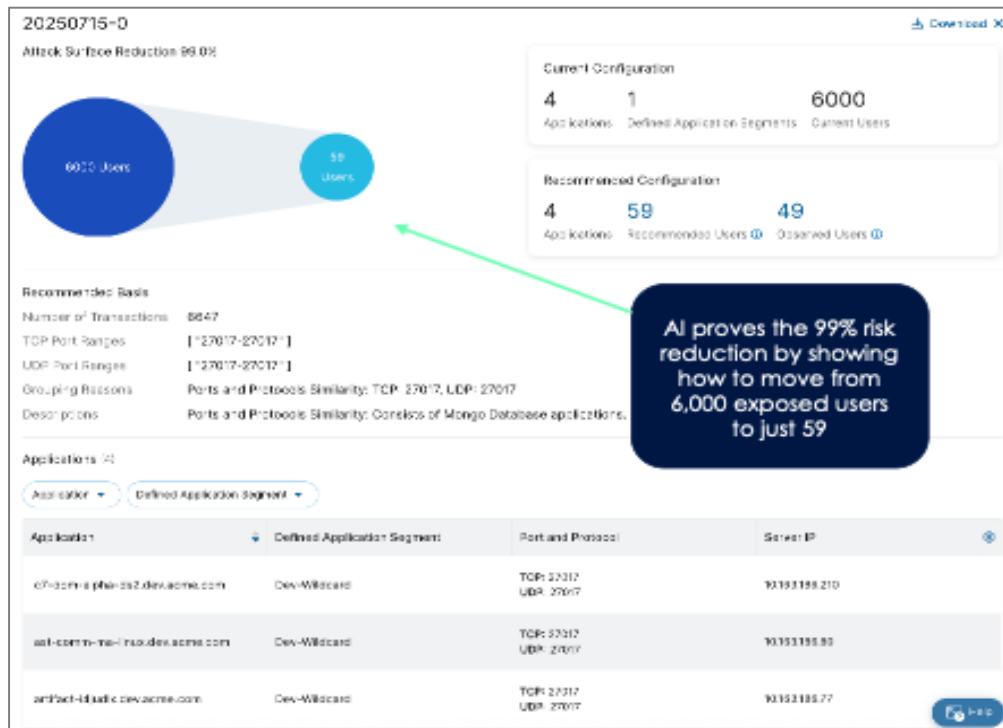
Name	Applications	Grouping Reasons	Attack Surface Reduction
20250603-4	prod_db_int01.acme.com prod_db_int100.acme.com +2 Applications	PORTS AND PROTOCOLS SIMILARITY Consists of MySQL applications.	88.0%
20250603-6	hs1307632401.corp.acme.com 10.101.39.75 +2 Applications	PORTS AND PROTOCOLS SIMILARITY Consists of RabbitMQ applications.	88.0%
20250603-10	jetadv05401.acme.com	PORTS AND PROTOCOLS SIMILARITY Consists of Microsoft Endpoint Configuration Manager applications.	88.0%
20250603-13		PORTS AND PROTOCOLS SIMILARITY Consists of VMware applications.	92.5%
20250603-16		PORTS AND PROTOCOLS SIMILARITY Consists of Rockwell Automation applications.	92.5%

The AI-Powered Segmentation shows the exact risk reduction to each application group.



Name	Applications	Grouping Reasons	Attack Surface Reduction
20250903-4	prod_db_int01.acme.com prod_db_int100.acme.com +8 Applications	PORTS AND PROTOCOLS SIMILARITY Consists of MySQL applications.	88.0%
20250903-6	hs1307632401.corp.acme.com hs135034676.corp.acme.com +2 Applications	PORTS AND PROTOCOLS SIMILARITY Consists of RabbitMQ applications.	88.0%
20250903-10	jetadv05401.acme.com	PORTS AND PROTOCOLS SIMILARITY Consists of Microsoft Endpoint Configuration Manager applications.	88.0%
20250903-13	ez_crms.com nzual.koc1011-12.msl.com	PORTS AND PROTOCOLS SIMILARITY Consists of VMware applications.	92.5%
20250903-16	rk_n-892731_mst1027.acme.com	PORTS AND PROTOCOLS SIMILARITY Consists of Rockwell Automation applications.	92.5%

The AI-Powered Segmentation details the relevant users for each application and, with one-click convert any AI recommendation into a secure application segment.



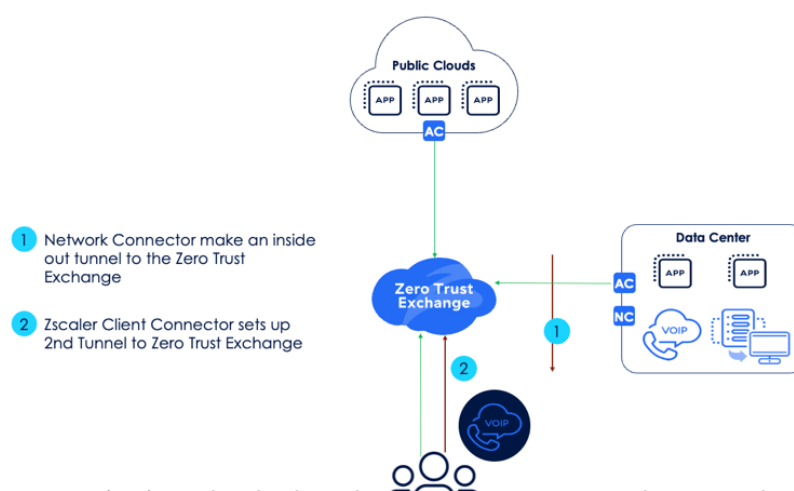
5.8 Zscaler VPN (For Legacy Apps)

The VPN service (for legacy apps) is designed to manage exception traffic, specifically for VoIP and S2C applications, while facilitating the transition to a zero-trust network architecture.

This solution ensures continued access to applications that are not immediately adaptable to zero trust access, thereby minimizing disruption during the migration process to critical applications.

5.8.1 ZPA Architecture for VoIP and Server-to-Client Apps: Network Connectors, Secondary Tunnel, and Zero Trust Exchange

High-level solution design:



- Network Connectors (NC) can be deployed in datacenter/campus locations hosting VoIP servers and other server-to-client (S2C) systems. These connectors initiate an outbound connection to the ZTE, establishing a secure tunnel between the connector and the ZTE.

- Zscaler Client Connector (ZCC) builds a secondary tunnel specifically for users authorized for VPN services, also connecting to the ZTE. The ZCC is configured to forward traffic through this alternative path based on the configuration parameters set by the administrator.
- ZTE integrates the connection between the ZCC and the NC, creating an end-to-end encrypted pathway that facilitates secure communication for these applications.

6 Part 3- Proposed Solution: Zscaler Digital Experience Monitoring (ZDX)

As your applications and work locations continue to evolve, so must your ability to monitor and diagnose application access and performance. Traditional monitoring tools for application performance and user experience relied on the ability to control and instrument the network and applications.

The rapid adoption of cloud and mobility initiatives within organizations and a shift to work-from- anywhere have introduced new monitoring challenges for IT teams. Applications are moving out of the data centre and into the cloud.

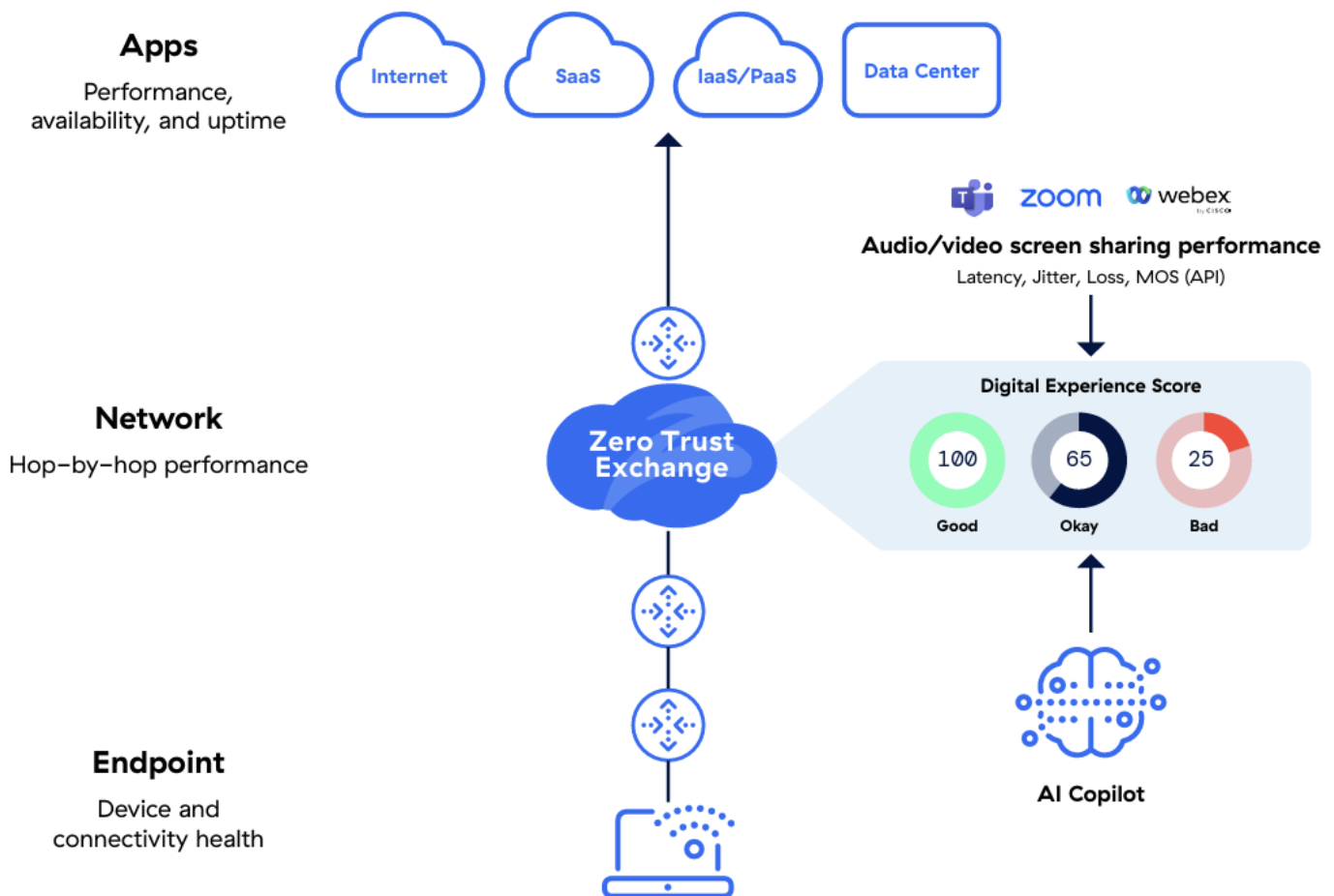
They are being accessed by a hybrid remote workforce, meaning IT teams no longer control the underlying infrastructure and technology stack and lose end-to-end visibility into the user experience. End-user performance issues arising from SaaS or cloud application availability, home Wi-Fi issues, network path outages, or network congestion are not easily isolated and diagnosed.

Digital experience monitoring for a hybrid workforce requires a modern and dynamic approach. IT teams need to continuously monitor and measure the digital experience for each user from the user perspective, regardless of their location. Traditional monitoring tools take a data center-centric approach to monitoring and collecting metrics from fixed sites rather than directly from the user device. This approach does not provide a unified view of performance based on a user device, network path, or application.

Zscaler Digital Experience (ZDX) is an AI-powered digital experience monitoring solution delivered as a service from the Zscaler cloud. ZDX provides end-to-end visibility and troubleshooting of end-user or customer performance issues for any user or application, regardless of location.

In addition, it enables continuous monitoring for network, security, and service desk teams with insight into the end user device, network, and application performance issues.

ZDX leverages Zscaler Client Connector and the Zscaler Zero Trust Exchange to actively monitor applications from an end user or customer perspective. It continuously collects and analyzes various performance metrics, including application availability, response times, network hop-by-hop performance metrics, and device health metrics such as device configuration, CPU, memory usage, process information, and device events. As a result, network operations and service desk teams get uninterrupted visibility and save time with proactive identification and resolution of end-user experience and application or service issues.



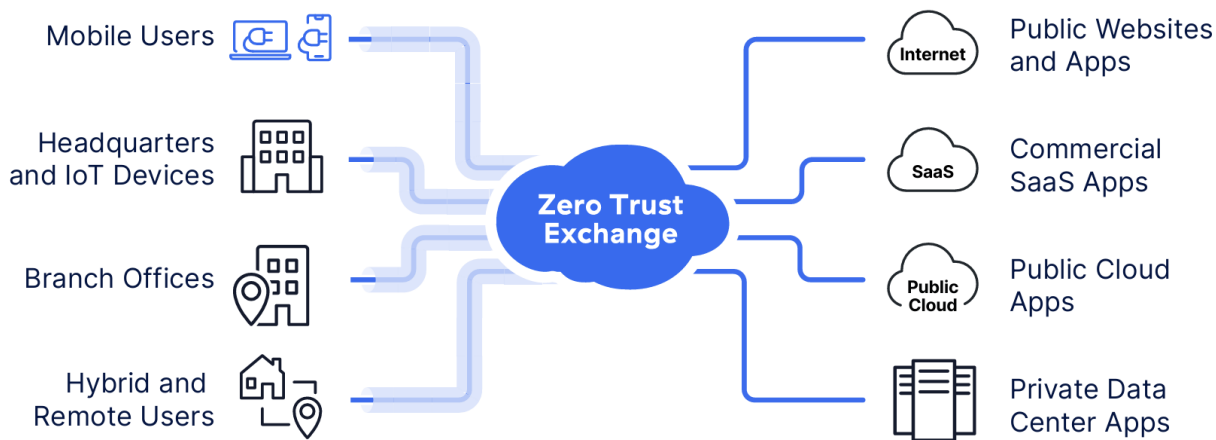
6.1 Key Capabilities

ZDX lets you monitor granular details for users, devices, applications, and more in your org. With ZDX, you can:

- Proactively monitor every user device in your organization to detect user experience and productivity issues.
- Grade your digital experience by referencing the ZDX Score over time for your organization and each application, location, department, and user.
- Triage performance issues and pinpoint whether the issue is in the local network, a user's device, the ISP provider, or within the Zscaler cloud.
- Use Zscaler's unified client, Zscaler Client Connector, to implement ZDX on Windows, macOS, Android, Android on ChromeOS, and iOS devices.
- Monitor general data centre information and your key SaaS applications (i.e., Outlook Online, Salesforce, Box, etc.) using HTTP, ICMP, or UDP synthetic probes running on user devices in near real time.
- Collect real-time device health information (i.e., CPU usage, memory usage, Network IO, disk I/O, Wi-Fi signal strength, etc.) for your user devices.
- Hop-by-Hop network path visualization from the client device to the destination device.
- Threshold-based alerting for SLA monitoring.
- Remote troubleshooting capabilities to perform detailed analyses of problematic devices (i.e., system process-level monitoring, full network path information including the Autonomous System Number (ASN), ISP information, country hop information, and packet tracing).
- Executive insights reports and digital experience analytics aggregated at organization, location, and application levels.

6.2 Understanding ZDX Probes

For many years, traditional network monitoring tools existed for cloud applications by monitoring connections from fixed sites. Remote work was limited and often entailed a VPN connection to a central site for access to applications. The realities of newly remote and hybrid work have made that monitoring style of limited value.



ZDX instead monitors application availability from every user's device via Zscaler Client Connector. This is the same software that allows users to connect directly to applications using ZPA, or to a ZIA Public Service Edge for internet access. The ZDX feature of Zscaler Client Connector enables probes to be sent to configured web-based applications.

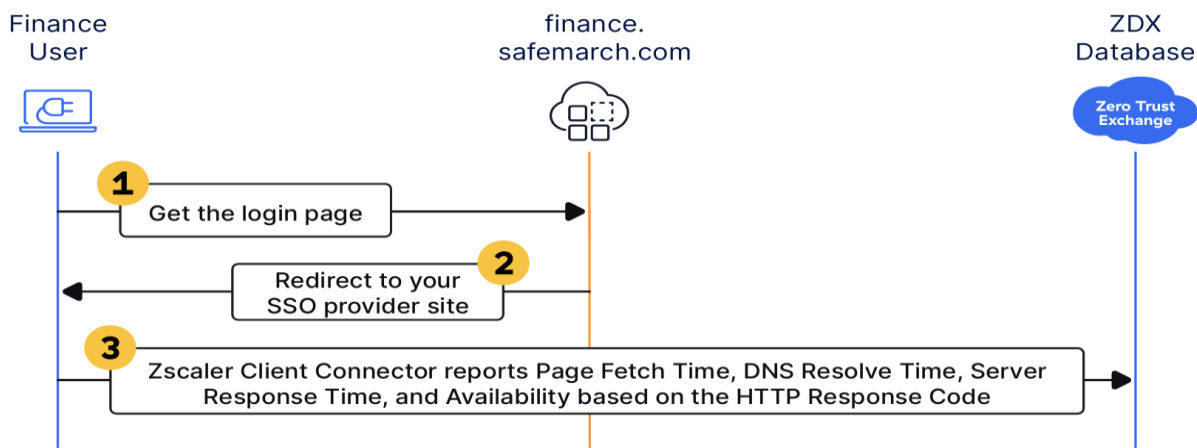
ZDX probes exist as part of an application you select. ZDX provides several preconfigured applications depending on your subscription level, and you can always define custom applications and probes. The probes check that your application is responding appropriately and record latency and jitter statistics along the network path. These two functions are handled using two probe types:

- Web probes that check for application availability.
- Cloud Path probes that record hop-by-hop network performance information between the user and the application.

The data from these probes is combined with information about the user's device. This includes items such as CPU and memory usage, network usage, and Wi-Fi signal strength. This information is sent to the ZDX cloud. The data is aggregated and presented as a series of dashboards that allow you to see your organization's application performance. ZDX also supports configurable alerts, allowing your operations team to proactively address issues as they begin, not after they are reported.

6.2.1 ZDX Web Probes

The ZDX web probe makes an HTTP or HTTPS GET request to an application to check its service availability and responsiveness. When the application receives the request, it responds with an HTTP Status Code, such as a redirect to a login page. ZDX sends the probe and looks for the correct response code in return based on its configuration to mark the status as available or down.



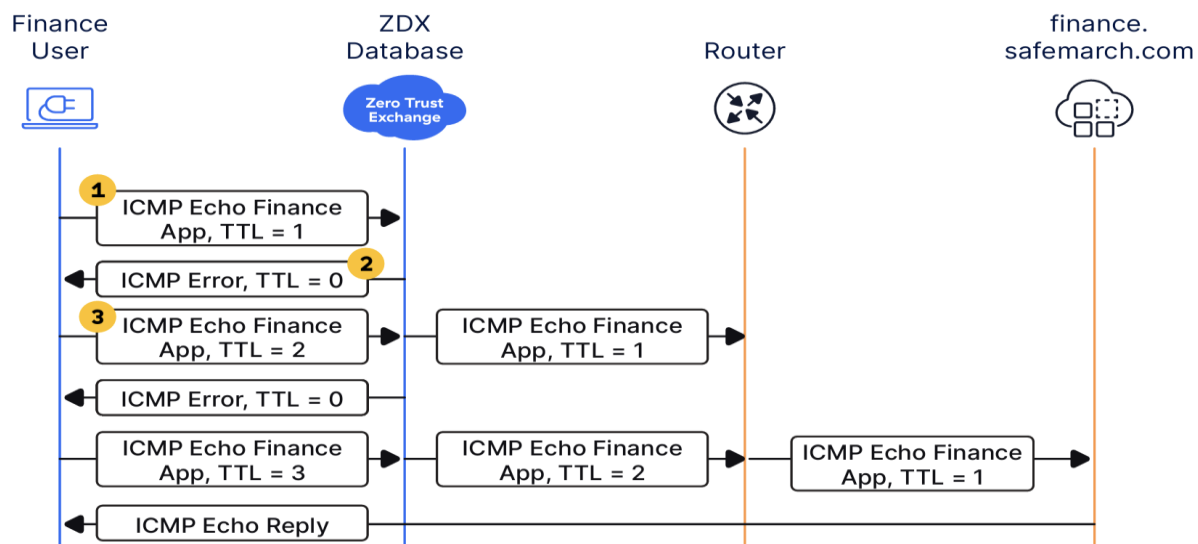
- 1) A member of the finance team has Zscaler Client Connector installed. Zscaler Client Connector is configured to check that the finance application is running for anyone in the finance group. To do this, Zscaler Client Connector sends an HTTPS probe to the login page for finance.safemarch.com.
- 2) Finance.safemarch.com responds with a redirect to the organization's single sign-on (SSO) provider to authenticate.
- 3) The server response and the data around the response are sent to ZDX, which is configured to consider the redirect response as a sign that the service is operational.

The ZDX web probes collect the following information about the application:

- **Page Fetch Time** – This metric collects the network fetch time of the web page from the URL-specified web probe. It requests only the top-level page document and does not request all embedded links within the web page.
- **DNS Resolve Time** – This metric represents the time it took to resolve the DNS name for the hostname specified in the web probe URL.
- **Server Response Time** – Time to First Byte (TTFB).
- **Availability based on the HTTP Response code** – If a success code is returned, the availability is either 1 or 0. If the probe times out, the availability defaults to 0.

6.2.2 ZDX Cloud Path Probes

Cloud Path probes work by sending packets with reduced time-to-live (TTL) values to map the path between the user-installed Zscaler Client Connector and the web application. Cloud Path probes can use ICMP, UDP, or TCP, and can change these segment by segment. The system records the statistics as the probes come back or fail to come back.



- 1) For the same finance user with Zscaler Client Connector installed, the agent begins sending probe packets out with a time to live (TTL) of 1, or 1 network hop away. The probes are sent 5 times with the same TTL.
- 2) At each hop, the router decrements the TTL by 1, dropping any probes that reach 0. Typically, a router sends a notification back to the sender that the TTL has expired and that the packet has been dropped. Zscaler Client Connector records this data for each set of probes.
- 3) After the 5 sets of packets, Zscaler Client Connector increases the Cloud Path probe TTL by 1 and sends another series of 5 probes. This increase continues until the application is reached or the number of hops exceeds the system's limits.

Cloud Path probes are used to collect the following metrics:

- **Hop Count** – The number of hops between each hop point on the path.
- **Packet Loss** – The percentage of packet loss at each hop point on the path.
- **Latency (Average, Minimum, Maximum, and Standard Deviation)** – The roundtrip path time measured in milliseconds.

6.3 Applications Monitoring

Application definitions allow you to build web and Cloud Path probes to the application for monitoring. ZDX comes with a set of predefined applications as well as the ability to build custom applications. When using a predefined application, you enable the application and enter your tenant information for your organization. With a custom application, you need to build the web and Cloud Path probes to support that application.

Configuration

End User 20

Top Private Apps

Search

+ Add

Unified Communication ...

Predefined Apps Collecti...

Custom Apps Collection

Predefined Apps Collection Enabled

Total: 16 Probes: 8 8

Collection Details

View Details

Status

Search

Add Application

Application Name	Status	No. Probes	Last Updated	Actions
box Box	Enabled	1 1	Jun 20, 2025 02:18 PM GMT+4	
Microsoft Login	Enabled	1 1	Jun 20, 2025 01:22 PM GMT+4	
Microsoft Teams Web App	Enabled	1 1	Jun 20, 2025 01:22 PM GMT+4	
Okta Okta	Enabled	1 1	May 21, 2025 12:35 AM GMT+4	
OneDrive for Business	Disabled	1 1	Jun 20, 2025 02:13 PM GMT+4	
Outlook Online	Enabled	1 1	Jun 20, 2025 02:03 PM GMT+4	

6.3.1 Applications Definition

ZDX has predefined support for common large enterprise applications. Because these applications are already understood by ZDX, you only need to do minimal configuration before using them. The exact applications that are available to your organization depend on your ZDX subscription level. The following list includes all supported applications:

- Unified Communication
 - Microsoft Teams Call Quality
 - Webex Call Quality
 - Zoom Call Quality
- Web Applications
 - Box
 - Microsoft Login
 - Microsoft Teams Web App
 - Okta
 - OneDrive for Business
 - Outlook Online
 - Salesforce
 - Salesforce Classic
 - Salesforce Lightning
 - ServiceNow
 - SharePoint Online
 - Webex
 - Zoom

6.3.2 Defining Custom Applications and Probes for ZDX

Custom applications allow you to apply ZDX monitoring to applications that you run in your private data center or that are hosted in the cloud. These can be custom-built applications, privately hosted instances of applications, or cloud services.

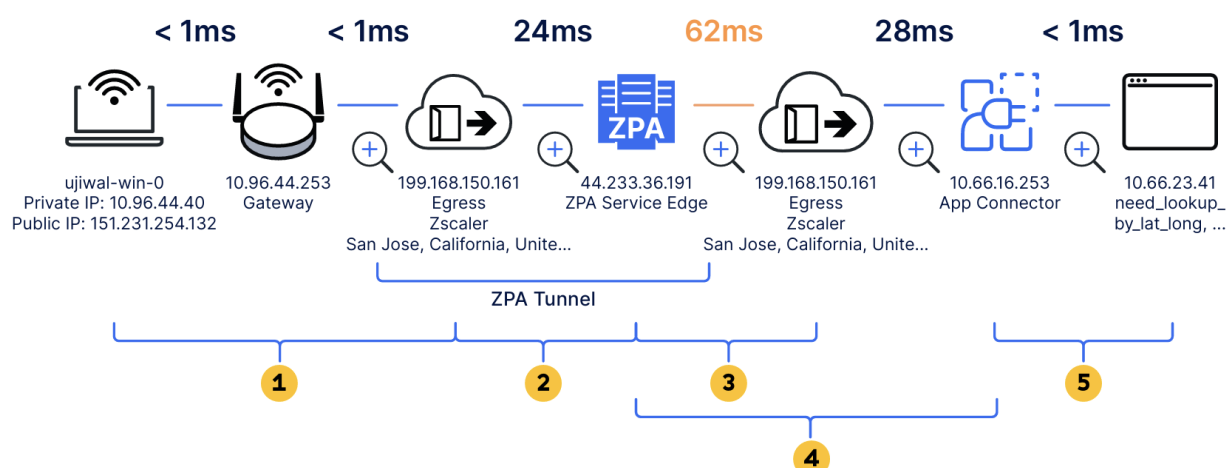
When you add a custom application, you must also add the associated probes to monitor the application. There are two types of probes you will build: a web probe and a Cloud Path probe. For each application, you will configure each probe type.

It is recommended that you build your web probes first, as the Cloud Path probe can follow the web probe and simplify configuration. Each probe has a frequency timer determining how often the probe should run.

6.4 ZDX, ZPA and Private Applications

ZPA offers the fastest, most secure access to private applications, services, and operational technology (OT) devices with the industry's only next-gen Zero Trust Network Access (ZTNA) platform.

ZPA allows you to make applications and OT devices invisible on the internet, reachable only through the ZPA service for authenticated and authorized users. When working with ZDX, ZPA allows you to leverage your existing authentication configuration and administrative accounts.



When you examine a user's path using ZDX with ZPA, there are 5 groupings of segments to consider as you begin your analysis:

- 1) **User Device to Egress Point** – This segment covers your user's device and the network gateway, up to the service provider edge.
- 2) **Egress Point to ZPA Public Service Edge** – This segment is the ISP network between your end user and the ZPA Public Service Edge.
- 3) **ZPA Public Service Edge to Application Egress Point** – This is the segment between the ZPA Public Service Edge and the egress point from the application's point of view.
- 4) **ZPA App Connector to ZPA Public Service Edge** – This segment contains segment 3, as well as the internal network between the ZPA App Connector and the ZPA Public Service Edge.
- 5) **ZPA App Connector to Application** – This segment is the internal network between the ZPA App Connector and the private application the user is trying to reach.

6.5 Device Scoring and Device Events

Without visibility into device events, IT support teams are forced into a reactive mode—waiting for users to report problems, which leads to increased downtime and user frustration. Device scoring evaluates **CPU, memory, disk, Wi-Fi, battery, and critical events like crashes**.

This approach not only delays issue resolution but also overwhelms service desks with preventable incidents. Adding to the challenge, critical device data is often spread across multiple external tools, creating silos and inefficiencies that slow down response times.

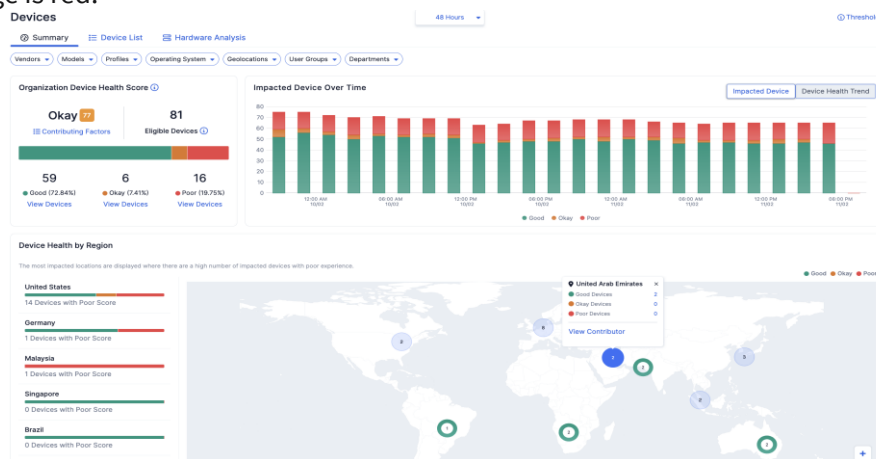
By implementing centralized device scoring and event tracking, organizations gain real-time insights into device health, enabling proactive support, faster root-cause analysis, and improved overall IT efficiency.

The Device Health dashboard uses existing user and device data to create a comprehensive device health scoreboard that monitors the performance of Windows and macOS devices. The dashboard provides useful data

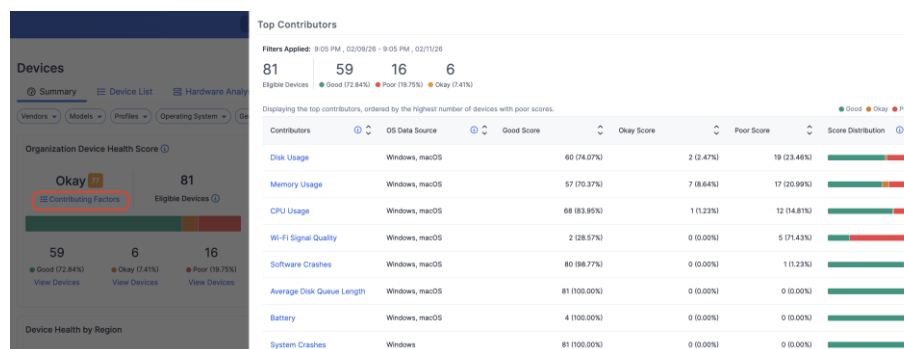
for evaluating trends to identify and understand the root causes of poor-performing devices. Then you can proactively collect device data and identify which devices require an IT's attention to remedy the device's poor performance (e.g., high CPU usage). With a dedicated dashboard, you can target hardware upgrades based on the device's usage for greater cost-effectiveness.

The ZDX's Device Health Score provides a comprehensive view of struggling devices across an entire organization, department, user group, or location. The score is determined by individual contributing metrics (e.g., CPU usage, memory usage, disk usage). The Device Health Scores are categorized as:

- **Good:** The usage profile has an acceptable Device Health Score and ranges from 66-100. The colour for this range is green.
- **Okay:** The usage profile has an acceptable Device Health Score and ranges from 34-65. The colour for this range is amber.
- **Poor:** The usage profile has a below an acceptable Device Health Score and ranges from 0-33. The colour for this range is red.

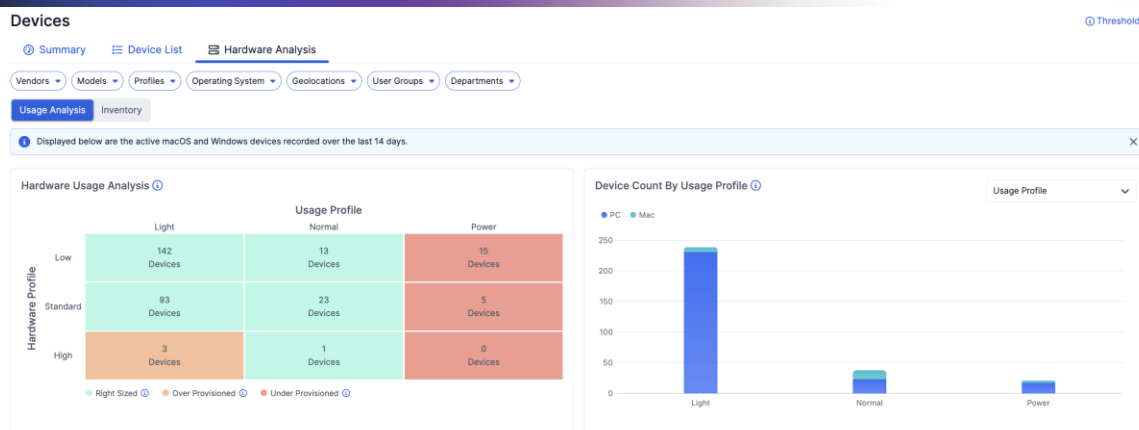


On the Summary page, clicking on “**Contributing Factors**” will show what’s impacting device performance the most. It highlights key issues like high CPU usage, frequent crashes, or poor Wi-Fi signal in descending order of Poor score weightage.



The list of impacted devices can also be viewed by using the “**Device List**” option.

ZDX also offers a Hardware Usage Analysis displaying hardware profile based on hardware allocation and usage profile based on users and device usage trend.



7 Part 4 - Technical Requirement Compliance

7.1 SASE platform

TECHNICAL SCOPE OF WORK		COMPLIANCE FC, PC, NC	REMARKS
3.1 General Scope of Work			
The following chapters provide an overview by describing the high-level scope of the project. The more detailed scoping shall be part of the proposal. (If there is a conflict between this chapter and the other more detailed chapters in this document, the latter takes precedence.) The Solution covers the following high-level scope:			
3.1.1	Propose a fully cloud-delivered SASE architecture for internet traffic security that includes centralized management, redundancy, AI-powered threat prevention, and consistent policy enforcement for both managed and BYOD users.	FC	
3.1.2	Provide a SASE solution that converges Secure Web Gateway (SWG), Firewall-as-a-Service (FWaaS), Remote Browser Isolation (RBI) / Enterprise Browser, and DNS Security into a unified cloud-delivered platform.	FC	
3.1.3	Provide a detailed plan for deploying the SASE solution across all campuses, the primary DC, DR site, and integration with local internet breakout links at each campus.	FC	
3.1.4	Support both agent-based deployment for managed (institution-owned) endpoints and agentless deployment for BYOD (personally-owned) endpoints with differentiated security policies.	FC	
3.1.5	Provide AI-powered security capabilities including real-time threat detection, zero-day malware prevention, phishing detection, user and entity behaviour analytics (UEBA), and generative AI application controls.	FC	

3.1.6 Plan for migrating existing legacy on-premises SASE for BYOD users and consolidating with the existing cloud-based solution for managed users into a single platform.	FC	
3.1.7 Include inline SSL/TLS inspection (TLS 1.2 and TLS 1.3) using an HCT local CA-signed certificate, content filtering, application control, and advanced threat prevention for all internet-bound traffic.	FC	
3.1.8 Real-time monitoring, reporting, and Digital Experience Monitoring (DEM) of user experience, network performance, security incidents, and other metrics.	FC	
3.1.9 Provide necessary training for IT staff on the SASE solution and create detailed documentation.	FC	
3.1.10 Support secure internet breakouts at the campus level via IPsec tunnel-based traffic steering from campus edge devices (NGFW or SD-WAN appliances) to the nearest SASE Point of Presence (PoP).	FC	
3.1.11 Enable agentless BYOD security through DNS-layer security, PAC file distribution, certificate-based authentication, and Remote Browser Isolation without requiring endpoint agent installation.	FC	
3.1.12 Provide granular visibility and control over sanctioned and unsanctioned SaaS application usage, shadow IT discovery, and tenant-level restrictions for multi-tenant SaaS platforms.	FC	
3.1.13 Provide granular controls for generative AI application usage including discovery, per-application policies, and AI usage analytics.	FC	
3.1.14 Integration with existing on-premises infrastructure including Identity Provider (IdP), Network Access Control (NAC), Next-Generation Firewall (NGFW), Endpoint Detection and Response (EDR/XDR), SIEM/SOAR, and Unified Endpoint Management (UEM/MDM).	FC	
3.1.15 Simplified operations with centralized cloud management console and integration with HCT's existing managed SOC.	FC	
3.1.16 Support compliance requirements applicable to education institutions including FERPA, NIST CSF, ISO 27001, PCI-DSS, and UAE data protection regulations.	FC	
3.1.17 (Optional) Provide Zero Trust Network Access (ZTNA) capabilities within the same SASE platform to enable secure, identity-aware, application-level access to on-premises/cloud and datacenter-hosted private applications for up to 200 designated users, without exposing the corporate network or requiring traditional VPN connectivity.	FC	

3.1.18 (Optional) The ZTNA solution must follow a broker-based architecture where the user's device connects to the SASE cloud, the cloud authenticates and authorizes the user and then proxies the connection to the private application via a lightweight connector deployed inside HCT's network. At no point should the user's device have direct network-layer access to HCT's internal network.	FC	
3.1.19 (Optional) The ZTNA solution must support both agent-based access (via the same unified SASE agent used for internet security) and browser-based clientless access for specific web applications, enabling access from both managed and approved unmanaged devices.	FC	
3.1.20 (Optional) All ZTNA access must be governed by the same centralized management console, policy engine, and logging infrastructure as the base SASE internet security platform. No separate management consoles or policy frameworks for ZTNA.	FC	
3.2 Secure Web Gateway (SWG) Requirements		
3.2.1 The SASE platform must provide inline Secure Web Gateway capabilities for all HTTP/HTTPS internet-bound traffic from both managed and BYOD users.	FC	
3.2.2 Full inline SSL/TLS decryption using HCT local CA-signed certificate and re-encryption of TLS 1.2 and TLS 1.3 traffic with configurable bypass policies for sensitive categories (banking, healthcare portals) and certificate-pinned applications.	FC	
3.2.3 Granular URL categorization with a minimum of 85 content categories. Must support allow, block, caution, and isolate actions per category. Real-time re-categorization of newly observed URLs using AI/ML.	FC	
3.2.4 Inline file scanning with multi-engine antivirus, heuristic analysis, and advanced cloud-based sandbox detonation for unknown files (PE, Office, PDF, archive formats). Must support both managed and BYOD traffic streams.	FC	
3.2.5 File type control (block uploads/downloads by file type), MIME type inspection, and configurable Safe Search enforcement for Google, Bing, YouTube, and other search engines.	FC	
3.2.6 Application-aware bandwidth management with the ability to throttle or prioritize traffic by category (e.g., limit streaming media during academic hours, prioritize LMS and e-learning traffic).	FC	
3.2.7 Customizable block pages and coaching pages that inform users of policy violations with institution branding and acceptable use policy references.	FC	

3.2.8 DNS Security: Inspection and control of DNS traffic (including DNS-over-HTTPS and DNS-over-TLS) to detect and block DNS tunnelling, DGA domains, newly registered domains, and known malicious domains.	FC	
3.2.9 Advanced Browser Threat Protection: AI inspection of fully rendered web content (post-DOM construction) to detect threats that evade traditional proxy-based inspection, including JavaScript-based credential theft, post-load payload assembly, and browser exploitation.	FC	
3.2.10 Encrypted Traffic Analysis: AI/ML analysis of encrypted traffic metadata (JA3/JA4 fingerprints, certificate attributes, traffic patterns) to detect malicious communications without decryption where decryption is not possible or desirable.	FC	
3.2.11 TLS inspection exemption by site reputation database, web categories, and/or policy addresses. Support for TLS Man-in-the-Middle (MITM) mirroring for forensic analysis.	PC	Zscaler supports exemptions based on web categories and IP/FQDN Addresses, but not by site reputation. Zscaler, as a cloud proxy, cannot mirror raw decrypted packet streams back to local forensic tools. Zscaler does offer a packet capturing feature allowing in-depth forensic and Threat Hunting. Packet capture license is not part of the proposed license.
3.2.12 Proxy avoidance prevention: Proxy site category blocking, rate URLs by domain and IP address, block redirects from cache and translation sites, proxy avoidance application blocking, proxy behavior blocking.	FC	
3.3 Firewall-as-a-Service (FWaaS) Requirements		
3.3.1 The SASE platform must provide cloud-delivered NGFW-equivalent capabilities for all internet-bound traffic.	FC	
3.3.2 Layer 7 application identification and control, supporting a minimum of 5,000 applications and protocols. Must include the	FC	

ability to differentiate between sub-applications (e.g., allow Teams chat but block Teams file transfer).		
3.3.3 Inline signature-based and anomaly-based Intrusion Prevention System (IPS) with automatic signature updates. Coverage for OWASP Top 10, CVE-based exploits, and protocol anomalies. Support for a minimum of 13,000 regular and rate-based IPS signatures.	FC	
3.3.4 Support IP, FQDN, device-based, and User/Group-based firewall policies.	FC	
3.3.5 Support for configuring firewall deny policies based on IP Reputation for known public IPs belonging to Botnet-C&C servers, Phishing Servers, Proxy Servers, Spam Servers, TOR Exit nodes and TOR Relay nodes. Updated with signatures from the vendor.	FC	
3.3.4 Support for retrieving External Block List for Domain Names, Web Filtering URLs, IP Addresses and Malware Hashes as Object/Profile settings for use in firewall policies.	FC	
3.3.5 Geo-IP Filtering: Ability to allow or block traffic based on source and destination country, with configurable exception lists.	FC	
3.3.6 Protocol enforcement (HTTP protocol validation, SSH version control) and blocking of non- standard protocol usage over standard ports.	FC	
3.3.7 Detection of traffic using HTTP/3 protocol and ability to block QUIC traffic so that the browser automatically falls back to HTTP/3 + TLS 1.2, TLS 1.3 for inspection purposes.	FC	
3.3.8 DNS-based filtering of Security Risk website categories including Dynamic DNS, Malicious websites, Newly Observed Domains, Newly Registered Domains, Phishing and Spam domains.	FC	
3.3.9 Botnet server IP-based blocking with global IP reputation database. Support for botnet domain-based blocking to filter known Fast Flux Botnet Domains.	FC	
3.4 Remote Browser Isolation (RBI)/ Enterprise Browser Requirements		
3.4.1 Pixel-Based Isolation: Execution of web content in an isolated cloud container with only rendered pixels streamed to the user endpoint. No active web content (JavaScript, Flash, ActiveX) should reach the endpoint.	FC	
3.4.2 Policy-Driven Isolation: Ability to selectively isolate web sessions based on URL category (e.g., isolate all uncategorized and newly registered domains), user risk score, or device posture.	FC	
3.4.3 Read-Only Mode for BYOD: Configurable read-only browser sessions that prevent copy, paste, download, upload, and printing	FC	

from isolated sessions for BYOD users accessing sensitive web applications.		
3.4.4 Transparent User Experience: Isolation must be transparent to the end user with minimal latency impact and full support for modern web applications including rich media, single-page applications, and web-based collaboration tools.	FC	
3.4.5 Clientless ZTNA via Browser-Based RBI: For BYOD users requiring access to institutional web applications, the platform must support clientless access via browser-based isolation without requiring endpoint agent installation.	FC	
3.5 AI-Powered Security Requirements		
The SASE platform must leverage artificial intelligence and machine learning across all security functions. The following AI capabilities are mandatory:		
3.5.1 AI-Driven Threat Detection and Prevention		
3.5.1.1 AI-Based Phishing Detection: Real-time analysis of web page content, URL patterns, brand impersonation indicators, and page behavior to detect phishing pages at the time of access, including pages that assemble malicious content after initial page load.	FC	
3.5.1.2 Zero-Day Malware Detection: ML-based static and dynamic analysis of files in the inline inspection path to identify previously unseen malware without reliance on signature databases alone.	FC	
3.5.1.3 AI-Powered DNS Threat Detection: Machine learning models that analyse DNS query patterns to identify domain generation algorithms (DGA), DNS tunnelling, and suspicious newly observed domains in real time.	FC	
3.5.1.4 Advanced Browser Threat Protection: AI inspection of fully rendered web content (post-DOM construction) to detect threats that evade traditional proxy-based inspection, including post-load malware assembly and browser exploitation.	FC	
3.5.1.5 Encrypted Traffic Analysis: AI/ML analysis of encrypted traffic metadata (JA3/JA4 fingerprints, certificate attributes, traffic patterns) to detect malicious communications without decryption where decryption is not possible.	FC	
3.5.2 AI-Based User and Entity Behavior Analytics (UEBA)		
3.5.2.1 Behavioral Baseline: Continuous learning of per-user and per-group normal internet usage patterns including access times, data volumes, application usage, and geographic patterns.	FC	

3.5.2.2	Anomaly Detection: Real-time flagging of deviations from established baselines, such as unusual data upload volumes, access to a typical category, login from anomalous locations, or use of evasion tools (anonymizers, personal VPN services).	FC	
3.5.2.3	Risk Scoring: Dynamic per-user and per-device risk scores that adapt based on observed behavior and are available for policy enforcement (e.g., high-risk users subject to stricter inspection or browser isolation).	FC	
3.5.3 AI-Powered Operational Intelligence			
3.5.3.1	AI-Assisted Policy Recommendations: The platform should analyze traffic patterns and threat data to recommend policy optimizations.	FC	
3.5.3.2	AIOps for Troubleshooting: AI-driven root cause analysis that correlates user experience degradation with network path issues, PoP performance, or policy conflicts to accelerate incident resolution.	FC	
3.5.3.3	Predictive Capacity Management: AI forecasting of traffic volumes and PoP utilization to proactively prevent performance degradation during peak periods (e.g., start of academic term, examination periods).	FC	
3.5.4 Generative AI Application Controls			
3.5.4.1	GenAI Application Discovery: Automated identification and categorization of all generative AI applications (ChatGPT, Gemini, Copilot, Claude, Midjourney, and others) accessed through the platform.	FC	
3.5.4.2	Granular GenAI Policy Controls: Per-application controls that allow differentiated policies, such as: allow ChatGPT for staff but restrict to read-only for students; block file upload to unsanctioned AI tools; allow institutional AI tools with full access.	FC	
3.5.4.3	AI Usage Analytics: Dashboards and reports showing GenAI application adoption, data exposure risk, and policy violations across user groups.	FC	
3.5.4.4	Agentic AI Governance: Visibility into agent-to-tool communications (MCP), intent-aware inspection of interactions and tool requests, and policy controls for agent connectivity.	FC	
3.6 BYOD-Specific Requirements			
3.6.1	PAC File / Proxy Auto-Configuration: Support for browser-level traffic steering via PAC file distribution (through DHCP/WPAD or manual configuration) without endpoint agent installation.	FC	

3.6.2 DNS Redirection: Ability to enforce DNS-layer security by configuring campus DHCP to point BYOD clients to the SASE platform DNS resolvers, providing baseline protection without any agent or proxy configuration.	FC	
3.6.3 IPsec Tunnel from Network Edge: Support for tunnel-based traffic steering from campus routers, firewalls, or SD-WAN appliances to the SASE PoP, capturing all internet traffic from BYOD VLANs transparently.	FC	
3.6.4 Certificate-Based Authentication: Support for BYOD user authentication via certificates distributed through an institutional onboarding portal (SCEP/EST) to provide identity context without requiring a full agent.	FC	
3.6.5 Device Type Differentiation: The platform must distinguish between managed and BYOD devices and apply differentiated security policies accordingly.	FC	
3.6.6 Privacy-Preserving Inspection: For BYOD users, the platform must support selective SSL inspection with configurable bypass categories (personal banking, healthcare) and clear user notification of inspection status.	FC	
3.6.7 Session-Based Controls: Time-based session controls for BYOD (e.g., maximum session duration, re-authentication intervals) to ensure continuous identity verification.	FC	
3.6.8 Guest User Self-Registration: Built-in or integrable captive portal workflow for guest user self- registration with terms-of-use acceptance, time-limited access, and configurable bandwidth quotas.	FC	Zscaler ZIA supports user self-registration workflow, but it does so through a seamless, cloud-to-cloud integration with certified technology partners (such as Cloudi-Fi or SecureW2) rather than building the guest registration/SMS gateway database natively inside the Zscaler portal.
3.7 Managed User-Specific Requirements		

3.7.1 Unified Endpoint Agent: A single lightweight agent that handles all SASE functions (SWG traffic steering, DNS security, certificate management, device posture reporting). The agent must support Windows 10/11, macOS (latest and N-1), iOS, and Android.	FC	
3.7.2 Always-On Connectivity: The agent must enforce an always-on tunnel to the SASE PoP with no user ability to disable it. Configurable fail-open or fail-close behaviour when the SASE PoP is unreachable.	FC	
3.7.3 Device Posture Assessment: Continuous endpoint posture checks including: OS patch level, endpoint protection agent status (running/updated), disk encryption status, firewall status, domain join status, and certificate validity. Posture results must feed into policy decisions.	FC	
3.7.4 Per-App Traffic Steering: Ability to selectively route specific application traffic through the SASE tunnel while allowing configurable split tunnel for trusted local services (e.g., local printer traffic, campus LAN resources).	FC	
3.7.5 Agent Tamper Protection: Anti-tamper mechanisms preventing users from uninstalling, disabling, or circumventing the agent without administrator credentials.	FC	
3.7.6 Silent Deployment: Support for silent deployment and update via enterprise endpoint management tools (SCCM, Intune, Jamf).	FC	
3.7.7 (Optional ZTNA) For managed users within the 200-user ZTNA scope, the unified SASE agent (Section 3.7.1) must handle both internet traffic steering and ZTNA private application tunnelling. No separate ZTNA agent or client shall be required. The agent must seamlessly route traffic to private applications through the SASE cloud ZTNA broker while simultaneously routing internet traffic through the SWG/ FWaaS inspection path.	FC	
3.7.8 (Optional ZTNA) The agent must support split-tunnel intelligence that can distinguish between: traffic destined for published private applications (routed via ZTNA broker), internet-bound traffic (routed via SWG/FWaaS), and local campus LAN traffic (routed directly, not via SASE). The traffic steering table must be dynamically updated based on the applications published to the user's ZTNA policy.	FC	
3.8 Platform Infrastructure and Performance Requirements		
3.8.1 Global PoP Footprint: The vendor must operate a globally distributed network of Points of Presence. At minimum, PoP presence	FC	

is required in the UAE and the broader GCC region with sub-30ms latency from all campus locations.		
3.8.2 PoP Redundancy: Automatic failover between PoPs with no user-perceptible disruption. Each PoP must be multi-homed with carrier-diverse internet connectivity.	FC	
3.8.3 Capacity and Scalability: The platform must support the total concurrent user count of the institution (29,000+ users, 45,000 concurrent devices) with no degradation. Architecture must be horizontally scalable.	FC	
3.8.4 Data Residency: Logs and configuration data must be stored within a specified geographic region to meet institutional and regulatory data residency requirements.	FC	
3.8.5 Uptime SLA: Minimum 99.999% platform availability SLA with financially backed service credits.	FC	https://www.zscaler.com/legal/sla-support
3.8.6 Latency SLA: Maximum additional latency introduced by the SASE inspection path must not exceed 25ms for SWG/FWaaS and 50ms for full SSL inspection plus sandboxing.	PC	Sandboxing time varies based on file size, file extension, content of the file, behaviour of the file, etc.
3.8.7 Throughput SLA: Per-user throughput must support a minimum of 100 Mbps for managed users and 50 Mbps for BYOD users through the full inspection stack.	FC	
3.8.8 Digital Experience Monitoring (DEM)		
3.8.8.1 End-to-End Path Visibility: Hop-by-hop visibility from endpoint to application, including Wi-Fi, LAN, WAN, SASE PoP, and application response metrics.	FC	
3.8.8.2 Synthetic Monitoring: Configurable synthetic probes to continuously test connectivity and performance to critical internet destinations and SaaS applications.	FC	
3.8.8.3 AI-Powered Root Cause Analysis: Automated correlation of user experience issues with network path anomalies, PoP performance, or application-side degradation.	FC	
3.8.8.4 User Experience Scoring: Per-user and per-application experience scores with historical trending and alerting on degradation.	FC	
3.8.9 (Optional ZTNA) ZTNA Session Establishment: Maximum time from user authentication completion to application session 428	FC	

availability shall not exceed 3 seconds for web applications and 5 seconds for thick client/RDP/SSH applications.		
3.8.10 (Optional ZTNA) ZTNA Throughput: Per-user throughput through the ZTNA inspection path must support a minimum of 50 Mbps for RDP sessions and 100 Mbps for file transfer operations.	FC	
3.8.11 (Optional ZTNA) ZTNA Latency: Additional latency introduced by the ZTNA brokering path (user → SASE cloud → connector → application) must not exceed 30ms for UAE based users and 80ms for users outside the UAE	FC	
3.9 Integration Requirements for Zero Trust Ecosystem		
The SASE platform must integrate with the following existing and planned infrastructure components. Integration capabilities are mandatory requirements for this procurement.		
3.9.1 Identity Provider (IdP) + MFA: SAML 2.0, OIDC, SCIM for user/group provisioning. Must support Azure AD/Entra ID, HCT in-house F5 SAML, and on-premises AD via federation. MFA enforcement at the SASE layer for every access request. Support for Edu Roam Federation.	FC	
3.9.2 Network Access Control (NAC): Integration via RADIUS CoA, REST API, or syslog to receive device posture and classification signals from the NAC. The SASE platform should accept NAC posture tags to differentiate policy for compliant vs. non-compliant devices.	FC	Achievable via REST API and external automation tool, noting that Zscaler supports client posture checks to validate if the device is compliant or not.
3.9.3 Next-Generation Firewall (NGFW): Bi-directional log sharing (syslog/CEF/LEEF), shared threat intelligence (STIX/TAXII), and ability to receive IPsec tunnels from the NGFW for on-premises traffic steering to the SASE PoP.	FC	Zscaler doesn't natively support receiving logs from next-generation firewalls, but depending on the use case, Zscaler can consume the relevant data via the REST API interface.
3.9.4 Endpoint Detection and Response (EDR/XDR): API-based integration to receive endpoint risk signals. When the EDR flags a	FC	

compromised endpoint, the SASE platform must dynamically adjust the access policy (e.g., restrict to isolation-only browsing or block entirely).		
3.9.5 SIEM / SOAR: Real-time log export via syslog (CEF), API, or native connector to enterprise SIEM. Support for common platforms (Splunk, Microsoft Sentinel, QRadar, FortiSIEM, Elastic). SOAR integration for automated response workflows.	FC	
3.9.6 Unified Endpoint Management (UEM/MDM): Query device compliance status (encryption, OS version, patch level) from UEM platforms (Intune, Jamf, VMware WS1) as an input to SASE policy decisions.	PC	Supported with different UEM/MDM on different levels in addition to utilising Zscaler's own device posture checks
3.9.7 Threat Intelligence Platform (TIP): Ingest external threat intelligence feeds (STIX/TAXII 2.1) and institutional indicators of compromise (IoCs) for custom blocklist enforcement.	FC	
3.9.8 ITSM / Ticketing: API integration with ServiceNow, IVANTI, or equivalent ITSM for automated ticket creation on security alerts and policy violations.	FC	Requires the utilization of an external automation tool
3.9.9 Integrate Microsoft Data Loss Prevention (DLP) with the SASE platform to enforce consistent data protection policies across web, cloud, and private application traffic.	FC	
3.9.10 Integrate Microsoft Defender for Cloud Apps (CASB) with the SASE solution for cloud application visibility, SaaS security, risk-based access control, and policy enforcement.	FC	https://www.zscaler.com/resources/solution-briefs/zscaler-microsoft-deliver-zero-trust-security.pdf https://learn.microsoft.com/en-us/defender-cloud-apps/zscaler-integration

3.9.11 Single sign-on: Integration with Windows AD, Microsoft Exchange Server and Terminal Server Agent, RADIUS Accounting message for wireless users, and captive portal authentication for wired users.	FC	
3.9.12 (Optional ZTNA) Privileged Access Management (PAM) Integration: If HCT deploys a PAM solution, the ZTNA platform must support integration via API or SAML to enforce PAM-brokered sessions for RDP/SSH access to sensitive servers. ZTNA session recording logs must be exportable to the PAM platform.	FC	Zscaler ZTNA will be the entry point to allow authorized access and reachability to HCT's PAM solution.
3.9.13 (Optional ZTNA) DNS-Based Application Routing: The ZTNA platform must support private DNS resolution so that published applications can be accessed via their internal FQDN (e.g., erp.hct.local) rather than requiring IP-based configuration. The platform must integrate with HCT's internal DNS servers for name resolution of private application FQDNs.	FC	
3.9.14 (Optional ZTNA) Service Ticket / Approval Workflow Integration: The ZTNA platform should support integration with ITSM (Ivanti or equivalent) for access request workflows, enabling users to request time-limited ZTNA access to specific applications through an approval workflow that automatically provisions and de-provisions access upon approval/expiry.	FC	Utilizing the REST API interface
3.10 Centralized Management and Reporting Requirements		
3.10.1 Single Management Console: All security and policy functions must be configurable and monitorable from a single cloud-based management portal. No separate consoles for separate features.	FC	
3.10.2 Role -Based Access Control (RBAC): Granular RBAC for administrative access with a minimum of read-only, operator, policy-admin, and super-admin roles. Support for SAML/OIDC-based admin authentication via the institutional IdP.	FC	
3.10.3 Policy Hierarchy: Support for hierarchical policy structure (global, regional, site-level, user-group- level) with inheritance and override capabilities.	FC	
3.10.4 Change Audit Trail: Immutable audit log of all administrative actions (policy changes, user modifications, configuration changes) with timestamps and administrator identity.	FC	
3.10.5 Real -Time Dashboards: Pre-built and customizable dashboards for security events, user activity, application usage, threat landscape.	FC	

3.10.6 Scheduled and On-Demand Reporting: Configurable scheduled reports (daily, weekly, monthly) and on-demand report generation for compliance, executive summary, threat summary, and incident reports. Export to PDF, CSV, and API-accessible formats.	FC	
3.10.7 Alerting and Notification: Configurable alerting thresholds with notification via email, webhook, syslog, and integration with ITSM platforms.	FC	
3.10.8 API Access: Comprehensive RESTful API for automation, integration, and custom reporting. API must cover policy management, user management, log retrieval, and configuration.	FC	
3.10.9 NOC / SOC View: Centralized monitoring and awareness of threats, events and network/internet activity, with predefined and customized dashboards.	FC	
3.10.10 Log Retention: High storage capacity for log retention up to 12 months of online searchable storage with option for extended archival. Log forwarding to third-party syslog server, CEF server, or SIEM solution.	FC	
3.10.11 Indicator of Compromise (IOC): Scan security logs to identify suspicious traffic patterns, continuously monitor for signs of compromise and present a prioritized list of possible compromised hosts.	FC	
3.10.12 HTML5-based Web UI: The management console should not have any Java, Flash or ActiveX components.	FC	
3.10.13 Integration with 3rd-party systems via JSON and XML Web Services API.	FC	
3.10.14 (Optional ZTNA) The management console must provide a dedicated ZTNA dashboard showing: active ZTNA sessions (real-time), application-level access summary, connector health and status across Primary DC and DR DC, user access patterns and top applications, session recording playback (for RDP/SSH if enabled), and ZTNA-specific policy violations and security events.	FC	
3.10.15 (Optional ZTNA) ZTNA Access Reports: The platform must generate ZTNA-specific reports including: per-user access audit trail (who accessed what application, when, from where, for how long), per-application access summary, denied access attempts with reason codes, device posture failures that prevented ZTNA access, and data volume transferred per user per application.	FC	
3.11 Managed Support Services		
3.11.1 Dedicated Onsite/offsite with 100% backfill in absence of Resident Engineer.	FC	Will be done by the Resident Engineer

3.11.2 24x7x365 back-to-back support contract from the principal vendor.	FC	
3.11.3 Carry out all operational activities and platform management, including changes, incidents, and availability monitoring.		
3.11.4 24x7x365 monitoring services including an alerting system.		
3.11.5 Premium 24x7x365 support with SLA.		
3.11.6 Problem Assessment and Investigation with root cause analysis.	FC	
3.11.7 Change Assessment and Implementation.	FC	Change assessment to be done by the resident engineer. Implementation will be covered with post-sales implementation support.
3.11.8 Policy and Configuration Management.	FC	Will be taken care of with post-sales
3.11.9 Policy Optimization and Tuning to ensure optimal resource utilization.	FC	Will be taken care of by the resident engineer
3.11.10 Patch/Update/Hotfix Implementation covering minor updates.	FC	Will be taken care of by the resident engineer
3.11.11 Configuration Backup and Restoration.	FC	Will be taken care of by the resident engineer
3.11.9 Unlimited break-fix support should be provided for any issues or problems.	FC	
3.11.10 The Bidder shall provide maintenance services through qualified, experienced and certified specialists.	FC	
3.11.11 Perform major and minor software/firmware/driver upgrades on a regular basis and keep the systems healthy and operational.	FC	Will be taken care of by the resident engineer
3.11.12 The bidder should have a 24x7x365 Help Desk System, Single Support Contact Number and provide Escalation Matrix and Support Methodology.	FC	

3.11.13	Vendor to provide a monthly report containing: Total number of tickets raised, Total number of tickets closed, Total number of tickets breached and reason for the breach, Technology-wise ticket details, RCA for all major incidents and service outages.	FC	
3.11.14	A monthly review meeting should be conducted to discuss the monthly report.	FC	
3.11.15	An Excel sheet with details of all the registered tickets for the month.	FC	
3.11.16	Quarterly preventive maintenance, health checks and Configuration review for in-scope platform components. Vendors provide quarterly configuration review and PM reports with findings and recommendations, and implement them.	FC	
3.11.17	Full ownership from local partners without any additional costs to HCT.	FC	
3.11.18	The vendor shall be responsible for the complete management of the SASE platform. This includes ensuring the platform is fully operational, maintaining health and availability, and managing configurations in alignment with HCT's operational requirements.	FC	
3.11.19	The vendor shall monitor the health, availability, and performance of the SASE platform on a 24/7 basis. The vendor must proactively detect and resolve any issues, ensuring timely patch management, security updates, and immediate remediation of faults.	FC	
3.11.20	24x7x365 comprehensive managed support services including simple and advanced configuration changes, customization, etc.	FC	
3.11.21	The vendor shall implement a formal change management process. Any proposed changes shall be evaluated for impact, tested in a non-production environment where possible, and approved by HCT before implementation.	FC	
3.11.22	The vendor should monitor the SASE platform 24x7x365 along with dashboards. All alerts and errors should be acknowledged and mitigated proactively. HCT should have access to the dashboards.	FC	
3.11.23	The vendor shall provide quarterly reports on performance, health, and capacity utilization. These reports shall include any potential risks, bottlenecks, or areas for improvement, along with actionable recommendations.	FC	

3.11.24	The vendor should ensure that all platform management activities comply with industry best practices and relevant regulatory requirements.	FC	
3.11.25	The vendor should provide a comprehensive dashboard covering all platform components to provide live information. Daily health check/status report on or before 7:45 AM on all working days.	FC	https://trust.zscaler.com/zscaler.net/cloud-status
3.11.26	The vendor should take all necessary precautions to ensure that the platform is always free from vulnerabilities/risks. The vendor should ensure that all components are within EoL/EoS expiry dates during the contract period and replace any that cross EoL/EoS at no additional cost.	FC	
3.11.29 Seasonal and Academic Calendar Considerations			
3.11.29.1	HCT shall provide the vendor with the annual academic calendar at least 60 days before each academic year. The vendor shall use this calendar to plan capacity, staffing, maintenance windows, and change schedules.	FC	
3.11.29.2	Capacity Surge Planning: The vendor shall implement a capacity surge plan aligned with HCT's academic calendar. Pre-provisioned additional capacity must be in place at least 7 days before the following peak periods: start of each semester (registration week), examination periods (mid-term and final exams), graduation and convocation events, and any other periods designated by HCT as critical. The vendor must demonstrate that the SASE PoPs serving HCT can handle at minimum 150% of normal peak load during these periods.	FC	
3.11.29.3	Change Freeze Windows: No platform maintenance, upgrades, policy changes, or configuration modifications shall be performed during examination periods unless explicitly approved in writing by the HCT Infrastructure Team. The change freeze window shall begin 3 business days before the first examination and end 1 business day after the last examination of each examination period.	PC	Zscaler will notify HCT and all other customers utilizing that specific cloud that will get any update, noting that most, if not all, the updates will not impact end-user traffic.
3.11.29.4	The vendor shall adjust staffing and support coverage during critical academic periods, ensuring that at minimum one additional senior engineer is on standby during examination weeks and registration periods.		

3.11.29.5 The vendor shall conduct a pre-semester readiness review at least 14 days before each semester start date, covering: platform health check, capacity validation, certificate expiry review, integration validation, and confirmation that no pending changes or known issues exist.	FC	
3.11.30 End-User Communication Protocol		
3.11.30.1 The vendor shall maintain a dedicated status page accessible to HCT IT staff (not publicly accessible) that displays real-time platform status, active incidents, scheduled maintenance, and historical uptime data.	PC	Zscaler cloud trust portal displays real-time platform status, active incidents, etc., but it's not dedicated to HCT, and it's publicly accessible.
3.11.30.2 The vendor shall send proactive notifications to HCT's IT operations team within 15 minutes of detecting any service degradation, platform anomaly, or PoP performance issue that could affect end users, even if the issue has not yet been classified as an incident.	FC	
3.11.30.3 HCT retains sole and exclusive authority over all communications to end users (students, staff, faculty, guests). The vendor shall not communicate directly with HCT end users under any circumstances without prior written authorization from HCT.	FC	
3.11.30.4 The vendor shall provide pre-approved communication templates to HCT for the following scenarios: planned maintenance notification, unplanned outage notification, service restoration notification, security incident advisory, and policy change notification. Templates shall be provided within 30 days of contract signing and updated annually.		Zscaler will be communicating that information to our subscribed customers over email.
3.11.30.5 For P1 and P2 incidents, the vendor shall provide HCT with situation update bulletins every 30 minutes until the incident is resolved or downgraded. Each bulletin must include current status, affected services, estimated time to resolution, and actions being taken.	FC	
3.12 Training Requirements		
3.12.1 The participating bidder shall provide OEM official training for all the proposed SASE technologies to HCT IT staff (minimum 4 staff).	FC	
3.12.2 The training must be conducted on the HCT premises.	FC	

3.12.3 Training must cover platform administration, policy configuration, troubleshooting, reporting, and integration management.	FC	
3.12.4 Provide a comprehensive online knowledge base, API documentation, and release notes accessible to institutional administrators.	FC	
3.12.5 The vendor shall provide refresher training annually for the duration of the contract at no additional cost to HCT, covering new features, platform updates, and changes to security best practices.	FC	All the new training will be accessible on demand via Zscaler University at no additional cost. Zscaler also conducts multiple user group training throughout the year.
3.12.6 The vendor shall provide a dedicated training lab or sandbox environment that mirrors the production SASE platform for HCT IT staff to practice configuration changes, test policies, and conduct operational drills without impacting the live environment.	FC	
3.12.7 Training materials, manuals, and recorded sessions shall be provided in digital format and remain the intellectual property of HCT for internal use throughout and beyond the contract period.	FC	All the training is available in Zscaler University, and access is granted for free to the relevant users during the contract period.
3.12.8 The vendor shall provide incident response drill training at least twice per year, simulating P1 and P2 scenarios to validate the joint HCT-vendor incident response process.		
3.12.9 Knowledge Transfer Program		
3.12.9.1 The vendor shall deliver a structured Knowledge Transfer (KT) program during the first 90 days of the operational phase. This program shall go beyond formal training and shall include documented troubleshooting decision trees for the 20 most common operational scenarios, common issue resolution playbooks with step-by-step procedures, a Day-1 Operations Guide covering all daily, weekly, and monthly operational tasks expected of HCT IT staff, and a Quick Reference Guide for emergency procedures.	FC	

3.12.9.2 Shadowing Sessions: During the first 90 days of the operational phase, the vendor shall provide shadowing opportunities where HCT IT staff work alongside vendor engineers on live operational tasks including incident handling, policy changes, and troubleshooting. A minimum of 40 hours of structured shadowing per HCT staff member shall be provided.	FC	
3.12.9.3 The vendor shall assess the knowledge transfer effectiveness at the end of the 90-day KT period through a practical assessment. If the assessment reveals gaps, the vendor shall provide additional targeted training at no cost until the gaps are closed.	FC	
3.12.9.4 The KT program shall be designed to ensure that HCT IT staff can independently perform Tier 1 and Tier 2 operational tasks (policy adjustments, user troubleshooting, report generation, basic incident triage) without vendor assistance after the 90-day KT period. The vendor remains responsible for Tier 3 and above.	FC	
3.13 Documentation Requirements		
3.13.1 The participating bidder must provide detailed documentation including architectural diagrams, high-level and low-level design documents, as-built drawings, integration topology diagrams, SOP, runbooks, and traffic flow diagrams.	FC	
3.13.2 Complete configuration documentation for all SASE platform components, policies, and integrations.	FC	
3.13.3 Runbook documentation covering standard operating procedures, incident response procedures, and escalation procedures.	FC	
3.13.4 The vendor should provide a complete set of detailed documents to cover all proposed technologies and maintain version control. Regular updates should be applied.	FC	All the technology-related documents are maintained on the public Zscaler documentation.
3.13.5 The vendor shall maintain a Configuration Management Database (CMDB) or equivalent register of all SASE platform components, policy objects, integration endpoints, and user group mappings. This register must be updated within 5 business days of any change and made available to HCT upon request.	FC	
3.13.6 The vendor shall provide a Security Architecture Document describing the end-to-end security posture of the SASE platform, including encryption standards, key management procedures, data handling practices, and threat model assumptions. This document must be updated annually.	FC	

3.13.7 All documentation shall be delivered in editable formats (Word/Visio/Draw.io) in addition to PDF. HCT shall retain full ownership and unrestricted use rights over all project documentation.	FC																															
3.13.8 The vendor shall maintain a Risk Register documenting all identified risks to the SASE platform, their probability, impact, mitigation measures, and risk owners. This register must be reviewed and updated quarterly as part of the governance review.	FC																															
3.14 Service Level Agreements																																
The following are the minimum acceptable service levels. The vendor shall comply with all SLA targets throughout the contract period. Failure to meet SLA targets shall result in financial penalties as defined in this section.																																
3.14.1 Incident Response and Resolution SLA	FC																															
<table><tr><th>SLA Matrix</th><th>P1</th><th>P2</th><th>P3</th><th>P4</th></tr><tr><td>Response Time</td><td>30 Mins</td><td>2 Hrs</td><td>4 Hrs</td><td>8 Hrs</td></tr><tr><td>Resolution Time</td><td>2 Hrs</td><td>6 Hrs</td><td>16 Hrs</td><td>32 Hrs</td></tr></table> <table><tr><th>Fault Classification</th><th>Response Time</th><th>Resolution Time</th></tr><tr><td>P1 - Critical (service affecting): Any critical SASE platform outage that results in loss of internet security for users or complete service unavailability.</td><td>30 Minutes</td><td>2 Hours</td></tr><tr><td>P2 - High (service affecting): Any major degradation of SASE platform performance that affects end user internet security quality or significantly impairs policy enforcement.</td><td>2 Hours</td><td>6 Hours</td></tr><tr><td>P3 - Medium (partially service affecting): Any medium degradation that has partial impact on end user security quality and impact on service operations.</td><td>4 Hours</td><td>16 Hours</td></tr><tr><td>P4 - Low (non-service affecting): Any minor degradation that does not have any impact on end user security quality and minimal impact on service operations.</td><td>8 Hours</td><td>32 Hours</td></tr></table>		SLA Matrix	P1	P2	P3	P4	Response Time	30 Mins	2 Hrs	4 Hrs	8 Hrs	Resolution Time	2 Hrs	6 Hrs	16 Hrs	32 Hrs	Fault Classification	Response Time	Resolution Time	P1 - Critical (service affecting): Any critical SASE platform outage that results in loss of internet security for users or complete service unavailability.	30 Minutes	2 Hours	P2 - High (service affecting): Any major degradation of SASE platform performance that affects end user internet security quality or significantly impairs policy enforcement.	2 Hours	6 Hours	P3 - Medium (partially service affecting): Any medium degradation that has partial impact on end user security quality and impact on service operations.	4 Hours	16 Hours	P4 - Low (non-service affecting): Any minor degradation that does not have any impact on end user security quality and minimal impact on service operations.	8 Hours	32 Hours	
SLA Matrix		P1	P2	P3	P4																											
Response Time	30 Mins	2 Hrs	4 Hrs	8 Hrs																												
Resolution Time	2 Hrs	6 Hrs	16 Hrs	32 Hrs																												
Fault Classification	Response Time	Resolution Time																														
P1 - Critical (service affecting): Any critical SASE platform outage that results in loss of internet security for users or complete service unavailability.	30 Minutes	2 Hours																														
P2 - High (service affecting): Any major degradation of SASE platform performance that affects end user internet security quality or significantly impairs policy enforcement.	2 Hours	6 Hours																														
P3 - Medium (partially service affecting): Any medium degradation that has partial impact on end user security quality and impact on service operations.	4 Hours	16 Hours																														
P4 - Low (non-service affecting): Any minor degradation that does not have any impact on end user security quality and minimal impact on service operations.	8 Hours	32 Hours																														
3.14.2 Incident Management Authority																																
3.14.2.1HCT reserves the sole and exclusive right to override the vendor’s incident priority classification. If HCT determines that an incident has been classified at a lower priority than warranted, HCT may reclassify the incident to a higher priority by written notification (email or ticketing system). Upon reclassification, the SLA response and resolution clocks shall reset to the higher priority’s requirements from the time of HCT’s reclassification.	FC																															
3.14.2.2Ticket Closure Authority: No incident ticket shall be marked as ‘Resolved’ or ‘Closed’ without explicit written confirmation from HCT. The vendor may mark a ticket as ‘Pending HCT Confirmation’ once the vendor believes the issue is resolved, but the SLA resolution clock continues until HCT provides confirmation. If HCT does not respond within 3 business days of the vendor’s confirmation request, the ticket may be auto-closed but must be re-opened immediately if HCT reports the issue persists.	FC																															
3.14.2.3Recurring Incident Escalation: If the same or substantially similar incident recurs three (3) or more times within a rolling 30-day period, the third occurrence shall be automatically escalated to P1 regardless of its individual severity assessment, and the vendor shall	FC	TSM will be the main focal point for this																														

perform a comprehensive root cause analysis with a permanent fix plan within 5 business days.																																		
3.14.2.4The vendor shall provide HCT with read-only access to the vendor’s ticketing system for all HCT-related incidents, enabling HCT to independently verify ticket status, timestamps, and SLA adherence at any time.	FC																																	
3.14.3 Mandatory Escalation Matrix																																		
The vendor shall implement the following mandatory escalation ladder. Escalation shall be automatic and require no action from HCT: <table><tr><th>Escalation Level</th><th>Trigger</th><th>Vendor Action Required</th><th>Timeframe</th></tr><tr><td>Level 1</td><td>P1 ticket opened</td><td>Assigned engineer + vendor duty manager notified</td><td>Immediate</td></tr><tr><td>Level 2</td><td>P1 not resolved within 2 hours</td><td>Vendor Regional Technical Director joins bridge call with HCT</td><td>2 Hours</td></tr><tr><td>Level 3</td><td>P1 not resolved within 4 hours</td><td>Vendor VP of Engineering / CTO engaged; dedicated war room established</td><td>4 Hours</td></tr><tr><td>Level 4</td><td>P1 not resolved within 8 hours</td><td>Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT</td><td>8 Hours</td></tr><tr><td>Level 5</td><td>P1 not resolved within 24 hours</td><td>Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership</td><td>24 Hours</td></tr><tr><td>Level 2 (P2)</td><td>P2 not resolved within 6 hours</td><td>Vendor Technical Director engaged</td><td>6 Hours</td></tr><tr><td>Level 3 (P2)</td><td>P2 not resolved within 16 hours</td><td>Vendor Regional Director engaged with action plan</td><td>16 Hours</td></tr></table>	Escalation Level	Trigger	Vendor Action Required	Timeframe	Level 1	P1 ticket opened	Assigned engineer + vendor duty manager notified	Immediate	Level 2	P1 not resolved within 2 hours	Vendor Regional Technical Director joins bridge call with HCT	2 Hours	Level 3	P1 not resolved within 4 hours	Vendor VP of Engineering / CTO engaged; dedicated war room established	4 Hours	Level 4	P1 not resolved within 8 hours	Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT	8 Hours	Level 5	P1 not resolved within 24 hours	Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership	24 Hours	Level 2 (P2)	P2 not resolved within 6 hours	Vendor Technical Director engaged	6 Hours	Level 3 (P2)	P2 not resolved within 16 hours	Vendor Regional Director engaged with action plan	16 Hours	FC	The final escalation matrix with specific contacts will be defined with the involvement of the account TSM. https://www.zscaler.com/legal/sla-support
Escalation Level	Trigger	Vendor Action Required	Timeframe																															
Level 1	P1 ticket opened	Assigned engineer + vendor duty manager notified	Immediate																															
Level 2	P1 not resolved within 2 hours	Vendor Regional Technical Director joins bridge call with HCT	2 Hours																															
Level 3	P1 not resolved within 4 hours	Vendor VP of Engineering / CTO engaged; dedicated war room established	4 Hours																															
Level 4	P1 not resolved within 8 hours	Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT	8 Hours																															
Level 5	P1 not resolved within 24 hours	Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership	24 Hours																															
Level 2 (P2)	P2 not resolved within 6 hours	Vendor Technical Director engaged	6 Hours																															
Level 3 (P2)	P2 not resolved within 16 hours	Vendor Regional Director engaged with action plan	16 Hours																															
3.14.4 Platform Availability SLA																																		
<table><tr><th>SLA Metric</th><th>Target</th><th>Measurement</th></tr><tr><td>Overall Platform Availability</td><td>99.999% (five nines)</td><td>Measured monthly across all PoPs serving HCT traffic</td></tr><tr><td>SWG Availability</td><td>99.999%</td><td>Measured as percentage of time SWG inspection path is operational</td></tr><tr><td>FWaaS Availability</td><td>99.999%</td><td>Measured as percentage of time FWaaS inspection path is operational</td></tr><tr><td>RBI/Enterprise Browser Session Launch</td><td>99.9%</td><td>Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds</td></tr><tr><td>Management Console Availability</td><td>99.9%</td><td>Measured as percentage of time admin console is accessible</td></tr><tr><td>DEM Data Freshness</td><td>< 5 minutes</td><td>Maximum delay between user event and DEM dashboard reflection</td></tr><tr><td>ZTNA Private Access Availability</td><td>99.99%</td><td>Measured as % of time ZTNA brokered sessions can be established</td></tr></table>	SLA Metric	Target	Measurement	Overall Platform Availability	99.999% (five nines)	Measured monthly across all PoPs serving HCT traffic	SWG Availability	99.999%	Measured as percentage of time SWG inspection path is operational	FWaaS Availability	99.999%	Measured as percentage of time FWaaS inspection path is operational	RBI/Enterprise Browser Session Launch	99.9%	Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds	Management Console Availability	99.9%	Measured as percentage of time admin console is accessible	DEM Data Freshness	< 5 minutes	Maximum delay between user event and DEM dashboard reflection	ZTNA Private Access Availability	99.99%	Measured as % of time ZTNA brokered sessions can be established	FC									
SLA Metric	Target	Measurement																																
Overall Platform Availability	99.999% (five nines)	Measured monthly across all PoPs serving HCT traffic																																
SWG Availability	99.999%	Measured as percentage of time SWG inspection path is operational																																
FWaaS Availability	99.999%	Measured as percentage of time FWaaS inspection path is operational																																
RBI/Enterprise Browser Session Launch	99.9%	Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds																																
Management Console Availability	99.9%	Measured as percentage of time admin console is accessible																																
DEM Data Freshness	< 5 minutes	Maximum delay between user event and DEM dashboard reflection																																
ZTNA Private Access Availability	99.99%	Measured as % of time ZTNA brokered sessions can be established																																
3.14.5 SLA Measurement and Reporting																																		
3.14.5.1SLA Measurement Methodology: The vendor shall provide a real-time SLA dashboard accessible to HCT 24x7x365 that displays current and historical availability, latency, throughput, and incident metrics for all SLA-measured components. SLA measurements shall be independently verifiable and not solely based on vendor self-reporting.	FC																																	
3.14.5.2HCT reserves the right to use its own DEM measurements, third-party monitoring tools, or independent audit results to dispute vendor-reported SLA figures. In the event of a dispute, the vendor must provide raw telemetry data within 5 business days to support their SLA calculations.	FC																																	

3.14.5.3The vendor shall deliver a formal SLA Performance Report within 5 business days of each calendar month end, including: actual availability per component, latency measurements, incident summary with SLA adherence, service credit calculations, and trend analysis.	FC	
3.14.5.4SLA Exclusions: The vendor may exclude only the following from SLA calculations: (a) scheduled maintenance windows pre-approved by HCT with a minimum of 7 calendar days advance notice, limited to a maximum of 4 hours per month during off-peak hours (Friday/Saturday 00:00-06:00 UAE time); (b) issues directly and demonstrably caused by HCT network infrastructure upstream of the SASE PoP handoff point. No other exclusions shall apply. Vendor internal issues including but not limited to staffing shortages, licensing disputes, sub- processor failures, or cloud infrastructure partner outages shall NOT constitute valid SLA exclusions.	FC	
3.14.5.5Security Efficacy SLA: The vendor shall report quarterly on false positive rates (target: < 0.1% of inspected sessions), malware detection rates (target: > 99% against industry-standard test suites such as AV-TEST or AMTSO), and mean time to block newly identified threats (target: < 60 seconds for known IoC, < 24 hours for zero-day).	PC	Zscaler offers 100% known Virus Capture Rate, but we don't provide false positive SLAs
3.14.5.6Chronic SLA Failure: If the vendor fails to meet the overall platform availability SLA (99.999%) for three or more months in any rolling 12-month period, HCT shall have the right to terminate the contract for cause and invoke the Transition Assistance obligations defined in Section 3.23.	FC	Based on the availability SLA in the following: https://www.zscaler.com/legal/sla-support
3.14.6 Financial Penalties and Service Credits		
3.14.6.1SLA breaches shall be governed in accordance with HCT Contract Terms and Conditions. Any applicable service credits, liquidated damages, penalties, or other contractual remedies arising from non-compliance with the agreed SLAs shall be determined and enforced by the HCT Contracts Team in accordance with HCT policies and procedures.		
3.15 Equipment Delivery or Project Timeline		
3.15.1 The SASE platform deployment, migration from legacy on-premises SASE, and commissioning should be completed within 3 months from the date of signing the contract.	FC	
3.15.2 A minimum 30-day parallel operation period where both legacy and new platforms operate simultaneously to validate policy parity and performance.	FC	

3.15.3 Policy migration assistance: The vendor must provide tooling or professional services to translate existing on-premises security policies into the new cloud platform format.	FC	
3.15.4 The vendor shall provide a detailed phased migration plan within 15 business days of contract signing, including site-by-site rollout sequence, rollback criteria for each phase, and user communication templates.	FC	
3.15.5 User Acceptance Testing (UAT): Each deployment phase must include a formal UAT period (minimum 10 business days) with defined acceptance criteria. HCT shall have the right to reject any phase that does not meet the documented acceptance criteria, and the vendor shall remediate and re-submit at no additional cost.	FC	
3.15.6 Go-Live Readiness Review: The vendor shall conduct a formal Go-Live Readiness Review with HCT before transitioning from parallel operation to production. This review must demonstrate policy parity, performance baseline compliance, integration validation, and incident response readiness. Go-Live requires formal HCT written sign-off.	FC	
3.15.7 Rollback and Migration Risk Management		
3.15.7.1 The vendor shall develop, document, and test a Rollback Plan for each migration phase before that phase begins. The rollback plan must be executable within 4 hours and must restore full service on the legacy platform with no data loss and no user-perceptible disruption beyond the rollback window.	FC	
3.15.7.2 Rollback Triggers: The rollback plan shall define specific, measurable triggers that automatically initiate rollback, including but not limited to: (a) internet latency increase of more than 20% over pre-migration baseline for more than 30 minutes; (b) policy enforcement failure rate exceeding 1% of inspected sessions; (c) more than 5% of users unable to access internet resources; (d) any P1 incident on the new platform not resolved within the P1 resolution SLA; (e) any integration failure with IdP, NAC, or SIEM that is not resolved within 4 hours.	FC	
3.15.7.3 The vendor shall maintain the legacy on-premises SASE platform in a fully operational state during the entire parallel operation period and for a minimum of 60 days after HCT provides formal written confirmation that the new platform is operating satisfactorily. Decommissioning of the legacy platform shall only occur after HCT provides explicit written authorization.	FC	
3.15.7.4 The vendor shall conduct a rollback drill (simulated rollback on a non-production segment) before commencing the first	FC	

production migration phase, to validate that the rollback procedure works as documented. Results of the drill must be shared with HCT.		
3.15.8 Pre-Deployment Performance Baseline		
3.15.8.1 Before the SASE platform goes live on any campus, the vendor shall measure and document the current baseline performance at that campus, including: internet round-trip latency to top 20 internet destinations, throughput (download/upload) for managed and BYOD users, application response times for HCT's top 10 SaaS applications (LMS, Google Workspace, Microsoft 365, etc.), DNS resolution time, user experience scores from the existing DEM or synthetic probes, and Wi-Fi to internet path performance metrics.	FC	
3.15.8.2 Post-deployment, the vendor shall repeat the same baseline measurements within 7 days of go-live on each campus. The SASE platform must not degrade any baseline metric by more than 10%. If any metric is degraded by more than 10%, the vendor must provide a remediation plan within 3 business days and remediate within 10 business days, or a rollback shall be triggered.	PC	Baseline remeasurement process can be committed to, but the $\leq 10\%$ degradation threshold depends on last-mile/ISP and campus network conditions outside the vendor's direct control.
3.15.8.3 The pre-deployment and post-deployment baseline measurements shall be compiled into a Performance Baseline Report for each campus, signed by both HCT and the vendor, and shall serve as the reference for ongoing performance SLA compliance throughout the contract.	FC	
3.15.9 Legacy Platform Decommissioning		
3.15.9.1 The vendor shall provide a comprehensive Legacy Decommissioning Plan covering: (a) data migration and archival from the legacy platform (logs, reports, historical analytics) to ensure continuity of audit trail; (b) license termination coordination with the legacy vendor (if applicable); (c) configuration export from the legacy platform in a format usable for reference and auditing; (d) validation that no traffic is still flowing through the legacy platform; (e) hardware disposal or repurposing guidance for any on-premises SASE appliances.	FC	
3.15.9.2 The legacy decommissioning shall only proceed after: (a) the new platform has been in production for a minimum of 60 days with	FC	

all SLAs met; (b) all baseline performance comparisons confirm no degradation beyond 10%; (c) all integrations have been validated on the new platform; (d) HCT provides formal written decommissioning authorization.		
3.15.9.3The vendor shall provide a formal Decommissioning Completion Certificate to HCT upon completion, confirming that all legacy data has been migrated or archived, all legacy services have been terminated, and no residual dependencies on the legacy platform remain.	FC	
3.15.10 Liquidated Damages for Project Delays		
3.15.10.1 SLA breaches shall be governed in accordance with HCT Contract Terms and Conditions. Any applicable service credits, liquidated damages, penalties, or other contractual remedies arising from non-compliance with the agreed SLAs shall be determined and enforced by the HCT Contracts Team in accordance with HCT policies and procedures.	FC	
3.15.10.2 Liquidated damages for project delays are separate from and in addition to any operational SLA penalties that may apply after Go-Live.	FC	
3.15.10.3 Delays caused solely by HCT (such as delayed site access, delayed approvals, or changes in scope requested by HCT) shall not be attributable to the vendor. All other delays, including those caused by vendor sub-contractors, resource availability, or vendor technology issues, shall be the vendor's responsibility.	FC	
3.16 Special Terms and Conditions		
3.16.1 Contract Duration and Commercial Terms		
3.16.1.1The contract shall be for 3 years from the date of signature.	FC	
3.16.1.2The payment shall be made on a yearly basis over 3 years based on the successful completion and acceptance of each site.	FC	
3.16.1.3Warranty and support for all subscriptions, licenses, and cloud services should be included for 3 years without any additional cost to HCT.	FC	
3.16.1.4HCT has the option to decide to renew/extend this contract at the end of the contract for the same cost.	PC	Subject to approvals
3.16.1.5Price Lock: The vendor shall not increase the subscription, licensing, or service fees for the duration of the 3-year contract. Any additional users, campuses, or capacity increases during the contract period shall be priced at or below the per-unit rates in the original contract.	FC	

3.16.1.6 Benchmarking Right: At the end of Year 3, HCT reserves the right to commission an independent benchmarking exercise to compare the vendor's pricing and service capability against current market offerings. If the benchmarking exercise demonstrates that the vendor's pricing is more than 15% above the market median for comparable SASE services, the vendor shall negotiate in good faith to align pricing within 10% of the market median.	PC	Subject to approvals
3.16.2 Payment Milestones Payments shall be tied to the successful completion and formal acceptance of defined milestones:		
3.16.3 Vendor Certifications and Compliance		
3.16.3.1 The vendor must hold current ISO 27001, SOC 2 Type II, and CSA STAR certifications for the SASE platform and its supporting infrastructure.	FC	
3.16.3.2 The vendor shall maintain all required certifications (ISO 27001, SOC 2 Type II, CSA STAR) throughout the entire contract duration. Renewed certificates must be provided to HCT within 30 days of issuance. Loss of any certification shall be reported to HCT within 5 business days and shall constitute grounds for termination for cause if not remediated within 90 days.	FC	
3.16.3.3 The vendor shall provide HCT with the annual SOC 2 Type II audit report within 30 days of its completion. If any material findings or qualifications are identified, the vendor shall provide a remediation plan within 15 business days.	FC	
3.16.4 Data Protection and Encryption		
3.16.4.1 Data Encryption: All data in transit between endpoints and the SASE PoP must be encrypted using TLS 1.2 or higher. All data at rest (logs, configuration, cached content) must be encrypted using AES-256 or equivalent.	FC	
3.16.4.2 The vendor must provide a Data Processing Agreement (DPA) that complies with UAE Federal Decree-Law No. 45 of 2021 (Personal Data Protection Law), EU GDPR (where applicable to international data transfers), and any other applicable local data protection regulations.	FC	
3.16.4.3 Data Classification Alignment: The vendor shall treat all HCT traffic metadata, logs, user identity information, and platform configurations in accordance with HCT's internal data classification policy. The vendor shall implement appropriate access controls, retention periods, and handling procedures for each classification level.	FC	

3.16.4.4 Data Sovereignty: HCT logs, metadata, and configuration data shall not be stored, processed, or transferred outside of the UAE/GCC region. The vendor shall provide written confirmation of all data storage locations and notify HCT 90 days in advance of any proposed change in data storage geography.	PC	
3.16.4.5 Key Management: Encryption keys used for HCT data shall be managed in accordance with industry's best practices (NIST SP 800-57). Where technically feasible, the vendor shall support customer-managed encryption keys (CMEK / BYOK) for HCT log data and configuration backups.	FC	
3.16.4.6 The solution shall support integration with Hardware Security Modules (HSM) for cryptographic key management, in compliance with UAE National Cybersecurity policies and NIST SP 800-57 key management recommendations. Where the SASE platform generates, stores, or manages cryptographic keys (including SSL/TLS inspection certificates, SAML signing certificates, and API authentication keys), the platform must support the use of FIPS 140-2 Level 2 (or higher) validated HSMs — whether vendor-managed cloud HSM or HCT-managed on-premises HSM — for key generation, storage, and lifecycle management. The vendor shall confirm HSM integration capability in their proposal and specify which HSM vendors and cloud HSM services (e.g., Azure Key Vault with HSM backing, AWS CloudHSM, Thales Luna, Entrust nShield) are supported.	FC	
3.16.5 Sub-Processor and Fourth-Party Governance		
3.16.5.1 The vendor shall disclose to HCT a complete list of all sub-processors and fourth parties involved in delivering the SASE service, including their roles, data access levels, and geographic locations. This list shall be provided prior to contract signing and updated within 30 days of any change.	FC	
3.16.5.2 The vendor shall not engage any new sub-processor or change any existing sub-processor without providing HCT with 60 days written notice and receiving HCT's written approval. HCT reserves the right to object to any sub-processor on reasonable grounds including data protection, geographic, or security concerns.	PC	Zscaler will notify and publish the list of updated sub-processors.
3.16.5.3 The vendor shall ensure that all sub-processors and fourth parties are contractually bound to security, confidentiality, and data protection obligations at least equivalent to those imposed on the vendor under this contract.	FC	
3.16.5.4 The vendor shall remain fully liable to HCT for all acts, omissions, and breaches by its sub-processors and fourth parties.	FC	

Use of sub-processors does not reduce or limit the vendor's obligations or liabilities under this contract.		
3.16.6 Vendor Personnel and Security		
3.16.6.1 All vendor personnel (including sub-contractors) who will have access to HCT traffic, data, or platform administration shall be subject to background verification checks. The vendor shall provide written confirmation that background checks have been completed for all assigned personnel prior to granting access.	FC	
3.16.6.2 Key Personnel Clause: The vendor shall identify named Key Personnel (at minimum: Project Manager, Technical Lead, Operations Lead, and Security Lead) assigned to the HCT account. Replacement of any Key Personnel requires 30 days' written notice to HCT and HCT's written approval. Replacement personnel must have equal or greater qualifications and experience.	FC	
3.16.6.3 The vendor shall immediately revoke access for any personnel who are no longer assigned to the HCT account and confirm revocation to HCT within 24 hours.	FC	
3.16.6.4 All vendor personnel with administrative access to the SASE platform serving HCT shall complete security awareness training annually. Evidence of training completion shall be provided to HCT upon request.	FC	
3.16.7 Vendor Lock-In Mitigation		
3.16.7.1 The vendor shall use open and industry-standard protocols wherever technically feasible, including but not limited to: SAML 2.0 / OIDC for identity federation, SCIM for user provisioning, CEF / LEEF for log export, STIX / TAXII 2.1 for threat intelligence exchange, syslog (RFC 5424) for event forwarding, RADIUS / RADIUS CoA for network integration, RESTful APIs with OpenAPI/Swagger documentation for automation, and IPsec for tunnel-based traffic steering.	FC	
3.16.7.2 If the vendor uses any proprietary protocols, formats, agents, or data structures that are not based on open standards, the vendor shall: (a) disclose all such proprietary elements to HCT before contract signing; (b) document the proprietary protocol or format sufficiently for migration or interoperability purposes; (c) provide a migration guide describing how to export data and configurations from the proprietary format to an open-standard equivalent.	FC	
3.16.7.3 The vendor's endpoint agent shall not create dependencies that persist beyond the contract period. The agent must be fully and cleanly uninstallable from all endpoint operating systems without leaving residual services, drivers, certificates, or registry entries that would impede installation of a replacement solution.	FC	

3.16.7.4All HCT policies, configurations, user/group mappings, URL category customizations, and integration configurations shall be exportable at any time via API or management console in a machine-readable, vendor-neutral format (JSON, CSV, XML). The vendor shall demonstrate this export capability during the PoC phase (Section 3.24).	FC	
3.16.8 Technology Refresh and Roadmap Alignment		
3.16.8.1The vendor shall keep HCT on the current-generation SASE platform throughout the 3-years contract duration. If the vendor releases a next-generation platform, HCT shall receive the upgrade at no additional cost, including all migration services required to move from the current to the next-generation platform.	FC	
3.16.8.2The vendor shall provide HCT with an annual Technology Roadmap Briefing (no later than Q1 of each contract year) covering: planned feature releases for the next 12 months, end-of-life or deprecation notices for any components used by HCT, emerging threat landscape trends and how the platform is evolving to address them, and any planned architectural changes to the SASE platform that may affect HCT's deployment.	FC	
3.16.8.3New features that fall within the contracted scope (SWG, FWaaS, RBI/Enterprise, DNS Security, AI Security, DEM, Management, Integration) shall be enabled for HCT as they become generally available, at no additional license, subscription, or service cost.	FC	
3.16.8.4If the vendor's technology roadmap diverges materially from HCT's strategic direction (as determined by HCT in its reasonable discretion), HCT shall have the right to invoke the benchmarking clause (3.16.1.6) at any time rather than waiting until Year 3, and if the divergence cannot be reconciled, HCT may terminate the contract for convenience under Section 3.23.3.1.	PC	Zscaler will notify HCT on a yearly basis with the roadmap.
3.16.9 Conflict of Interest Disclosure		
3.16.9.1The vendor shall disclose to HCT, prior to contract signing and on an annual basis thereafter, any existing or potential conflicts of interest including but not limited to: (a) engagements with other UAE federal or educational entities where HCT's data, configurations, or traffic patterns could be exposed or shared, even in anonymized or aggregated form; (b) partnerships, reseller agreements, or financial relationships with competitors of HCT's existing technology vendors (NAC, NGFW, wireless, IdP, SIEM) that could influence the vendor's integration recommendations or support prioritization; (c) any pending or threatened litigation, regulatory action, or investigation that could materially affect the vendor's ability to deliver the	FC	

contracted services; (d) any financial interest or relationship between the vendor's personnel assigned to the HCT account and HCT employees or contractors.		
3.16.9.2 If a conflict of interest is identified (either through disclosure or discovery), the vendor shall propose mitigation measures within 10 business days. HCT reserves the right to approve, reject, or propose alternative mitigation measures. If the conflict cannot be adequately mitigated, HCT may require replacement of affected vendor personnel or, in severe cases, terminate the contract for cause.	FC	
3.16.10 Testing and Non-Production Environment		
3.16.10.1 The vendor shall provide HCT with a dedicated testing and non-production environment (sandbox/staging tenant) that mirrors the production SASE platform configuration. This environment must be available from the deployment phase through the full contract term at no additional cost.	FC	
3.16.10.2 The testing environment shall be used for: validating policy changes before production deployment, testing new features and platform updates before rollout, conducting integration testing with HCT's security ecosystem (IdP, NAC, NGFW, SIEM, EDR), training and knowledge transfer exercises for HCT IT staff, simulating incident response scenarios and tabletop exercises, and validating major SASE platform upgrades before production activation.	FC	
3.16.10.3 The testing environment must support: a representative subset of production security policies, the ability to generate and inspect test traffic (managed and BYOD profiles), all integration endpoints in test mode, full management console access with the same RBAC model as production, and logging and reporting capabilities for test validation.	FC	
3.16.10.4 The testing environment must be logically isolated from the production environment. No test traffic, test policies, or test configurations shall affect or interact with the production platform.	FC	
3.16.10.5 The vendor shall ensure the testing environment is maintained at the same software version as the production environment, or at the version being evaluated for upgrade, throughout the contract term.	FC	
3.17 Project Management		
3.17.1 The winning bidder must appoint a dedicated PM to ensure that all project management processes are effectively managed in accordance with HCT PMO Policy & procedures and PMBOK (PMI) standards and guidelines.	FC	

3.17.2 The winning bidder shall appoint a Project Manager on site. This individual will head the project for the duration of the work except by mutual agreement with HCT.	FC													
3.17.3 Have sufficient authority to make day-to-day decisions on site during the progress of the project without recourse to his/her Head Office.	FC													
3.17.4 The Project Manager shall institute changes in project management processes as necessary to ensure that the project is executed within scope, budget and schedule and at an acceptable level of risk. Specific processes include: • Scope Management • Schedule Management • Cost Management • Quality Management • Staffing Management • Communications Management • Risk Management • Procurement Management • Change Management	FC													
3.17.5 The vendor project manager should be available on a scheduled weekly basis for a meeting to update the HCT representative on vendor work progress and problem resolution. Project Management Office Deliverables: <table><tr><th>Deliverable</th><th>Description</th></tr><tr><td>Project Charter</td><td>The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.</td></tr><tr><td>Project Scope Statement</td><td>Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.</td></tr><tr><td>Project Schedule</td><td>Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.</td></tr><tr><td>Project Progress Status Report</td><td>To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.</td></tr><tr><td>Documentation</td><td>Provide all the documentation as per Section 3.13.</td></tr></table>	Deliverable	Description	Project Charter	The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.	Project Scope Statement	Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.	Project Schedule	Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.	Project Progress Status Report	To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.	Documentation	Provide all the documentation as per Section 3.13.	FC	
Deliverable	Description													
Project Charter	The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.													
Project Scope Statement	Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.													
Project Schedule	Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.													
Project Progress Status Report	To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.													
Documentation	Provide all the documentation as per Section 3.13.													
3.17.6 Project-to-Operations Handover														
3.17.6.1The vendor shall conduct a formal Project Closure and Operational Handover process at the conclusion of the deployment phase, before the project team is demobilized and responsibility transfers to the vendor's operations team.	FC													
3.17.6.2The Project-to-Operations Handover shall include the following mandatory checklist items, each requiring sign-off from both HCT and the vendor:	FC													

Handover Item	Description	Sign-Off Required		
Documentation Completeness	All documentation listed in Section 3.13 has been delivered, reviewed, and accepted by HCT.	HCT IT + Vendor PM		
Integration Validation	All integrations (Section 3.9) have been tested and validated with bi-directional data flow confirmed.	HCT IT + Vendor Tech Lead		
Monitoring and Alerting	All monitoring dashboards, alerting rules, and notification channels are operational and verified.	HCT IT + Vendor Ops Lead		
Configuration Baseline	Approved configuration baseline (Section 3.18.2.1) has been established, documented, and signed off.	HCT IT + Vendor		
Knowledge Transfer	90-day KT program (Section 3.12.9) has been completed and practical assessment passed.	HCT IT + Vendor		
Runbooks and Playbooks	All operational runbooks and incident response playbooks have been delivered and walked through with HCT staff.	HCT IT + Vendor Ops Lead		
Escalation Contacts	Complete escalation contact list for vendor operations team provided and verified.	HCT IT + Vendor Ops Lead		
Backup and Recovery	Configuration backup procedures tested and verified; restore drill completed successfully.	HCT IT + Vendor		
SLA Baseline	SLA measurement baseline established, dashboards operational, and first SLA report generated.	HCT IT + Vendor Ops Lead		
Open Issues Register	All known issues documented with severity, owner, and resolution timeline. No open P1 or P2 issues.	HCT IT + Vendor PM		
3.17.6.3 The operational handover shall not be considered complete until all checklist items are signed off by both parties. The vendor's project team shall remain available for a minimum of 15 business days after the handover sign-off to address any issues arising from the transition.			FC	
3.17.6.4 The vendor shall provide a formal Project Closure Report summarizing: project scope delivered, deviations from the original plan, lessons learned, outstanding items (if any) with timelines, and recommendations for the operational phase.			FC	
3.18 Configuration Hygiene and Lifecycle Management				
The vendor shall implement a rigorous configuration hygiene program to ensure the SASE platform remains optimized, clean, and free from configuration drift, redundant policies, or orphaned objects throughout the contract period.			FC	
3.18.1 Quarterly Configuration Review and Clean-Up				
3.18.1.1 The vendor shall conduct a comprehensive configuration audit every quarter. The audit shall cover all policy rules, security profiles, user/group mappings, application definitions, URL categories, integration endpoints, certificate stores, and all other configurable elements within the SASE platform.			FC	
3.18.1.2 Unused Policy Identification: The vendor shall identify and flag all security policies, firewall rules, and access rules that have not been triggered or matched by any traffic within the preceding 90-day period. A report of these unused policies must be presented to HCT with a recommendation to disable, archive, or delete.			FC	
3.18.1.3 Orphaned Objects Clean-Up: The vendor shall identify and remove all orphaned configuration objects including: user groups no longer referenced by any policy, IP address objects with no policy association, expired certificates, stale DNS entries, unused URL category overrides, disabled integration endpoints, and			FC	

decommissioned user accounts. A written summary of all objects removed must be provided to HCT.		
3.18.1.4Redundant and Conflicting Policy Detection: The vendor shall use policy analysis tools (vendor-native or third-party) to identify shadowed rules (rules that can never match due to a higher-priority rule), duplicate rules, overlapping rules with conflicting actions, and overly permissive rules. A detailed report with remediation recommendations must be delivered.	FC	
3.18.1.5Policy Rule Optimization: The vendor shall review the ordering and specificity of all policy rules and recommend reordering or consolidation to improve inspection efficiency, reduce latency, and tighten the security posture. Any changes must be tested and approved by HCT before implementation.	FC	
3.18.1.6Certificate and Credential Lifecycle: The vendor shall track all SSL/TLS certificates, SAML certificates, API keys, service accounts, and authentication tokens used by the SASE platform. A quarterly report must list all credentials approaching expiry (within 90 days) and confirm that no expired or revoked credentials remain active.	FC	
3.18.1.7Integration Health Validation: The vendor shall validate the health and operational status of all integrations (IdP, NAC, NGFW, EDR, SIEM, UEM, TIP, ITSM) during each quarterly review. Broken or degraded integrations must be remediated within 5 business days of identification.	FC	
3.18.1.8(Optional ZTNA) ZTNA Application Review: The quarterly configuration audit must include review of all published ZTNA applications to identify: applications that have had zero access sessions in the preceding 90 days (candidates for de-publishing), applications with excessively broad access policies (more users than required), ZTNA connector capacity and utilization, and any private applications that should be published but are being accessed through alternative paths (e.g., legacy VPN if still active).	FC	
3.18.2 Configuration Baseline and Drift Management		
3.18.2.1 The vendor shall establish and maintain an approved configuration baseline (gold standard) for the SASE platform. The baseline shall be documented, version-controlled, and formally approved by HCT at the end of the deployment phase and after each major change.	FC	
3.18.2.2Configuration Drift Detection: The platform must support automated detection of deviations from the approved baseline configuration. Any drift detected must generate an automated alert	PC	The detection is not automated and will need to be

to both vendor operations and HCT IT. The vendor shall remediate unauthorized drift within 4 hours of detection.		checked by the solution admin.																			
3.18.2.3 Configuration Backup: The vendor shall maintain automated daily configuration backups with a minimum retention of 365 days. The vendor must demonstrate the ability to restore the platform to any previous configuration state within 2 hours for P1 incidents.	FC																				
3.18.2.4 Change-Triggered Audit: Every configuration change (whether manual or automated) must be logged with the change requestor, approver, timestamp, description, and before/after configuration diff. These logs must be immutable and available to HCT for audit purposes.	FC																				
3.18.3 Quarterly Configuration Review Deliverables																					
The vendor shall produce and present the following deliverables at each quarterly configuration review meeting:	FC																				
<table border="1"> <thead> <tr> <th>Deliverable</th><th>Description</th><th>Deadline</th></tr> </thead> <tbody> <tr> <td>Configuration Audit Report</td><td>Complete audit of all policies, rules, objects, and configurations including unused/orphaned/redundant items identified and remediation status.</td><td>Q+10 business days</td></tr> <tr> <td>Policy Hit Count Analysis</td><td>Detailed hit-count analysis for all policies showing usage frequency over the preceding quarter. Zero-hit policies flagged with disposition recommendation.</td><td>Q+10 business days</td></tr> <tr> <td>Certificate & Credential Inventory</td><td>Complete inventory of all certificates, API keys, and service accounts with expiry dates and renewal status.</td><td>Q+10 business days</td></tr> <tr> <td>Integration Health Report</td><td>Status of all integrations including connectivity test results, data flow validation, and any degradation observed during the quarter.</td><td>Q+10 business days</td></tr> <tr> <td>Configuration Drift Report</td><td>Summary of all configuration drift events, their root cause, remediation time, and preventive measures implemented.</td><td>Q+10 business days</td></tr> <tr> <td>Remediation Action Plan</td><td>Plan for addressing all findings from the audit including timelines, responsible parties, and risk classification.</td><td>Q+15 business days</td></tr> </tbody> </table>			Deliverable	Description	Deadline	Configuration Audit Report	Complete audit of all policies, rules, objects, and configurations including unused/orphaned/redundant items identified and remediation status.	Q+10 business days	Policy Hit Count Analysis	Detailed hit-count analysis for all policies showing usage frequency over the preceding quarter. Zero-hit policies flagged with disposition recommendation.	Q+10 business days	Certificate & Credential Inventory	Complete inventory of all certificates, API keys, and service accounts with expiry dates and renewal status.	Q+10 business days	Integration Health Report	Status of all integrations including connectivity test results, data flow validation, and any degradation observed during the quarter.	Q+10 business days	Configuration Drift Report	Summary of all configuration drift events, their root cause, remediation time, and preventive measures implemented.	Q+10 business days	Remediation Action Plan
Deliverable	Description	Deadline																			
Configuration Audit Report	Complete audit of all policies, rules, objects, and configurations including unused/orphaned/redundant items identified and remediation status.	Q+10 business days																			
Policy Hit Count Analysis	Detailed hit-count analysis for all policies showing usage frequency over the preceding quarter. Zero-hit policies flagged with disposition recommendation.	Q+10 business days																			
Certificate & Credential Inventory	Complete inventory of all certificates, API keys, and service accounts with expiry dates and renewal status.	Q+10 business days																			
Integration Health Report	Status of all integrations including connectivity test results, data flow validation, and any degradation observed during the quarter.	Q+10 business days																			
Configuration Drift Report	Summary of all configuration drift events, their root cause, remediation time, and preventive measures implemented.	Q+10 business days																			
Remediation Action Plan	Plan for addressing all findings from the audit including timelines, responsible parties, and risk classification.	Q+15 business days																			
3.19 Compliance and Regulatory Requirements																					
3.19.1 UAE National Regulatory Compliance																					
3.19.1.1 The vendor and the SASE platform shall comply with the UAE Information Assurance (IA) Regulation as published by the Telecommunications and Digital Government Regulatory Authority (TDRA), including all applicable IA controls and standards for federal entities.	FC																				
3.19.1.2 The vendor shall demonstrate alignment with the UAE National Cybersecurity Strategy and the requirements of the National Electronic Security Authority (NESA) Compliance Framework as applicable to federal government institutions.	FC																				
3.19.1.3 The vendor shall comply with UAE Federal Decree-Law No. 45 of 2021 regarding the Protection of Personal Data, including all requirements for data processing, data transfer, data subject rights, and breach notification.	FC																				
3.19.1.4 The vendor shall comply with any directives issued by the UAE Cybersecurity Council that are applicable to the SASE services delivered under this contract.	FC																				

3.19.2 International Standards Compliance		
3.19.2.1The SASE platform and the vendor's operational practices shall support HCT's compliance with the following international standards and frameworks: NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-171, ISO/IEC 27001:2022, PCI-DSS v4.0 (where applicable), FERPA (Family Educational Rights and Privacy Act), CIS Controls v8.	PC	
3.19.2.2The vendor shall provide compliance mapping documentation showing how the SASE platform's features and controls map to each of the above frameworks. This mapping must be delivered within 60 days of signing the contract and updated annually.	PC	
3.19.3 Compliance Evidence and Reporting		
3.19.3.1The vendor shall provide to HCT, on an annual basis: renewed ISO 27001 certificate, SOC 2 Type II audit report (full report, not summary), CSA STAR certification, evidence of TDRA/NESA compliance (if applicable), and confirmation of ongoing compliance with UAE data protection law.	PC	
3.19.3.2The vendor shall notify HCT within 5 business days of any regulatory finding, audit qualification, enforcement action, or investigation by any regulatory authority that relates to the SASE platform or the vendor's security practices.	FC	
3.19.3.3 The vendor shall cooperate fully with any HCT internal audit, external audit, or regulatory examination that requires information about the SASE platform, data handling practices, or security controls.	FC	
3.19.4 HCT Information Security Requirements Baseline	FC	
3.20 Business Continuity and Disaster Recovery		
3.20.1 Vendor BCP/DRP Requirements		
3.20.1.1The vendor shall maintain a documented and tested Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) specific to the SASE platform and the services delivered to HCT. The BCP/DRP must be provided to HCT prior to contract signing and updated annually.	FC	
3.20.1.2The vendor shall conduct a full BCP/DRP test at least annually and provide HCT with the test results, including scenarios tested, recovery times achieved, and any identified gaps with remediation plans, within 30 days of each test.	FC	
3.20.1.3Recovery Time Objective (RTO): The vendor shall commit to a maximum RTO of 4 hours for complete platform restoration following	FC	

a catastrophic failure of any single PoP or data centre serving HCT traffic.		
3.20.1.4Recovery Point Objective (RPO): The vendor shall commit to a maximum RPO of 1 hour for configuration data, policy data, and log data. No configuration or policy changes committed within the RPO window shall be lost.	FC	
3.20.1.5The vendor's BCP/DRP must address the following scenarios at minimum: (a) complete failure of a single PoP; (b) simultaneous failure of all PoPs in a geographic region; (c) control plane failure (management console unavailable while data plane continues); (d) vendor cloud infrastructure provider outage; (e) major cybersecurity incident affecting the vendor's own infrastructure; (f) vendor personnel unavailability (pandemic, strike, mass resignation).	FC	
3.20.2 Regional PoP Resilience		
3.20.2.1The vendor shall maintain a minimum of two (2) geographically separated Points of Presence within the UAE/GCC region, each capable of independently handling 100% of HCT's traffic volume.	FC	
3.20.2.2Automatic failover between regional PoPs must occur within 60 seconds with no user- perceptible disruption and no loss of active sessions. The failover mechanism must be tested quarterly and results shared with HCT.	FC	
3.20.2.3The vendor shall notify HCT within 30 minutes of any PoP degradation or failover event and provide a full incident report within 24 hours.	FC	
3.20.2.4(Optional ZTNA) ZTNA Connector Resilience: The BCP/DRP must address ZTNA connector failure scenarios. If all connectors in the Primary on-premises or cloud DC fail, traffic must automatically failover to on-premises or cloud DR DC connectors within 60 seconds. The vendor must demonstrate this failover during the PoC or deployment phase.	FC	
3.20.2.5(Optional ZTNA) ZTNA Fallback: If the ZTNA cloud broker is unavailable for an extended period (> 1 hour), the vendor must provide a documented fallback procedure that allows HCT to temporarily grant direct VPN or alternative access to critical private applications for the 200 ZTNA users, without requiring vendor involvement. This fallback must be pre-configured and tested during deployment.	FC	
3.20.3 HCT Emergency Bypass		

3.20.3.1The vendor shall design the architecture to allow HCT to bypass the SASE inspection path in an emergency scenario without vendor involvement. The bypass mechanism must be documented, tested during deployment, and controlled by HCT IT staff via a pre-configured procedure.	FC	
3.20.3.2The emergency bypass procedure must include defined criteria for when bypass is authorized, which HCT personnel can authorize it, the method of re-engaging SASE inspection after the emergency, and a maximum bypass duration policy.	FC	
3.20.3.3The vendor shall provide HCT with a ‘break glass’ administrator account that is independent of the vendor’s normal authentication infrastructure and can be used by HCT to access the SASE management console even if the vendor’s identity systems are unavailable.	FC	
3.20.4 Force Majeure		
3.20.4.1Force majeure events shall be limited to: natural disasters, acts of war or terrorism, government-mandated shutdowns, and events genuinely beyond the reasonable control of the affected party. The following shall NOT constitute force majeure: vendor staffing shortages, vendor sub-contractor or sub-processor failures, vendor licensing or commercial disputes with their OEM or technology partners, vendor cloud infrastructure provider outages (unless caused by a qualifying force majeure event), or vendor financial difficulties.	FC	
3.20.4.2In the event of a force majeure, the affected party shall notify the other party within 24 hours, provide a detailed mitigation plan within 48 hours, and use all reasonable efforts to resume normal service. If a force majeure event persists for more than 30 consecutive days, either party may terminate the contract with 30 days written notice.	FC	
3.21 Governance Framework		
The vendor and HCT shall establish a formal governance framework for the duration of the contract. The governance structure shall operate at three levels:	FC	

Governance Level	Frequency	Participants (Vendor)	Participants (HCT)	Scope
Operational Review	Monthly	Operations Lead, Technical Lead	IT Infrastructure Team	Ticket review, SLA performance, incident analysis, configuration changes, upcoming maintenance
Service Management Review	Quarterly	Account Manager, Operations Lead, Technical Director	Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network, Specialist Network & Security	SLA trends, capacity planning, configuration audit review, risk register update, roadmap alignment, vendor scorecard review
Strategic Steering Committee	Bi-Annual	Country Manager / Regional Director, Account Director, Technical Director	Director IT, Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network	Contract performance, strategic alignment, technology roadmap, escalated issues, benchmarking results, annual business review

3.21.1 Vendor Performance Scorecard

3.21.1.1 The vendor shall be assessed quarterly against the following Key Performance Indicators (KPIs). The scorecard results shall be presented at the quarterly Service Management Review and form part of the annual strategic review:

KPI Category	KPI Metric	Target	Measurement Method
Availability	Platform uptime (SLA adherence)	> 99.999%	Vendor SLA dashboard + HCT DEM validation
Incident Management	P1/P2 SLA adherence rate	> 98%	Ticket system analysis
Incident Management	Mean Time to Detect (MTTD)	< 5 minutes	SIEM correlation and alert timestamps
Incident Management	Mean Time to Respond (MTTR)	Per SLA matrix	Ticket system analysis
Security Efficacy	False positive rate	< 0.1%	Quarterly sampling and analysis
Security Efficacy	Threat detection rate	> 99%	AMTSO/AV-TEST benchmarking
Operations	Change success rate	> 99%	Change records / rollback analysis
Operations	Configuration drift incidents	< 2 per quarter	Drift detection alerts
Operations	Quarterly config review completion	100%	Deliverable tracking
User Experience	User experience score (DEM)	> 85/100	DEM platform scoring
User Experience	Latency SLA adherence	100%	DEM and synthetic monitoring
Reporting	Monthly report on-time delivery	100%	Report delivery date tracking
Training	Annual training delivery	100%	Training records

FC

3.21.2 Dispute Resolution

3.21.2.1 Disputes arising under this contract shall be resolved through the following escalation ladder:

(a) Level 1 – Operational teams (vendor Operations Lead and HCT Assistant Manager/Manager) shall attempt to resolve the dispute within 5 business days; (b) Level 2 – If unresolved, escalate to senior management (vendor Account Director and HCT Senior Manager IT Infrastructure) within 10 business days; (c) Level 3 – If still unresolved, escalate to executive management (vendor Country Manager and HCT Director IT) within 15 business days; (d) Level 4 – If still unresolved, the parties shall submit the dispute to formal mediation under the rules of the Abu Dhabi Commercial Conciliation and Arbitration Centre; (e) Level 5 – If mediation fails, the dispute shall be referred to binding arbitration under UAE law, with the seat of arbitration in Abu Dhabi.

FC

3.21.2.2 During the dispute resolution process, the vendor shall continue to provide all services under this contract without interruption or degradation.	FC	
3.21.3 Continuous Improvement		
3.21.3.1 The vendor shall propose a minimum of four (4) improvement initiatives per year, aligned with HCT's strategic objectives and industry's best practices.	FC	
3.21.3.2 The vendor shall conduct an annual Threat Landscape Review with HCT, analyzing emerging threats relevant to the higher education sector and recommending adjustments to the SASE security posture accordingly.	FC	
3.22 Audit and Assurance		
3.22.1 HCT Right to Audit		
3.22.1.1 HCT (or a third-party auditor appointed by HCT) shall have the right to audit the vendor's security controls, data handling practices, incident response procedures, compliance posture, and operational processes related to the SASE services delivered under this contract.	PC	Zscaler is being audited by trusted global companies and, with the relevant NDA, Zscaler can share audit findings.
3.22.1.2 Routine audits may be conducted once per year with 30 days written notice. The vendor shall provide full cooperation, including access to documentation, personnel, facilities, and platform data relevant to the audit scope.	PC	Zscaler is being audited by trusted global companies and, with the relevant NDA, Zscaler can share audit findings.
3.22.1.3 In the event of a confirmed or suspected security incident, data breach, or material SLA breach, HCT shall have the right to conduct an immediate audit with 48 hours' notice.	PC	Zscaler is being audited by trusted global companies and, with the relevant NDA, Zscaler can share audit findings.
3.22.1.4 The vendor shall remediate all audit findings classified as Critical within 15 business days, High within 30 business days, and Medium within 60 business days. The vendor shall provide a remediation action plan within 10 business days of receiving audit findings.	PC	Audit findings will be resolved as soon as it's technically feasible

3.22.1.5 All audit costs shall be borne by HCT for routine annual audits. However, if an audit triggered by a vendor-caused incident or SLA breach reveals material deficiencies, the vendor shall bear the cost of the audit.	NC	
3.22.2 Penetration Testing and Vulnerability Assessment		
3.22.2.1The vendor shall conduct an independent third-party penetration test of the SASE platform at least annually and provide HCT with the full report within 30 days of test completion.	FC	
3.22.2.2HCT reserves the right to conduct its own penetration testing or vulnerability assessment of the SASE platform interfaces accessible to HCT, with 30 days written notice to the vendor.	FC	Need to follow a request/approve process
3.22.2.3The vendor shall maintain a vulnerability management program that ensures: (a) critical vulnerabilities (CVSS >= 9.0) are patched within 48 hours; (b) high vulnerabilities (CVSS 7.0-8.9) are patched within 7 days; (c) medium vulnerabilities (CVSS 4.0-6.9) are patched within 30 days.	FC	
3.22.3 Incident Forensics and Evidence Preservation		
3.22.3.1In the event of any security incident, the vendor shall preserve all forensic evidence for a minimum of 12 months or until HCT provides written authorization to destroy the evidence, whichever is longer.	FC	
3.22.3.2The vendor shall provide HCT with a detailed incident timeline within 24 hours of incident detection.	FC	
3.22.3.3The vendor shall cooperate fully with HCT's own forensic investigations and any regulatory or law enforcement investigations arising from a security incident.	FC	
3.22.3.3 Data Breach Notification: The vendor shall notify HCT of any confirmed or suspected data breach affecting HCT data within 1 hour of detection.	FC	
3.22.3.5 The vendor shall maintain online (searchable, queryable) log storage for no less than eight (8) months for all SASE platform logs including: DNS query logs, web access logs, security event logs, firewall logs, RBI/enterprise browser session logs, DEM telemetry, administrative audit logs, and integration event logs. Online logs must be searchable in near-real-time (maximum 5-minute indexing delay) and accessible to HCT administrators via the management console and API. Logs older than 8 months may be moved to archival storage but must remain retrievable within 24 hours upon HCT request for a total retention period of no less than 12 months. Log	FC	

forwarding to HCT's SIEM via syslog (CEF/LEEF) shall operate in real-time independent of the online retention period.		
3.22.4 Configuration Audit Baseline		
3.22.4.1The vendor shall establish an approved security configuration baseline at the end of the deployment phase. This baseline shall be documented, cryptographically hashed, and stored for audit comparison purposes.	FC	
3.22.4.2Any deviation from the approved baseline must be authorized through the formal change management process. Unauthorized deviations shall be treated as a P2 security incident.	FC	
3.22.5 Third-Party Audit Report Sharing		
3.22.5.1The vendor shall provide HCT with copies of all third-party security assessments, penetration test reports, compliance audit findings, and regulatory examination results that relate to the SASE platform, within 30 days of receipt.	FC	
3.22.5.2If any third-party report identifies material findings, the vendor shall provide a remediation plan to HCT within 10 business days.	PC	Audit findings will be resolved as soon as it's technically feasible
3.22.6 Joint Security Exercises		
3.22.6.1The vendor shall participate in annual joint tabletop exercises with HCT, simulating security incident scenarios including: compromised endpoint exfiltrating data through the SASE platform, SASE platform bypass attempt, and advanced persistent threat targeting HCT users. The exercises shall test the end-to-end detection, response, escalation, and remediation processes.	FC	
3.22.6.2The vendor shall support HCT's own red team exercises. If HCT engages a red team to test the overall security posture, the vendor must cooperate fully and shall not treat red team activity as hostile or use it as grounds for SLA exclusion. The vendor shall be notified of red team exercises in advance under NDA.	FC	
3.22.6.3Findings from tabletop and red team exercises shall be documented and tracked in the Risk Register (Section 3.13.8). The vendor shall implement remediation measures for any identified gaps within agreed timeframes.	FC	

7.2 HCT Information Security Requirements Baseline

5	Information Security Requirements	Compliance	Remarks
5.1	Information Security Governance & Policy		
5.1.1	The supplier shall maintain a documented Information Security Management System (ISMS) aligned with an internationally recognized standard (e.g., ISO/IEC 27001, NIST CSF, UAE IA) and provide evidence of certification or compliance upon request.	☒ Yes ☐ No ☐ NA	
5.1.2	The supplier shall comply with applicable national cybersecurity policies and regulations issued by the Cyber Security Council (CSC) and provide evidence of adherence upon request.	☒ Yes ☐ No ☐ NA	
5.1.3	The supplier shall have a formally approved Information Security Policy, reviewed and updated periodically or following significant organisational or threat changes.	☒ Yes ☐ No ☐ NA	
5.1.4	The supplier shall designate a named Information Security Officer (ISO) or equivalent role with defined responsibilities for overseeing the security programme. (incident response, vulnerability, patch, BCDR, continuity, etc)	☒ Yes ☐ No ☐ NA	
5.1.5	The supplier shall ensure that roles and responsibilities and segregation of duties are formally defined, documented, and communicated to all relevant personnel.	☒ Yes ☐ No ☐ NA	
5.1.6	The supplier shall maintain and make available to HCT a current register of all applicable regulatory, legal, and contractual compliance obligations relevant to information security.	☒ Yes ☐ No ☐ NA	
5.1.7	The supplier shall conduct formal security programme reviews at least annually with the supplier's senior management sign-off.	☐ Yes ☐ No ☐ NA	
5.1.8	The supplier shall maintain a security metrics programme and report agreed KPIs/KRIs to HCT on a periodic basis as agreed.	☐ Yes ☐ No ☐ NA	
5.1.9	The supplier shall ensure that all subcontractors and sub- processors are bound by information security obligations no less stringent than those imposed on the supplier by HCT.	☒ Yes ☐ No ☐ NA	

5.2.1	The supplier shall operate a documented information security risk management process aligned with an accepted framework (e.g., ISO 27001, UAE IA) covering identification, assessment, treatment, and monitoring of risks.	☒ Yes ☐ No ☐ NA	
5.2.2	The supplier shall conduct a formal risk assessment (aligned with HCT's IS Risk Management Processes) at least annually and whenever significant changes are made to systems, processes, or the threat landscape pertinent to services provided to HCT.	☐ Yes ☐ No ☐ NA	
5.2.3	The supplier shall maintain a risk register capturing identified risks, likelihood, impact, risk owners, treatment decisions, remediation timelines and residual risk levels pertinent to services provided to HCT.	☐ Yes ☐ No ☐ NA	
5.2.4	The supplier shall define and apply a documented risk acceptance process requiring appropriate senior management authorisation for all accepted risks (pertinent to services provided to HCT) above a defined threshold. [Risk acceptance in this context refers to the time between the identification of the risks and mitigation of the risks.]	☐ Yes ☐ No ☐ NA	
5.2.5	The supplier shall communicate material security risks that may affect HCT's data, operations, or regulatory standing immediately after confirmation.	☒ Yes ☐ No ☐ NA	
5.2.6	The solution shall incorporate security risk considerations in the design, development, operations, and change management lifecycle (Security by Design).	☒ Yes ☐ No ☐ NA	
5.3.1	The solution shall support seamless integration with the HCT Identity and Access Management (IAM) solution.	☒ Yes ☐ No ☐ NA	
5.3.2	The solution shall support role-based access control (RBAC), allowing HCT to assign permissions based on user roles and the principle of least privilege.	☒ Yes ☐ No ☐ NA	
5.3.3	The solution shall support multi-factor authentication (MFA) for all user access to the solution, particularly for privileged, administrative, and remote access.	☒ Yes ☐ No ☐ NA	
5.3.4	The solution shall implement a formal access provisioning and de-provisioning process ensuring access rights are revoked promptly (within 24 hours for terminations) upon role change or departure.	☒ Yes ☐ No ☐ NA	

5.3.5	The solution shall enforce strong authentication policies including minimum password complexity, length (minimum 14 characters), and account lockout after a configurable number of failed attempts.	☒ Yes ☐ No ☐ NA	
5.3.6	The solution shall support integration with HCT's identity provider (e.g., Microsoft Entra ID / Azure AD) via SAML 2.0 or OpenID Connect (OIDC) for Single Sign-On (SSO).	☒ Yes ☐ No ☐ NA	
5.3.7	The supplier shall conduct formal access reviews at least every six months (quarterly for privileged accounts) to validate that all user access rights remain appropriate.	☒ Yes ☐ No ☐ NA	
5.3.8	The solution shall enforce separate privileged access mechanisms (e.g., PAM) for administrative and service accounts, with full session logging.	☒ Yes ☐ No ☐ NA	
5.3.9	The solution shall not permit shared or generic user accounts; all accounts shall be uniquely attributable to an individual.	☒ Yes ☐ No ☐ NA	
5.3.10	The solution shall automatically terminate or lock inactive user sessions after a configurable inactivity timeout period.	☒ Yes ☐ No ☐ NA	
5.2.11	All default vendor-supplied credentials shall be changed before delivery or first use. No hardcoded credentials may exist in any delivered component.	☒ Yes ☐ No ☐ NA	
5.4.1	All HCT data must be encrypted in transit using TLS 1.2 or higher. TLS 1.0 and 1.1 must be disabled.	☒ Yes ☐ No ☐ NA	
5.4.2	All HCT data stored at rest must be encrypted using AES-256 or an equivalent approved cypher.	☒ Yes ☐ No ☐ NA	
5.4.3	HCT data must be stored and processed only within data centres or regions explicitly approved by HCT in writing. Cross- border data transfers require prior HCT approval.	☒ Yes ☐ No ☐ NA	
5.4.4	Upon contract termination or at HCT's request, all HCT data must be returned in a usable format and then securely and verifiably deleted from all vendor systems within 30 days.	☒ Yes ☐ No ☐ NA	
5.4.5	The vendor must not use HCT data for any purpose other than service delivery (e.g., no use for training AI models, analytics, or advertising).	☒ Yes ☐ No ☐ NA	

5.4.6	The solution shall support configurable data retention periods aligned with HCT's requirements, and shall be capable of enforcing automated deletion at the end of retention.	☒ Yes ☐ No ☐ NA	
5.4.7	The supplier shall handle data in accordance with controls aligned with the HCT data classification scheme.	☒ Yes ☐ No ☐ NA	
5.4.8	HCT data shall be stored and processed within data centres and regions explicitly approved by HCT in writing. Cross-border data transfers require prior HCT approval.	☒ Yes ☐ No ☐ NA	
5.4.9	The supplier shall process personal data only in accordance with HCT's documented instructions and applicable data protection laws.	☒ Yes ☐ No ☐ NA	
5.4.10	The supplier shall maintain a current Record of Processing Activities (RoPA) covering all personal data processed on behalf of HCT.	☒ Yes ☐ No ☐ NA	
5.4.11	The solution shall enforce data minimisation principles, collecting and retaining only the minimum personal data necessary.	☒ Yes ☐ No ☐ NA	
5.4.12	The supplier shall implement and maintain documented data retention and secure disposal policies, ensuring data is deleted or destroyed in a verifiable manner.	☒ Yes ☐ No ☐ NA	
5.4.13	The solution shall provide mechanisms to fulfil Data Subject Access Requests (DSARs), right to erasure, and other data subject rights within legally required timeframes.	☒ Yes ☐ No ☐ NA	
5.4.14	The supplier shall conduct Data Protection Impact Assessments (DPIAs) for high-risk processing activities.	☒ Yes ☐ No ☐ NA	
5.4.15	The solution shall prevent unauthorised copying, printing, downloading, or exfiltration of classified data through technical controls (e.g., DLP, access restrictions).	☒ Yes ☐ No ☐ NA	
5.4.16	The supplier shall immediately notify HCT of any personal data breach within the timeframes specified in the contract.	☒ Yes ☐ No ☐ NA	

5.5.1	The solution shall implement network segmentation and zoning principles to separate production, development, and testing environments and to isolate sensitive system components from less trusted networks.	☒ Yes ☐ No ☐ NA	
5.5.2	The solution shall deploy and maintain next-generation firewalls (NGFW) with documented, reviewed, and approved rule sets.	☒ Yes ☐ No ☐ NA	
5.5.3	The solution shall enforce encrypted communications for all data in transit using TLS 1.2 or higher and disable deprecated protocols.	☒ Yes ☐ No ☐ NA	
5.5.4	The solution shall implement intrusion detection and/or prevention systems (IDS/IPS) to detect and alert on or block malicious network activity.	☒ Yes ☐ No ☐ NA	
5.5.5	The solution shall secure all remote access to internal systems via approved encrypted VPN or ZTNA mechanisms with MFA enforced.	☒ Yes ☐ No ☐ NA	
5.5.6	The supplier shall maintain and regularly review network architecture documentation, including data flow diagrams.	☒ Yes ☐ No ☐ NA	
5.5.6	The solution shall implement DNS security controls (DNSSEC, DNS filtering) and email security standards (SPF, DKIM, DMARC).	☒ Yes ☐ No ☐ NA	
5.5.7	The solution shall prohibit unauthorised wireless access points and enforce security controls (WPA3, 802.1X) on approved wireless networks.	☒ Yes ☐ No ☐ NA	
5.5.8	The solution shall implement DDoS mitigation controls or services to protect the availability of internet-facing services.	☒ Yes ☐ No ☐ NA	

8 Part 5- Statement of work

This Statement of Work (“SOW”), effective as latter date of execution (“SOW Effective Date”), is entered into between the customer and Inspira, a company incorporated, having its registered offices.

Inspira Professional Services described in this SOW (“Services”) are based on Inspira’s understanding of tasks related to the Zscaler solution in the customer’s network and its requirements.

The following workstreams are in scope for this engagement:

#	Workstream	Description
1	Identity Integration & ZCC Enrolment	Configure ZIdentity federation with the customer's IdP (SAML 2.0 / SCIM). Enrol all 2,719 users via Zscaler Client Connector (ZCC) with automated device enrolment and user provisioning.
2	ZIA Business Edition Baseline	Tenant baseline, location hierarchy, SSL/TLS inspection policy, URL filtering, DNS security, Cloud Firewall standard ruleset, and Cloud App Control visibility, backed by Extended Log Store retention.
3	Cyber Threat Protection — Sandbox & Firewall Advanced	Configure Advanced Sandbox for unknown file analysis and zero-day protection, and Advanced Cloud Firewall policies for inline threat prevention across all users.
4	Secure AI Access	Discover and classify Generative-AI application usage; configure granular access, isolation, and DLP controls for sanctioned and unsanctioned AI tools.
5	Zero Trust Browser Advanced	Deploy browser isolation policies for high-risk categories, unmanaged devices, and third-party/BYOD access, covering the licensed browser session pool.
6	ZDX Advanced Plus	Deploy Digital Experience Monitoring across 2,719 users — endpoint, network, and application performance monitoring with proactive alerting.
7	Zscaler Private Access (ZPA)	Deploy ZPA Platform, Segmentation, and Legacy App support (VoIP/S2C) for 200 users — private application access, micro-segmentation, and legacy protocol enablement.

8.1 Identity Integration & ZCC Enrolment

- Configure ZIdentity federation with the customer's identity provider (Azure AD, ADFS, or equivalent) via SAML 2.0 / SCIM.
- Provision user and group objects via SCIM for automated user lifecycle management.
- Deploy Zscaler Client Connector (ZCC) to all 2,719 users — enrolment via MDM (Intune/SCCM) or manual deployment per the customer's endpoint management capability.
- Validate ZCC enrolment, tunnel-up status, and ZIA policy enforcement.

8.2 ZIA Business Edition Baseline

- Tenant baseline: organisation hierarchy, locations, and sub-locations aligned to network topology.
- SSL/TLS inspection: decryption policy, bypass list, and certificate deployment guidance.
- URL filtering: category-based policies aligned to acceptable use requirements.
- DNS security: DNS control, sinkhole policy, and DNS-layer threat prevention.
- Cloud Firewall: standard outbound traffic controls and application-aware policies.
- Cloud App Control / Shadow IT visibility: application discovery and risk-tiered reporting.
- Extended Log Store activation for extended retention and reporting.

8.3 Cyber Threat Protection — Sandbox & Firewall Advanced

- Configure Advanced Sandbox policies for unknown file analysis, malware, and zero-day threat prevention.
- Configure Advanced Cloud Firewall policies for inline threat protection across all user traffic.
- Tune sandboxing quarantine and file-type inspection rules with the customer's security team.
- Validate threat protection policies with test scenarios before production enforcement.

8.4 Secure AI Access

- Discover and classify Generative-AI application usage across the user base.
- Configure granular access controls (allow/isolate / block) for sanctioned and unsanctioned AI tools.
- Configure DLP controls for sensitive data entered into AI prompts and file uploads.
- Produce an AI application risk visibility report for customer security review.

8.5 Zero Trust Browser Advanced

- Configure browser isolation policies for high-risk categories and unmanaged/BYOD access.
- Configure session controls: copy/paste, upload/download, watermarking, and clipboard restrictions as required.
- Validate isolation policies against the licensed browser session pool.

8.6 ZDX Advanced Plus

- Deploy ZDX across all 2,719 users for endpoint, network path, and application performance monitoring.
- Configure ZDX Score baselines, alerting thresholds, and Deep Tracing for priority applications.
- Provide initial digital experience baseline report to the customer IT team.

8.7 Zscaler Private Access (ZPA)

- Deploy ZPA Platform: App Connectors, App Segments, Access Policies, and Client Connector integration for 200 users.
- Configure ZPA Segmentation for micro-segmentation of private application access.
- Configure ZPA support for Legacy Apps (VoIP, Server-to-Client, and other non-web protocols) as required.
- Validate private application access, connector high availability, and policy enforcement.

9 Implementation & Migration Approach

Inspira follows a phased implementation and migration approach designed to move the customer from current-state connectivity to a fully validated Zscaler Zero Trust architecture with minimal business disruption:

- Discover & Design — Gather network topology, IdP details, application inventory, and produce a Detailed Design Document (DDD) that is reviewed and signed off before configuration begins.
- Foundation Build — Stand up ZIdentity federation, ZIA Business Edition baseline, and begin phased ZCC enrolment in monitor-only mode to validate traffic visibility before enforcement.
- Security Layer Rollout — Progressively enable Cyber Threat Protection, Secure AI Access, and Zero Trust Browser Advanced policies, moving from alert-only to enforcement mode after validation with a pilot user group.
- Experience & Access Layer — Deploy ZDX monitoring in parallel, followed by ZPA application onboarding in controlled batches (pilot app segments first, then phased rollout to the full 200-user population), running alongside existing access methods until cutover is confirmed.
- Cutover & Decommission — Once pilot validation is complete for each workstream, extend enforcement to the full user population and coordinate decommissioning of legacy access paths (e.g., VPN) with the customer's change control process.
- Validate & Transition — Execute UAT across all workstreams, tune policies based on findings, and complete Knowledge Transfer and formal sign-off.

This phased, pilot-first approach is applied consistently across ZIA, ZPA, CTP, Secure AI Access, and ZTB workstreams to de-risk enforcement changes and ensure business continuity throughout the 3-month engagement.

10 Project Plan – 3 Months

All activities are delivered remotely by an Inspira PS engineer.

Phase	Timeline	Key Activities	Milestone
1	Month 1 – Weeks 1–2	Kick-off with Customer IT and Inspira. Tenant provisioning verification. Collect IdP details (Azure AD/ADFS/Okta), network topology, user group structure, and application inventory. Confirm ZCC deployment method (MDM/SCCM/manual). Produce Detailed Design Document (DDD). Begin ZIdentity/SAML/SCIM federation and ZIA Business Edition baseline configuration.	DDD signed off · IdP details confirmed · ZCC deployment plan agreed
2	Month 1 – Weeks 3–4	Complete ZIA Business Edition baseline: location hierarchy, SSL/TLS inspection, URL filtering, DNS security, Cloud Firewall, Cloud App Control. Extended Log Store activation. ZCC enrolment rollout across 2,719 users. PAC file generation and validation.	ZIA Baseline live · ZIdentity active · ZCC enrolment underway
3	Month 2 – Weeks 5–6	Configure Cyber Threat Protection: Sandbox Advanced (file analysis, zero-day protection) and Firewall Advanced (inline threat prevention). Configure Secure AI Access policies for GenAI application visibility and control. Internal testing and validation.	CTP Sandbox & Firewall configured · Secure AI Access policies active
4	Month 2 – Weeks 7–8	Deploy Zero Trust Browser Advanced isolation policies. Deploy ZDX Advanced Plus across all 2,719 users – endpoint/network/application monitoring configured and validated.	ZTB Advanced deployed · ZDX Advanced Plus live
5	Month 3 – Weeks 9–10	Deploy ZPA Platform for 200 users: application segments, connectors, and access policies. Configure ZPA Segmentation and Legacy App support (VoIP/ S2C). Activate Support Plus coverage.	ZPA Platform, Segmentation & Legacy App access live for 200 users
6	Month 3 – Week 11	UAT across all workstreams with representative users. Collect and consolidate UAT findings. Policy tuning and false-positive remediation across ZIA, CTP, AI Access, ZTB, ZDX, and ZPA.	UAT complete
7	Month 3 – Week 12	Final validation across all workstreams. Knowledge Transfer (KT) sessions with customer IT admins. Deliver Operational Runbook, As-Built Configuration Document, and SOPs. Formal project closure review and sign-off.	All users live · KT complete · As-Built delivered · Project signed off.

Note: Week-by-week timing is indicative across the 3-month engagement. Activities within a phase may run in parallel where dependencies allow. Final schedule is confirmed at Week 1 kick-off. Timeline extensions due to delayed information provision by the Customer are subject to a Change Order.

11 BOQ

SN	ProductName	Description	Quantity	Tenure
----	-------------	-------------	----------	--------

1	ZIA-BIZ- EDITION	ZIA-BIZ-EDITION ZIA Business Edition Term: 01/01/2027 to 12/31/2029	2,719	3 Year
2	ZSC-LOG- EXTSUBS	ZSC-LOG-EXTSUBS Extended Log Store Term: 01/01/2027 to 12/31/2029	2,719	3 Year
3	ZDX-ADV-PLUS	ZDX-ADV-PLUS ZDX Advanced Plus Term: 01/01/2027 to 12/31/2029	2,719	3 Year
4	ZS-CTP- SANDBOX	ZS-CTP-SANDBOX Zscaler Inline Cyber Threat Protection- Sandbox Advanced Term: 01/01/2027 to 12/31/2029	2,719	3 Year
5	ZS-CTP- FIREWALL	ZS-CTP-FIREWALL Zscaler Inline Cyber Threat Protection- Firewall Advanced Term: 01/01/2027 to 12/31/2029	2,719	3 Year
6	ZS-AI-ACCESS- PRE	ZS-AI-ACCESS-PRE Secure AI Access Term: 01/01/2027 to 12/31/2029	2,719	3 Year
7	ZT-BROWSER- ADV	ZT-BROWSER-ADV Zero Trust Browser Advanced Term: 01/01/2027 to 12/31/2029	29,022	3 Year
8	ZS-ZPA- PLATFORM	ZS-ZPA-PLATFORM Zscaler Private Access Platform Term: 01/01/2027 to 12/31/2029	200	3 Year
9	ZS-ZPA-VPN	ZS-ZPA-VPN ZPA for Legacy Apps (VOIP S2C etc.) Term: 01/01/2027 to 12/31/2029	200	3 Year
10	ZS-ZPA-SEGM	ZS-ZPA-SEGM Zscaler Private Access: Segmentation Term: 01/01/2027 to 12/31/2029	200	3 Year
11	ZS-TEST-ENV	ZS-TEST-ENV Zscaler Test Environment Term: 01/01/2027 to 12/31/2029	1	3 Year
12	ZCES-SUP-PLUS	ZCES-SUP-PLUS Zscaler Support Plus Term: 01/01/2027 to 12/31/2029	1	3 Year
14	ZCES-EDU- CREDIT	ZCES-EDU-CREDIT Zscaler Education Credits	16	Training Credits
14	Zscalar-SL-PS	Zscalar-SL-PS Zscalar Professional Services based on the BOQ	1	One Time Service
15	Zscalar-SL-PS	Zscalar-SL-PS Zscalar Resident Engineer for 1 Year Invoicing Terms - Monthly in Advance	1	1 Year

16	SL-Care- Standard	SL-Care-Standard One year 8*5 Unlimited technical support, 24*7 is for P1 cases only. Quarterly Health Check.	1	1 Year
17	Zscaler-SL-PS	Zscaler-SL-PS Onsite Project manager	1	1 Year
18	Zscaler-SL-CS- Basic	Zscaler-SL-CS-Basic 50 mandays of post implementation support	1	One Time Service

12 Proposed Team Structure

Role	Responsibilities	Mode
PS Lead Consultant	Owns all technical configuration across ZIA, ZPA, ZDX, CTP, Secure AI Access, and ZTB. Single point of technical accountability for the engagement.	Remote
Inspira Partner Coordinator	Facilitates Customer stakeholder access, IdP and network information gathering, and deployment logistics coordination.	Remote / Onsite
Customer IT Point of Contact	Provides access credentials, network information, endpoint management access, application inventory, and UAT sign-off.	Customer-side

Working Hours: Remote sessions are conducted during Customer standard working hours (Monday to Friday, 0900–1700 hrs). Out-of-hours sessions require advance written agreement from both parties.

13 Assumptions

- Zscaler licenses/subscriptions are considered for a 3-year tenure from 01 January 2027 to 31 December 2029, as per the BOQ.
- Zscaler Professional Services are considered as a one-time implementation service based on the agreed BOQ and standard OEM recommendations.
- Resident Engineer services are considered for 1 year, with monthly invoicing in advance. This can be mutually accepted and extended.
- Onsite Project Manager services are considered for 1 year. This can be mutually accepted and extended.
- Standard Care support is considered for 1 year, including 8x5 unlimited technical support, 24x7 support for P1 incidents, and quarterly health checks. This can be mutually accepted and extended.
- Post-implementation support is considered as a one-time service of 50 man-days.
- Zscaler Education Credits are considered as per the BOQ and are subject to OEM training availability.
- All services are assumed to be delivered remotely unless explicitly stated otherwise. Any additional onsite services, resources, integrations, migration, or activities beyond the defined scope will be treated as a Change Request and quoted separately.
- The Zscaler tenant is provisioned by Zscaler and Admin Portal access is granted to Inspira PS engineers before Week 1 kick-off.
- Customer holds valid Zscaler licenses (as per the BOM in Section 2) for all in-scope users before the engagement commences.
- IdP details (SAML metadata, SCIM endpoint, AD group structure) are provided before Month 1 configuration begins.
- The customer's endpoint management team provides MDM/SCCM access or deployment support for ZCC rollout.
- Customer IT is responsible for deploying ZCC to endpoints under Inspira's guidance; remote desktop access or screen-sharing support is made available for troubleshooting.
- All remote sessions are conducted over a stable video/screen-share platform agreed between parties (Teams/

Zoom/WebEx).

14 Dependencies

- Timely provisioning of the Zscaler tenant, ZIA/ZPA/ZDX admin console access, and license activation by Zscaler before kick-off.
- Customer's network team to confirm and, where required, update firewall/proxy egress rules to support ZIA, ZPA App Connector, and ZDX cloud connectivity.
- Customer's IT security team to define DLP, AI-access, and browser-isolation policy requirements within the timelines set out in Section 5.
- Customer's endpoint management team (Intune/SCCM/MDM) to have management coverage sufficient for ZCC deployment to the in-scope device population.
- Availability of Customer IT and business stakeholders for design workshops, pilot testing, and UAT sign-off within the agreed project plan windows.
- Inspira to coordinate commercial, licensing, and escalation matters between Inspira and Customer.
- Any delay in the above dependencies may impact the 3-month timeline and is subject to a Change Order.

15 Out of Scope

- Zscaler modules or SKUs not listed in the Bill of Materials in Section 2.
- On-premises hardware installation, network re-architecture, or firewall/router changes beyond the egress rule guidance required for Zscaler connectivity.
- Active Directory / Azure AD tenant configuration — the customer owns IdP administration; Inspira provides integration guidance only.
- End-user helpdesk, device support, or ZCC troubleshooting beyond initial deployment validation.
- Custom application development or non-standard API integrations beyond the packaged Secure AI Access and CASB-style connectors covered in Section 3.
- Additional users beyond 2,719 (ZIA/ZDX/CTP/AI Access/ZTB) or 200 (ZPA) without a Change Order.
- Any effort beyond the 3-month engagement duration without a signed Change Order.
- Procurement or licensing of Zscaler or any other product.
- On-site presence — this is a fully remote delivery engagement

16 Project Change Request Form Procedure

- A Project Change Request may be initiated by either party. It may also be used to extend the expiration date of the SoW or purchase additional PS consulting days.
- The customer's project manager and the Inspira project manager will review the proposed change(s) and recommend it for further investigation or reject it.
- If the agreement is not reached within (5) calendar days of the response to the requested change, the parties may elect to:
 - Proceed without the requested change
 - Continue negotiating the change
 - Escalate to upper management
- Once the change is agreed to, a project change request must be signed by authorized representatives from both parties to authorize implementation of the requested changes. Until a project change request is fully executed by the parties, the services will continue in accordance with the latest agreed version of SoW.

17 Place(s) of Performance

Inspira will implement the above solution. Inspira will update the customer once per week (day and time TBD) for a weekly status meeting based on requirement.

Inspira Resource(s) will work a normal workday of (8) hours and will adhere to Customer's local business hours. In addition, Inspira resources will adhere to the local Inspira office holiday schedule. Any services performed after hours (8 pm to 8 am) and on weekends must be approved in advance by Inspira Professional Service Management and will be assessed at 1.5x per hour worked. For example, if a resource is requested to work after hours for an additional two (2) hours, three (3) hours will be charged against any existing PS Consulting days, or if additional time is needed, a project change request and purchase order will be required to cover the additional time required before exceeding the PS Consulting days purchased.

If Customer reschedules the services within two (2) weeks of the scheduled services, Customer will be charged two (2) full business days from any existing PS Consulting days. If additional time is required to cover the cancellation or rescheduling of the services, a project change request and purchase order will be required to cover the additional costs.

18 Deliverables

The following deliverables will be produced during the project's timeframe:

- Implementation & Deployment of solution components in production.
- High-level Design Documentation
- As-Built documentation.

The Project Engineer will share daily updates of the progress to the end user, and in case the end user does not provide confirmation within 2 business days, then the delivery will be deemed as accepted by the end user.

19 Miscellaneous

Project kick off meeting will be scheduled four (4) weeks from the date of the PO, provided Inspira has received the signed SOW. Please note the signed SOW needs to be shared with the Inspira resource at least 2 weeks prior to the kickoff.

The PS Consulting days must be utilized within six (6) months from the last signature date set forth below (“SOW Effective Date”). Any hours/days remaining following the six months will expire, along with any obligation to deliver any further services unless otherwise mutually agreed to in writing.

IN WITNESS WHEREOF, the parties hereto have executed this SOW as of the SOW Effective Date.

20 Clientele



21 Past Project Success and References

Cybersecurity Transformation for Energy Sector – Dana Gas

Overview

- Leading regional energy company with distributed users requiring secure access to internet and private applications.
- Objective to modernize network security and enable a Zero Trust architecture using Zscaler cloud security services.
- Inspira delivered deployment and implementation services for ZIA, ZPA, and ZDX platforms for approximately 200 users.

Challenge

- Legacy security architecture requiring modernization.
- Need for secure internet access and private application access for remote users.
- Requirement for data protection, SSL inspection, and centralized policy management.
- Limited visibility into user experience and application performance.

Solution

- Implemented Zscaler Internet Access (ZIA) with traffic forwarding, authentication integration, SSL inspection, advanced security policies, reporting, and pilot rollout.
- Implemented Zscaler Private Access (ZPA) for secure Zero Trust access to internal applications.
- Configured Zscaler Digital Experience (ZDX) for user and application performance monitoring.
- Integrated Single Sign-On (SSO), DLP policies, log forwarding, and best-practice security configurations.

Customer Benefit

- Established a cloud-native Zero Trust security framework.
- Enhanced protection of users, applications, and sensitive data.
- Improved visibility into user activity, application performance, and security events.
- Reduced dependence on traditional perimeter security while enabling secure remote access.
- Standardized security policies and strengthened overall cybersecurity posture

Cybersecurity Modernization for Diversified Enterprise Group – Easa Saleh Al Gurg Group

Overview

- One of the UAE's leading diversified business groups operating across multiple industries and business units.
- Required a scalable cloud security platform to protect thousands of users while simplifying internet security management.
- Inspira implemented a Zscaler-based Secure Internet Access solution with ongoing managed value-added support services.

Challenge

- Large distributed workforce requiring secure internet access across multiple business entities.
- Need for centralized web security and protection against modern cyber threats.
- Requirement to protect sensitive corporate data and ensure policy consistency across locations.
- Limited internal resources for continuous policy tuning and platform optimization.

Solution

- Deployed Zscaler Internet Access (ZIA Transformation Edition) for 2,300 users.
- Implemented Zscaler Data Protection (DLP) controls for sensitive information security.
- Enabled centralized cloud-based Secure Web Gateway (SWG) capabilities.
- Provided annual value-added expert services including policy creation, policy optimization, DLP tuning, and new Zero Trust use-case configuration.
- Delivered remote security advisory and technical support services for ongoing platform enhancement.

Customer Benefit

- Enhanced protection against web-based threats and malware.

- Centralized and standardized security policy enforcement across the enterprise.
- Improved visibility and control over internet usage and data movement.
- Reduced operational burden on internal IT and security teams.
- Increased agility through rapid implementation of new Zero Trust access requirements.
- Strengthened overall security posture while supporting business growth and digital transformation.

Cybersecurity Transformation for Digital Banking – Al Maryah Community Bank (Mbank)

Overview

- A leading digital-first banking institution focused on delivering secure and seamless banking services.
- Required secure privileged access to critical banking applications while adhering to Zero Trust security principles.
- Inspira implemented Zscaler Privileged Remote Access (PRA) to provide secure, controlled, and auditable access for privileged users and administrators.

Challenge

- Need to secure privileged access to critical banking systems and applications.
- Requirement to reduce exposure of administrative accounts and sensitive resources.
- Need for secure remote access without traditional VPN dependencies.
- Requirement for granular access control and enhanced visibility into privileged user activities.

Solution

- Implemented Zscaler Privileged Remote Access (PRA) for secure administrative access.
- Configured PRA user portal and application segments for controlled access to banking applications.
- Established Zero Trust access policies and security best practices.
- Conducted pilot deployment and rollout for privileged users.
- Delivered remote implementation, testing, handover, and as-built documentation.

Customer Benefit

- Strengthened security for privileged and administrative accounts.
- Eliminated risks associated with traditional network-level access methods.
- Improved visibility and control over privileged sessions.
- Reduced attack surface through application-level access segmentation.
- Enabled secure remote administration aligned with Zero Trust principles.
- Enhanced regulatory compliance and security governance for critical banking systems.

22 Indicative Profiles

inspira®

Project Manager- Z-Scaler

Summary

Experienced Project Manager with **8+ years** of expertise in managing large-scale and complex cybersecurity deployment projects. Skilled in project planning, risk management, stakeholder engagement, and cross-functional coordination. Proven ability to lead high-profile customer engagements, mentor project teams, and deliver successful outcomes while ensuring quality, timelines, and customer satisfaction.

Engagements

- Managed **large and complex customer deployment projects**, ensuring successful delivery within the defined scope, schedule, budget, and quality standards.
- Proactively identified, assessed, and mitigated **project risks and issues**, implementing effective mitigation strategies to minimize deployment delays and ensure project success.
- Led **pilot implementations of new technologies and Professional Services offerings**, validating deployment approaches and supporting continuous service improvements.
- Planned, monitored, and tracked **project milestones, deliverables, dependencies, and resource utilization** throughout the project lifecycle to ensure timely completion.
- Coordinated with **customers, consultants, engineers, and cross-functional teams** to facilitate seamless communication and successful project execution.
- Mentored and guided **new team members** on departmental processes, project management methodologies, and best practices to support their professional development.
- Drove **project governance activities**, including stakeholder communication, status reporting, change management, issue tracking, and executive-level project reviews.
- Managed **project scope, timelines, quality, and customer expectations**, ensuring alignment with contractual deliverables and organizational objectives.
- Led **cross-functional meetings and customer discussions**, facilitating decision-making, resolving project challenges, and maintaining stakeholder alignment. Ensured successful project delivery by maintaining **high customer satisfaction**, delivering quality outcomes, and fostering strong customer relationships throughout the engagement.
- Worked closely with internal teams to **optimize project execution**, improve delivery processes, and ensure effective coordination across multiple stakeholders.
- Supported continuous improvement initiatives by identifying opportunities to enhance project management practices, delivery efficiency, and overall customer experience.

Skills & Knowledge

- Advanced Project Management
- Zscaler Product Knowledge
- Communication & Stakeholder Management
- Risk & Opportunity Management
- Negotiation Skills
- Leadership & Team Mentoring

Industry Experience

- Cybersecurity
- Professional Services
- Enterprise IT
- Cloud Security
- Project Delivery
- Customer Engagement

Domain Knowledge

- Project Management
- Risk & Issue Management
- Stakeholder Management
- Resource Planning
- Customer Deployment
- Cross-functional Coordination
- Professional Services

Soft Skills

- Leadership
- Communication
- Negotiation
- Problem Solving
- Decision Making
- Team Mentoring
- Stakeholder Management
- Cross-functional Collaboration

Certifications

- PMP (Project Management Professional)
- PRINCE2 Practitioner

inspira®

Senior Consultant - Z-Scaler

Summary

Experienced Zscaler Professional Services Consultant with **8+ years** of experience in designing, deploying, and supporting Zscaler security solutions for enterprise customers. Strong expertise in ZIA, ZPA, and ZDX deployments, cloud security, customer engagement, solution implementation, and project delivery. Proven ability to independently execute complex deployments while collaborating with cross-functional teams to ensure successful customer outcomes and high CSAT.

Engagements

- Successfully deployed and implemented **ZIA, ZPA, and ZDX** solutions for enterprise customers, ensuring seamless integration with existing network and security environments.
- Provided technical deployment guidance and implementation support to consultants, promoting best practices and ensuring consistent project delivery.
- Contributed to **Zscaler Professional Services SME initiatives** by sharing technical knowledge and supporting continuous service improvement.
- Defined project scope, identified scope variations, and aligned customer expectations with the agreed Professional Services deliverables.
- Reproduced and analysed customer-reported issues, documenting findings and collaborating with Zscaler Support, Engineering, and Operations teams for timely resolution.
- Supported deployment automation and operational efficiency using **scripting, APIs, and Terraform**, streamlining implementation activities where applicable.
- Worked closely with Project Managers to track project milestones, monitor progress, manage dependencies, and ensure timely delivery.
- Mentored junior consultants by providing technical guidance, knowledge sharing, and support during customer deployment engagements.
- Independently managed and delivered customer deployment projects while maintaining high service quality and customer satisfaction.
- Collaborated effectively with cross-functional teams, including Project Managers, Technical Consultants, Sales Engineers, TAMs, and Customer Success Managers, to ensure successful project execution and customer success.
- Prepared and maintained deployment documentation, implementation guides, and technical knowledge artifacts to support successful project delivery.
- Worked closely with internal delivery, engineering, and customer teams to resolve technical challenges and ensure timely project completion.

Tools & Frameworks

- ZIA, ZPA, ZDX
- DLP
- CASB
- Terraform
- APIs
- Scripting (Python, PowerShell)
- Cloud Security
- Zero Trust Architecture

Industry Experience

- Enterprise IT
- Cloud Security
- Network Security
- Professional Services
- Cybersecurity Consulting

Domain Knowledge

- ZIA, ZPA, ZDX
- Zero Trust, Cloud & Network Security
- Professional Services

Soft Skills

- Customer Communication
- Project Coordination
- Problem Solving
- Technical Documentation
- Team Collaboration
- Mentoring & Knowledge Sharing
- Stakeholder Management
- Time Management

Certifications

- Zscaler Internet Access (ZIA) Professional
- Zscaler Private Access (ZPA) Professional
- ZIA Delivery Specialist
- ZPA Delivery Specialist

Service Delivery Manager

Summary

Experienced Service Delivery Manager with 10+ years of expertise in managing enterprise cybersecurity managed services and ensuring service excellence. Skilled in SLA governance, stakeholder management, incident and escalation management, service reporting, and continuous service improvement. Proven ability to manage customer engagements while maintaining high service quality and operational efficiency.

Industry Experience

- Cybersecurity
- Cloud Security
- Enterprise IT
- Professional Services
- Network Security

Domain Knowledge

- Zscaler Internet Access (ZIA)
- Zscaler Private Access (ZPA)
- Secure Access Service Edge (SASE)
- Cloud Security Architecture
- Technical Design Review
- Security Integration

Soft Skills

- Leadership
- Technical Consulting
- Customer Communication
- Problem Solving
- Team Mentoring
- Decision Making

Engagements

- Managed end-to-end delivery of enterprise cybersecurity managed services, ensuring compliance with agreed SLAs, KPIs, and contractual commitments.
- Governed service performance through regular operational reviews, monthly service reports, executive dashboards, and customer governance meetings.
- Proactively managed service risks, customer escalations, and critical incidents to ensure timely resolution and minimal business impact.
- Coordinated with technical delivery teams, OEM support, and customer stakeholders to ensure seamless service execution and operational excellence.
- Led service transition, knowledge transfer, and stabilization activities to ensure smooth onboarding of new managed services.
- Monitored service quality, customer satisfaction, and operational metrics while driving continuous service improvement initiatives.
- Conducted periodic service review meetings with customers to discuss performance, improvement opportunities, action plans, and future roadmap.
- Worked closely with project managers and solution architects during implementation to ensure successful transition into BAU support.
- Managed change requests, service governance activities, resource planning, and operational compliance throughout the engagement lifecycle.
- Established strong customer relationships by acting as the primary point of contact for service delivery, escalations, and strategic service discussions.

Skills & Knowledge

- ZIA
- ZPA
- Cloud Security
- SASE
- Security Architecture
- OEM Coordination

Certifications

- Zscaler Certified Administrator (Preferred)
- Zscaler Certified Architect (Preferred)

23 Vendor Point of Contact

Country Head - MEA

Contact	Sunil Krishnarao
Address	201 & 204, 2nd Floor, Al Moosa Tower 2, Shaikh Zayed Road, Dubai, UAE
Phone	+971521903533
Email	sunil.krishnarao@inspiraenterprise.com

Account Manager • MEA Sales

Contact	Sanjay Krishnamurthy
Phone	+971585141909
Email	sanjay.krishnamurthy@inspiraenterprise.com

- End of Document -